



# Azure Open AI

## Foundational Privacy Impact Assessment

April 2024

# Table of Contents

|                                                                         |            |
|-------------------------------------------------------------------------|------------|
| About The Assessor .....                                                | 3          |
| Table of Acronyms .....                                                 | 5          |
| <b>Executive Summary.....</b>                                           | <b>7</b>   |
| <b>Part 1: Context of Assessment.....</b>                               | <b>10</b>  |
| <b>Part 2: Solution Description.....</b>                                | <b>15</b>  |
| A. Introduction .....                                                   | 15         |
| B. Foundation AI Models and Use Cases .....                             | 18         |
| C. Customization/Fine Tuning .....                                      | 24         |
| D. Deploying a Model .....                                              | 26         |
| E. Conversations .....                                                  | 28         |
| F. Prompt Construction.....                                             | 29         |
| G. Generating or Manipulating Text.....                                 | 30         |
| H. Working with Codex.....                                              | 32         |
| I. Support for Azure OpenAI.....                                        | 33         |
| <b>Part 3: AI Safety Measures .....</b>                                 | <b>35</b>  |
| A. Registration .....                                                   | 35         |
| C. Code of Conduct .....                                                | 35         |
| D. Abuse Monitoring .....                                               | 38         |
| E. Content Filtering .....                                              | 39         |
| F. Red Teaming .....                                                    | 41         |
| G. Monitoring .....                                                     | 42         |
| <b>Part 4: Personal Information .....</b>                               | <b>46</b>  |
| A. Data Flows.....                                                      | 46         |
| B. Data Elements within Flows.....                                      | 49         |
| C. Data Elements Within Microsoft Entra ID.....                         | 51         |
| D. Data Elements Within Diagnostic Data .....                           | 52         |
| <b>Part 4: Privacy Analysis .....</b>                                   | <b>53</b>  |
| A. Introduction .....                                                   | 53         |
| B. Agreements.....                                                      | 54         |
| C. Data Residency.....                                                  | 66         |
| C1. Legislative/Policy Requirements .....                               | 66         |
| C2. Analysis .....                                                      | 73         |
| D. Guidance on the Use of Cloud Computing Services.....                 | 75         |
| D1. The Canadian Landscape .....                                        | 75         |
| D2. Treasury Board Guidance on the Use of Cloud Computing.....          | 76         |
| E. Guidance on the Use of Generative AI (for Federal Institutions)..... | 83         |
| F. Privacy Authorities' Guidance on the Responsible Use of AI .....     | 87         |
| G. Privacy Considerations and Risks in the Use of Generative AI.....    | 91         |
| H. Privacy Act (Canada) .....                                           | 96         |
| I. Provincial Public Sector Legislation - FIPPA (Ontario) .....         | 98         |
| J. Provincial Health Sector Legislation – PHIPA (Ontario).....          | 108        |
| K. Necessity and Proportionality Test (Federal Institutions).....       | 119        |
| L. Private Sector Legislation – CSA Code.....                           | 120        |
| M. Québec Private Sector Law .....                                      | 133        |
| <b>Annex A – Microsoft Security Controls.....</b>                       | <b>147</b> |

## About The Assessor

This report was written by Michael Power, who providing legal, strategic, and operational advice to private, public, and healthcare sector customers on issues related to privacy, information governance, artificial intelligence, and emerging technologies.

Michael Power has written extensively on privacy and information security issues. He is the author of The Law of Privacy (2013, 2017, 2021 editions) as well as the Access to Information and Privacy Title of Halsbury’s Laws of Canada (2005, 2011, 2016, 2020 and 2024 editions). He is also the co-author of the American Bar Association’s Sailing in Dangerous Waters: A Director’s Guide to Data Governance (2004).

Michael Power is a member of the Law Society of Upper Canada and the Canadian Bar Association. He served an adjunct professor at Osgoode Hall Law School, teaching privacy law, from 2012-2022.

June 2024

## INDEX OF TABLES

|                                                             |    |
|-------------------------------------------------------------|----|
| TABLE 1: ACRONYMS .....                                     | 6  |
| TABLE 2: MODELS WITHIN SCOPE OF FPIA .....                  | 11 |
| TABLE 3: DOMAINS WITHIN SCOPE.....                          | 12 |
| TABLE 4: AZURE OPEN AI MODELS .....                         | 21 |
| TABLE 5: EMBEDDING MODELS .....                             | 24 |
| TABLE 6: FINE TUNING HYPERPARAMETERS .....                  | 25 |
| TABLE 7: CONTENTS OF FINE-TUNING RESULTS FILE .....         | 26 |
| TABLE 8: CHOICES TO DEPLOY AN AZURE OPENAI MODEL .....      | 27 |
| TABLE 9: EXAMPLES OF LEARNING TYPES .....                   | 30 |
| TABLE 10: HARMFUL CONTENT CATEGORIES .....                  | 39 |
| TABLE 11: HARMFUL CONTENT RATINGS .....                     | 40 |
| TABLE 12: DEFAULT FILTERING CONFIGURATION .....             | 40 |
| TABLE 13: AZURE OPENAI METRICS .....                        | 44 |
| TABLE 14: PERSONAL INFORMATION DATA ELEMENTS.....           | 51 |
| TABLE 6: PERSONAL INFORMATION PROTECTION REQUIREMENTS ..... | 53 |

## INDEX OF IMAGES

|                                                                        |     |
|------------------------------------------------------------------------|-----|
| IMAGE 1: NEURAL NETWORK.....                                           | 16  |
| IMAGE 2: CREATION OF AZURE OPENAI RESOURCE VIA AZURE PORTAL .....      | 27  |
| IMAGE 3: HOW TO REDUCE HALLUCINATIONS.....                             | 32  |
| IMAGE 4: AI ABUSE REPORTING FORM .....                                 | 38  |
| IMAGE 5: AZURE CONTENT CONFIGURATION PAGE .....                        | 41  |
| IMAGE 6: DATA FLOWS I.....                                             | 47  |
| IMAGE 7: DATA FLOWS II (ON CUSTOMER DATA).....                         | 48  |
| IMAGE 8: AZURE OPEN AI TERMS (I) .....                                 | 61  |
| IMAGE 9: AZURE OPENAI TERMS (II) .....                                 | 61  |
| IMAGE 10: AZURE AD INTERNAL TOPOLOGY INDICATING TENANT ISOLATION ..... | 151 |
| IMAGE 11: INCIDENT INVESTIGATION AND RESPONSE FLOW .....               | 160 |

## Table of Acronyms

The following acronyms appear in this document:

| Acronym | Term                                                                    |
|---------|-------------------------------------------------------------------------|
| AAI     | Algorithmic AI                                                          |
| ACL     | Access Control List                                                     |
| AES     | Advanced Encryption Standard                                            |
| AI      | Artificial Intelligence                                                 |
| API     | Application Programming Interface                                       |
| CAI     | Commission d'accès à l'information (Québec)                             |
| CESO    | Core Services Engineering and Operations                                |
| DNS     | Domain Name Services                                                    |
| DPA     | Data Protection Addendum                                                |
| FIPPA   | Freedom of Information and Protection of Privacy Act (Ontario)          |
| FOIPPA  | Freedom of Information and Protection of Privacy Act (British Columbia) |
| FPIA    | Foundational Privacy Impact Assessment                                  |
| GAI     | Generative AI                                                           |
| GC      | Government of Canada                                                    |
| GDPR    | General Data Protection Regulation                                      |
| HIC     | Health Information Custodian                                            |
| IaaS    | Infrastructure as a Service                                             |
| IDS/IPS | Intrusion Detection System                                              |
| IPC     | Office of the Information and Privacy Commissioner of Ontario           |
| IPS     | Intrusion Protection System                                             |
| JSONL   | JSON Lines                                                              |
| LLM     | Large Language Model                                                    |
| MNR     | Ministry of Natural Resources                                           |
| NIST    | National Institute of Standards and Technology                          |
| NLP     | Natural Language Processing                                             |
| NSG     | Network Security Group                                                  |
| NTFS    | New Technology File System                                              |
| OIPC-BC | Office of the Information and Privacy Commissioner of British Columbia  |
| OPC     | Office of the Privacy Commissioner of Canada                            |
| OSA     | Operational Security Assurance                                          |
| PaaS    | Platform as a Service                                                   |
| PHIPA   | Personal Health Information Protection Act, 2004 (Ontario)              |
| PIA     | Privacy Impact Assessment                                               |

|        |                                                                            |
|--------|----------------------------------------------------------------------------|
| PIB    | Personal Information Bank                                                  |
| PI     | Personal Information                                                       |
| PIIDPA | Personal Information International Disclosure Protection Act (Nova Scotia) |
| PIPEDA | Personal Information Protection and Electronic Documents Act (Canada)      |
| RAI    | Responsible AI                                                             |
| RBAC   | Role-Based Access Control                                                  |
| REST   | Representational State Transfer                                            |
| RMS    | Rights Management System                                                   |
| SDL    | Security Development Lifecycle                                             |
| SOC    | Service Organization Control                                               |
| SSE    | Storage Service Encryption                                                 |
| SSL    | Secure Sockets Layer                                                       |
| SSPA   | Microsoft Supplier Security and Privacy Assurance Program                  |
| TBS    | Treasury Board of Canada Secretariat                                       |
| TLS    | Transport Layer Security                                                   |
| UDR    | User Data Repositories                                                     |
| VPN    | Virtual Private Network                                                    |

Table 1: Acronyms

## EXECUTIVE SUMMARY

Generative AI - a technology that creates new content in the form of text, code, speech, and images - has captured the world's political and economic attention. Microsoft launched its Azure OpenAI Service in November 2021 to combine Generative AI models created by OpenAI with the benefits of Microsoft Azure.

**Azure OpenAI.** Microsoft indicates that its Azure OpenAI service provides users with the “best of both worlds”: the same models available from Open AI but with the privacy, security, and enterprise management features of Microsoft Azure. This is accomplished, in part, through the co-development of APIs with OpenAI to ensure compatibility and a smooth transition from one to the other. Users can OpenAI models “as-is” or adapt and customize (fine tune) the AI models to meet their own needs.

For text, code and fine-tuning, the large language models available are OpenAI's GPT-4, GPT-3, and Codex. For image generation, the models available are DALL·E 2 and DALL·E 3. Finally, for speech recognition and speech translation tasks, the Whisper model is available. The models are grouped by family and each model family has a series of individual models that are further distinguished by capability.

Training data and fine-tuned models:

- Are available exclusively for use by the customer.
- Are stored within the same region as the Azure OpenAI resource.
- Can be double encrypted at rest (by default with Microsoft's AES-256 encryption and optionally with a customer-managed key).
- Can be deleted by the customer at any time.

A customer's prompts (inputs), completions (outputs), embeddings, and training/validation data are:

- NOT available to other Microsoft customers.
- NOT available to OpenAI.
- NOT used to improve OpenAI models.
- NOT used to improve any Microsoft or 3rd party products or services.
- NOT used for automatically improving Azure OpenAI models.

**Scope of Document.** The potential of Generative AI requires customer consideration of the current legal and regulatory landscape. One aspect of that landscape is privacy. This document is a Foundational Privacy Impact Assessment, specifically intended to help the reader to better understand the components and features of Microsoft's Azure Open AI service as well as relevant Canadian requirements associated with using the service. The document's fundamental objective is to assist organizations in their risk management activities, specifically in the development of their own privacy impact assessments.

The scope of this FPIA is centred on Microsoft's Azure OpenAI service. This includes the use of the models and fine tuning available as well as the Azure OpenAI Service Studio. This is a large document because it is about a cloud-based (Azure) Generative AI (OpenAI) service. Because the technology is

new, this document presents AI concepts as well as the AI safety features implemented by Microsoft in addition to the privacy considerations associated with a cloud-based service.

**Responsible AI.** The Azure OpenAI Service has been developed in conformity with Microsoft's Responsible AI principles. As part of its registration and approval process, Microsoft requires all Azure OpenAI users to adhere to a Code of Conduct, which defines a series of (i) requirements for all Azure OpenAI Service implementations and (ii) content prohibitions. To ensure conformity with this Code of Conduct, Microsoft conducts abuse monitoring. This process is similar to that for virus monitoring in that it is an automated process at first but then involves human review if specific activity is flagged for follow up.

Human reviewers assessing potential abuse, *who may or may not be in the same Azure region as the customer's tenant*, can access prompts and completions data only when that data has been flagged by the abuse monitoring system. The human reviewers are authorized Microsoft employees who access the data via queries using request IDs, Secure Access Workstations, and Just-In-Time request approval granted by team managers.

Some customers may want to use the Azure OpenAI Service for a use case that involves the processing of sensitive, highly confidential, or legally regulated input data but where the likelihood of harmful outputs and/or misuse is low. Microsoft does allow customers who meet additional Limited Access eligibility criteria and attest to specific use cases to apply to modify the Azure OpenAI content management/monitoring features. If Microsoft approves a customer's request to modify abuse monitoring, then Microsoft does not store any prompts and completions. In this case, because no prompts and completions are stored at rest in the Service Results Store, the human review process is not possible and is not performed.

**Privacy Considerations.** The deployment, fine tuning and subsequent use of Generative AI tools or services has the potential to introduce new privacy risks, especially if personal information is used as inputs to generate output and/or used to further train the models. The privacy risks to weigh invariably revolve around the "lifecycle" of information, from collection/generation to ultimate disposition.

To ensure appropriate internal oversight, organizations – whether public or private – should have appropriate AI Governance measures in place. This includes:

- Having a process to research and analyze each AI service prior to use by the organization.
- Maintaining a registry of commercial Generative AI services approved for use within the organization.
- Establishing an internal "use" policy and ensuring that internal users adhere to and comply with that policy.
- Requiring users to review each output for accuracy, functional effectiveness, suitability, and adherence to intellectual property laws.
- Reporting any unintended or inappropriate output as well as potential cybersecurity incidents, data spillage, or fabrication outputs or errors.

Privacy risks with respect to AI primarily revolve around inputs (prompts), outputs and training data (both the initial data, any supplemental data and any private organizational data used to fine tune a model). Several privacy risks were identified but can be mitigated by appropriate organizational policy and oversight.

It is to be noted that these privacy considerations apply to any Generative AI deployment and are not specific to Azure OpenAI.

**Privacy Consideration 1:** Each Generative AI service is governed by the model provider’s privacy policy, terms of service, account registration requirements, and model training. Some may collect information to train their models through “inputs” from users. Once a user discloses any information to a Generative AI service, the organization no longer has control over that information. Users need to (and should be required to) carefully assess the information they are inputting into the service.

**Privacy Consideration 2:** Generative AI tools are known to fabricate or invent/create inaccurate responses and/or provide biased outputs (because of biases in training data). Because of this fabrication aspect, users should minimize the use of personal information as inputs and/or actively seek such information as outputs (even if anonymized or de-identified). Given the accuracy principle commonly found in Canadian privacy laws, if the tool generates personal information in its output, users should carefully consider whether to use such information for decision-making.

**Privacy Consideration 3:** There is a risk that organizational personnel may not know the risks associated with or proper uses of Generative AI services. This risk can be mitigated if organizational users are aware of – and agree to – the limitations on use prior to being authorized to use a Generative AI tool. In addition to training on the organization’s AI Use Policy, awareness tools such as “best practices” statements and Frequently Asked Questions documents should also be considered.

**Privacy Consideration 4:** There is a risk that employees/contractors will not have sufficient training for the Generative AI service. This risk can be mitigated by requiring all users to complete training prior to use of any Generative AI service.

**Privacy Consideration 5:** There is a risk that members of the public may not know how the organization’s use of a Generative AI tools may affect or impact them. This risk can be mitigated if (i) an appropriate AI use policy is implemented; (ii) appropriate language is inserted in the organization’s privacy policy or in a public notice to explicitly indicate whether the use of Generative AI involves the use of personal information and whether it is used for decision-making purposes.

**Privacy Consideration 6:** There is a risk that Generative AI output could include personal information or information that could otherwise affect the privacy of an individual, even where the user did not intend to receive or collect it. If this should occur, it should be noted that any personal information found in an output will be subject to applicable personal information protection laws, even if not originally collected by the organization. This risk can be partially mitigated by ensuring users are aware of an organization’s AI Use policy as well as report any problems or issues in the use of Generative AI services.

**Privacy Consideration 7:** There is a risk that the organization may receive unintended information as part of the outputs. This risk can be partially mitigated by making the use a mechanism to report potential issues mandatory (i.e., issues such as unintended, or inappropriate outputs, fabrications, errors, unintended bias, or privacy concerns/incidents are to be reported).

**Privacy Consideration 8:** There is a risk that the organization will not appropriately process outputs that could include personal information. This risk can be partially mitigated through the establishment and

use of a reporting mechanism to address output-related issues and the development of a process to address situations where outputs contain personal information.

**Privacy Consideration 9:** There is a risk that Generative AI services may receive and use data not intended for public use. This risk can be partially mitigated by a prohibition of the use of non-public information in prompts. [Note: Microsoft indicates that it nor OpenAI does not use customer outputs as training data.]

**Privacy Consideration 10:** There is a risk that an organization's employees/contractors may use the Generative AI service for unauthorized purposes. This risk can be partially mitigated by having employees/contractors using the Generative AI service (i) complete training specific to Generative AI, privacy, and security requirements; (ii) review and agree to follow the organization's AI Use Policy, and (iii) report any inappropriate use.

**Privacy Consideration 11:** There is a risk that user account and other data disclosed during activities within Generative AI service - as distinct from inputs - may be used for other purposes by the Generative AI service provider. This risk can be partially mitigated. Generative AI service offerings are governed by their own terms of service and/or privacy policies that indicate how (or if) the services uses data. [Note: Microsoft indicates that neither it nor OpenAI uses user data or outputs for training purposes.]

**Privacy Consideration 12:** There is a risk that the organization will not appropriately retain any output. This risk can be mitigated by having information be subject to the organization's records retention policy/schedule.

**Privacy Consideration 13:** There is a risk that the organization does not have appropriate accountability and auditing processes in place. This risk can be partially mitigated by putting a greater emphasis on the control of inputs (i.e. limiting or prohibiting the use of sensitive/confidential information and limiting or prohibiting the use of personal information).

**Disclaimer.** While this document goes into extensive detail about AI, it is a privacy impact assessment and not a formal AI or algorithmic impact assessment.

This document is not an audit of the privacy and security measures described in this document and implemented by Microsoft. Reliance is placed on the information, materials and responses provided by Microsoft, which have not been verified as to the actual operation of the controls in place. Unless otherwise indicated, the views and statements expressed in this assessment are those of the author and not Microsoft.

## PART 1: CONTEXT OF ASSESSMENT

**Introduction.** Since the introduction of Open AI's Chat GPT in November 2022, artificial intelligence ("AI") has captured the world's imagination and sparked a series of reactions ranging from excitement to concern. Microsoft first launched Azure OpenAI Service in November 2021 to combine large-scale generative AI models with the features of Microsoft Azure. The exploration and early-stage adoption of

AI – a term explained in more detail below – requires consideration of the current legal and regulatory landscape facing organizations today. One aspect of that landscape is privacy.

This document is a Foundational Privacy Impact Assessment (“FPIA”). Its objective is to help the reader to better understand the components and features of Microsoft’s Azure Open AI Service and Canadian privacy requirements associated with using the service as they complete their own privacy impact assessments. In doing so, it presents AI concepts as well as the AI safety features that Microsoft has implemented.

At the outset, it is important to emphasize that public or private organizations are, first and foremost, accountable for their custodianship of business and personal information. This remains the case in using not only Microsoft but any AI or cloud service provider.

**Scope of Assessment.** The scope of this FPIA is centred on Microsoft’s Azure OpenAI service. This includes the use of the models and fine tuning available and the Azure OpenAI Service Studio. Also within scope is content filtering performed by Microsoft.

| Models     | Description                                                                                        |
|------------|----------------------------------------------------------------------------------------------------|
| GPT-4      | A set of models that improve on GPT-3.5 and can understand and generate natural language and code. |
| GPT-3.5    | A set of models that improve on GPT-3 and can understand and generate natural language and code.   |
| Embeddings | A set of models that can convert text into numerical vector form to facilitate text similarity.    |
| DALL-E     | A series of models that can generate original images from natural language.                        |
| Whisper    | A series of models in preview that can transcribe and translate speech to text.                    |

Table 2: Models Within Scope of FPIA

Azure OpenAI utilizes a set of services provided by both Microsoft Azure (“Azure”) and Core Services Engineering and Operations (“CSEO”). In this document, reference will be made to Azure and CSEO to the extent that they provide support services to Azure OpenAI. CSEO is an organization within Microsoft that provides hosting and network support solutions for the Azure OpenAI environment. CSEO provides the datacenters hosting Azure OpenAI service. The Azure product group within Microsoft provides support services for Azure OpenAI, including authentication, virtual server hosting, and system data storage.

| FPIA Domains             |                                                                                                                                                                                                      |                                                                                                                                                                                                                                                                 |
|--------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Domain                   | Within Scope                                                                                                                                                                                         | Not Within Scope                                                                                                                                                                                                                                                |
| <b>Data transactions</b> | <ul style="list-style-type: none"><li>▪ Personal information data flows between customer and Microsoft data centers.</li><li>▪ Personal information storage within Microsoft data centers.</li></ul> | <ul style="list-style-type: none"><li>▪ Anonymized or de-identified information about individuals associated with customer.</li><li>▪ Any information that is not personal information, excluding identifying information of customer personnel (e.g.</li></ul> |

| FPIA Domains                      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |                                                                                                                                                                                                          |
|-----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Domain                            | Within Scope                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | Not Within Scope                                                                                                                                                                                         |
|                                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | employees/contractors) required to access and use the service.                                                                                                                                           |
| <b>Relevant Legislation</b>       | <ul style="list-style-type: none"> <li>Privacy Act (Canada)</li> <li>Freedom of Information and Protection of Privacy Act (ON) ("FIPPA") and associated regulations</li> <li>Personal Information Protection and Electronic Documents Act (Canada) and associated regulations ("PIPEDA")</li> <li>An Act respecting the Protection of Personal Information in the Private Sector (QC).</li> <li>Personal Health Information Protection Act, 2004 (Ontario) and associated regulations ("PHIPA")</li> <li>Legislation within Canada that specifically address data residency.</li> </ul> | <ul style="list-style-type: none"> <li>Legislation that does not specifically address protection of personal information related to the customer program or service.</li> </ul>                          |
| <b>Privacy Posture</b>            | <ul style="list-style-type: none"> <li>Microsoft privacy posture as it relates to provision of cloud services, compliance with applicable legislation and compliance with service agreements.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                | <ul style="list-style-type: none"> <li>Customer privacy posture as it relates to compliance with the applicable personal information protection legislation (e.g. Privacy Act, PIPEDA, FIPPA)</li> </ul> |
| <b>Security Posture</b>           | <ul style="list-style-type: none"> <li>Microsoft security posture as it relates to data flows and hosting the Azure OpenAI service and support services.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                     | <ul style="list-style-type: none"> <li>Customer security posture as it relates to its own physical, procedural, and technical security measures.</li> </ul>                                              |
| <b>Technology and Environment</b> | <ul style="list-style-type: none"> <li>Azure Open AI service</li> <li>Relevant CSEO services</li> <li>Relevant Azure services</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                | <ul style="list-style-type: none"> <li>Customer infrastructure and back-office services.</li> </ul>                                                                                                      |

Table 3: Domains Within Scope

**Methodology.** A privacy impact assessment ("PIA") is an evaluation of a system, environment, or process. A PIA considers the system, environment, or process in the context of privacy principles, best practices, codes of conduct, legislation, and directives. This type of assessment is intended to inform relevant stakeholders and decision-makers about the risks to privacy arising from the changes to the system, environment, process, or program under review. Such change might take the form of a revised policy or process, or the introduction of new technology.

In completing this Azure OpenAI FPIA, the following activities were undertaken:

- Information gathering from materials provided by Microsoft.
- Interpretation and documentation of Azure OpenAI components, for subsequent analysis and assessment.
- Review with Microsoft of the solution descriptions, for accuracy and completeness prior to conducting a privacy analysis.
- Analysis of Azure OpenAI components in the context of compliance with chosen statutory authorities, relevant policies, and public expectations.
- Identification of privacy considerations and proposed mitigation strategies.
- Review of outcomes with Microsoft stakeholders.

#### Why are PIAs Conducted?

To describe the privacy and security measures and controls associated with a particular project or initiative.

To assess the potential privacy risks and provide recommendations to mitigate those risks.

For the purposes of this FPIA, all customer information is assumed to be either business confidential or personal information and assigns such information a high confidentiality and integrity value. Such a valuation assumes that any compromise or unauthorized disclosure of the information in question could cause social hardship, loss of privacy or serious harm to business operations or relationships. For federal entities, the confidentiality and integrity value would be sufficient for information classified up to a Protected B level.

In this document, reference will be made to Azure and CESO to the extent that they provide support services.

**Resources.** Much of the information about the privacy and security posture of Microsoft Azure is available to users through the Microsoft Service Trust Portal.<sup>1</sup> Azure documentation is relevant here because Azure provides most, if not all, of the security used to protect personal information - to the extent it may be used by customers in using Azure OpenAI. Some documentation is restricted to users who sign a non-disclosure agreement. Similarly, access to some documentation depends on a particular organization's subscriptions and permissions. It is within the Trust Portal that the most current documentation pertaining to certifications, such as those under ISO (e.g. ISO 27017, ISO 27018, ISO 22301, can be found along with other relevant publications from Microsoft.

[Remainder of page left intentionally blank.]

---

<sup>1</sup> Available at <https://servicetrust.microsoft.com>.

## Certifications, Regulations and Standards

|                                                                                                                                                                                                               |                                                                                                                                                                                  |                                                                                                                                                                   |                                                                                                                                                            |                                                                                                                                                                |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <br><b>ISO/IEC</b><br>International Organization for Standardization (ISO) / International Electrotechnical Commission (IEC) | <br><b>SOC</b><br>System and Organization Controls (SOC) 1, 2, and 3 Reports                    | <br><b>GDPR</b><br>General Data Protection Regulation                            | <br><b>FedRAMP</b><br>Federal Risk and Authorization Management Program | <br><b>PCI</b><br>Payment Card Industry (PCI) Data Security Standards (DSS) |
| <br><b>CSA Star</b><br>Cloud Security Alliance (CSA) Security, Trust and Assurance Registry (STAR)                           | <br><b>Australia IRAP</b><br>Australia Information Security Registered Assessors Program (IRAP) | <br><b>Singapore MTCS</b><br>Multi-Tier Cloud Security (MTCS) Singapore Standard | <br><b>Spain ENS</b><br>Spain Esquema Nacional de Seguridad (ENS)       |                                                                                                                                                                |

## Reports, Whitepapers and Artifacts

|                                                                                                                                                     |                                                                                                                                                                                                                       |                                                                                                                                                                  |                                                                                                                                                                            |                                                                                                                                                                                                                                           |
|-----------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <br><b>BCP and DR</b><br>Business Continuity and Disaster Recovery | <br><b>Pen Test and Security Assessments</b><br>Attestation of Penetration tests and security assessments conducted by third parties | <br><b>Privacy and Data Protection</b><br>Privacy and Data Protection Resources | <br><b>FAQ and Whitepapers</b><br>Whitepapers and answers to frequently asked questions | <br><b>AI Resources</b><br>Resources describing the approach to Compliance, Security and Privacy in the AI solutions such as Copilot and Azure Open AI |
|-----------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

**Disclaimer.** This document is not an audit of the privacy and security measures described in this document and implemented by Microsoft. Reliance is placed on the information, materials and responses provided by Microsoft, which have not been verified as to the actual operation of the controls in place. Unless otherwise indicated, the views and statements expressed in this assessment are those of the author and not Microsoft.

While this document goes into extensive detail about AI, it is to be emphasized that this document provides foundational information to allow users to conduct privacy impact assessments. It is not an AI or algorithmic impact assessment.

[Remainder of page left intentionally blank.]

## PART 2: SOLUTION DESCRIPTION

### A. Introduction

Microsoft's Azure OpenAI Service provides REST API access to OpenAI's language models. These models can be used for such tasks as content generation, summarization, image understanding, semantic search, and natural language to code translation. Users can access the service through REST APIs, Python SDK, or Microsoft's web-based interface in the Azure OpenAI Studio.

"AI" generally falls into two categories:

- Algorithmic AI ("AAI") or a technology that analyzes data with machine-learning algorithms and is used to make decisions or recommendations based on the data used. Prior to the introduction of Generative AI, this is what the world generally characterized as being "AI".
- Generative AI ("GAI") is a technology that can create new content in response to prompts, including but not limited to text, speech, and images. There are both proprietary and open-source models of this type of AI. The most obvious examples are Open AI's ChatGPT4 (text generation) and DALL-E (image generation).

Generally, an "AI-enabled software tool" can be considered as any software, or system that can independently perform tasks, analyze data, or make decisions or recommendations utilizing machine learning. The use of an "AI Tool" may involve the use GAI, AAI, or both.

Generative AI is a subfield of artificial intelligence that focuses on creating systems that can generate new outputs, such as images, text, or speech. The goal of Generative AI is to develop models that are developed from the underlying probability distribution of a given dataset and use this knowledge to generate new content.

Generative AI models fall into two broad categories: generative models and discriminative models. Generative models learn the underlying probability distribution of the dataset and can generate new examples from that "learned distribution". Discriminative models, such as deep neural networks, learn to differentiate between different classes or categories, and are generally used for tasks such as image or speech recognition.

In thinking about what constitutes Generative AI, one metaphor to use can simply be that of an automobile with three major components: the "engine" which is a foundational Large Language Model ("LLM"); the "fuel" which is the data used to train that LLM and a "steering wheel" which is a user-friendly interface to both submit an input and display an output.

Microsoft indicates that its Azure OpenAI service provides users with the "best of both worlds": the same models available from Open AI but with the privacy, security, and enterprise management features of Microsoft Azure. This is accomplished, in part, through the co-development of APIs with OpenAI to ensure compatibility and a smooth transition from one to the other. Users can OpenAI models "as-is" or adapt and customize (fine tune) the AI models to meet their own specifications with

labeled data using a simple Programming interface or using other service feature to adjust the tone of outputs.

Microsoft also indicates that the Azure OpenAI Service has been developed using Microsoft's Responsible AI ("RAI") approach, and addresses Microsoft's RAI principles, including the filtering and moderating the content of users' requests and responses, to ensure that coding and language AI models behave in a manner consistent with Microsoft's RAI principles. The RAI principles are discussed in further detail below.

Azure OpenAI relies upon the physical infrastructure and security measures associated with Microsoft Azure.

**Basic Concepts and Vocabulary.** Before exploring in detail what constitutes Azure Open AI, this section introduces some vocabulary as well as describes, in limited terms, concepts to better understand the technology that underpins AI.

**Algorithm.** A set of steps to achieve a desired result.

**Machine Learning.** A process by which algorithms build a model based on data to make predictions or decisions without being programmed to do so. Machine learning involves a training stage, in which a model is learned, and a deployment stage, in which the model is deployed on new data samples to generate predictions.

**Neural Network.** A subset of machine learning that, in essence involves the use of non-linear statistical data modeling or decision-making tools. A neural network consists of at least three layers of nodes: an input layer, one or more hidden layers and an output layer. Each node within each layer connects to another node and is assigned both a weight and threshold. If the threshold is exceeded, the data is further processed. In this manner, neural networks describe relationships between inputs and outputs to find patterns in data. A basic neural network would have a smaller number of hidden layers; a deep learning neural network would have a significantly larger number of hidden layers.

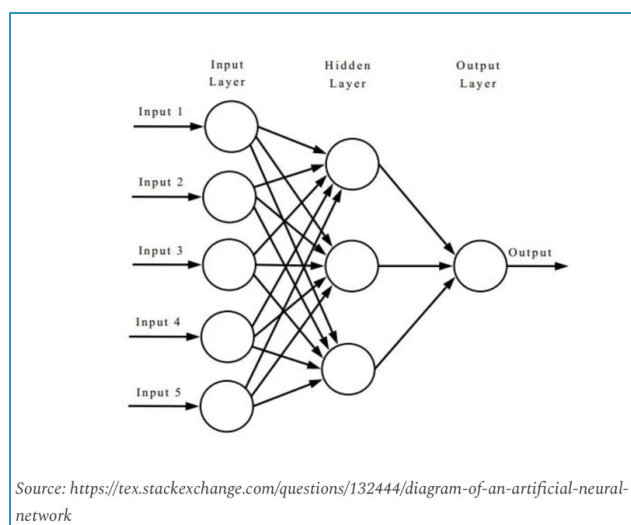


Image 1: Neural Network

**Deep Learning.** A subset of neural networks structured to deploy a large number of hidden layers to (i) extract data (“extraction”) and then (ii) transform it into different representations (“abstraction”). Because a deep learning neural network learns from the processed data, extraction and abstraction occurs with little, if any, human involvement. Examples where deep learning is deployed can be seen in applications such as speech, image recognition and natural language processing.

**Transformer.** A transformer is a type of neural network whose most important aspect is that it “understands” context. A transformer neural network encodes and decodes plain language terms as “vectors”. Its distinguishing characteristic is the use of mathematical techniques (known as “attention” or “self-attention”) to identify data elements which both influence and rely on one another. A transformer’s “attention mechanism” assigns an importance in the “encoding” of a “token” at the input layer. See also the term “Embedding” below.

**GPT.** Generative Pre-trained Transformer. This is a deep learning algorithm that can generate human-like language and has been used for tasks such as language translation and text completion.

**Large Language Model.** A large language model (“LLM”) is transformer-based neural network, trained on an extremely large amount of unlabelled data, using deep learning techniques to identify patterns after considering a large number of factors in collating and generating content. LLMs are considered sophisticated models capable of responding to a variety of requests. Open AI models are large language models.

**Embedding.** Embedding is a technique to “tune” or adjust the behaviour of a large language model. “Embedding” is the process of changing plain language text into a format understandable by a machine learning models and algorithms. The resulting, changed format is a “vector” or list of floating-point numbers used by an algorithm or machine learning model.

In Open AI’s case, text embeddings measure the “relatedness” of text strings where a small “distance” between text strings suggests high relatedness and a large distance suggests low relatedness. If two texts are similar, then their vector representations should also be similar.

According to Open AI, embeddings are commonly used for:

- Search (where results are ranked by relevance to a query string).
- Clustering (where text strings are grouped by similarity).
- Recommendations (where items with related text strings are recommended).
- Anomaly detection (where outliers with little relatedness are identified).
- Diversity measurement (where similarity distributions are analyzed).
- Classification (where text strings are classified by their most similar label).

Embeddings make it easier to do machine learning on large inputs representing words by capturing the semantic similarities in a vector space. In effect, embeddings make it possible to map content to a “semantic space”.

Different Azure OpenAI embedding models are specifically created to be good at a particular task. **Similarity embeddings** are good at capturing semantic similarity between two or more pieces of text. **Text search embeddings** help measure whether long documents are relevant to a short

query. **Code search embeddings** are useful for embedding code snippets and embedding natural language search queries.

**Token.** Tokens represent the “language” of an LLM in that they form the basic units of text or code that an LLM uses to process and generate language. They can be characterized as “pieces of words”. For English language text, one token constitutes approximately four characters or 0.75 words. Tokens are assigned numerical values; arranged in vectors and then used at the input layer to submit text and the output layer to show the results of the request. “Tokenization” is the process of splitting the input and output texts into smaller units for processing by the LLM. For Azure OpenAI, the current range of token support goes from 2000 tokens with earlier GPT-3 models to up to 32,768 tokens with the 32k version of the latest GPT-4 model.

Tokens are central to how Generative AI interacts with text and images to create a response to user requests. By making calculations of how frequently word fragments (tokens) appear close to one another (the concept of “relatedness” described above), LLMs can make predictions to compose meaningful natural language outputs.

**Prompt.** A prompt is an instruction to a large language model through an application interface. Prompts are the primary means of interaction with large language models. In most interactions with a large language model, a prompt will represent a natural language question posed by a user.

For a developer, the user prompt may be complemented with additional prompting to accompany it. Developers may choose to add “metaprompts” or other context improvement prompts to all user prompts to provide additional detail. This helps to create more relevant and responsive responses. A metaprompt is a program that serves to guide a model’s behaviour. For example, a metaprompt may include a line that states “communicate in the user’s language of choice”.

For any given interaction with an LLM, a prompt can be considered an initial input to generate an output (response). The output could be written (text), a picture or drawing (image) or auditory (speech). Three common types of prompts are (i) command prompts (giving instructions), (ii) question prompts (asking questions), and (iii) text entry prompts (submitting information).

**Temperature.** “Temperature” is a setting that controls the apparent creativity of generated completions in Azure OpenAI. This setting has a valid range of 0.0 to 2.0 and defaults to 1.0 if not otherwise specified. The “temperature” and “top\_p” settings in Azure OpenAI control how deterministic the model is in generating a response. If a user seeks a response where there's only one right answer, then the temperature setting would be set to a low value or a range of lower values. If user seeks a response that's not obvious, then the temperature setting would be set to a high value or a range of higher values.

## B. Foundation AI Models and Use Cases

**Introduction.** The current surge of interest in AI is based on foundation models which represent a fundamental change in how AI systems are constructed. A foundation model is a machine learning model that is trained on a large amount of unlabeled data.

Over time, foundation models have been adapted to a wide variety of tasks. These models capture general patterns and structure of data and are intended to replace task-specific models by unifying different tasks and modalities into one, eliminating the need to train individual models and integrate several models together. Foundation models use self-supervised learning and transfer learning. It has been shown that, in some cases, they may be used to apply information learned in one situation to another situation or task. Microsoft indicates that Azure Open AI provides a consistent single interface to a variety of models.

These models use an autoregressive architecture, i.e., data from training is used to predict the most probable next word. This technique is known as "in-context" learning. This process is then repeated by appending the newly generated content to the original text to produce the complete generated response. Because the response is conditioned on the input text, these models can be applied to various tasks simply by changing the input text.

**Use Cases.** For text, code and fine-tuned models, the GPT-4, GPT-3, and Codex models in the Azure OpenAI service can be used in many ways including, but not limited to:

- **Chat and conversation interaction.** Users can interact with a conversational agent that responds with responses drawn from company documentation or tech support documentation. Conversations must be limited to answering scoped questions.
- **Chat and conversation creation.** Users can create a conversational agent that responds with responses drawn from company documentation or tech support documentation. Conversations must be limited to answering scoped questions.
- **Code generation or transformation scenarios.** Users can convert one programming language to another, generating docstrings for functions or converting natural language to SQL.
- **Journalistic content.** Users can create new journalistic content or to rewrite journalistic content. Users cannot use the application as a general content creation tool for all topics. [Note: Azure OpenAI may not be used to generate content for political campaigns.]
- **Question-answering.** Users can ask questions and receive answers from organizational documentation. The application does not generate answers ungrounded in trusted source documentation.
- **Reason over structured and unstructured data.** Users can analyze inputs using classification, sentiment analysis of text, or entity extraction.
- **Search.** Users can search organizational documentation. The application does not generate results ungrounded in trusted source documentation.
- **Summarization.** Users can submit content to be summarized for predefined topics built into the application. However, they cannot use the application as an open-ended summarizer.
- **Writing assistance on specific topics.** Users can rewrite or create content for specific business purposes or predefined topics. However, they cannot use the application as a general content creation tool for all topics.

For the DALL·E 2 and DALL·E 3 APIs, the Azure OpenAI service can be used for various image- generation scenarios, such as:

- **Accessibility features:** To generate image-based visual descriptions.
- **Art and design:** To generate imagery, for artistic purposes only, for designs, artistic inspiration, mood boards, or design layouts.

- **Communication:** To create imagery for business-related communication, documentation, essays, newsletters, blog posts, social media, or memos.
- **Education:** To create imagery for enhanced or interactive learning materials, either for use in educational institutions or for professional training.
- **Entertainment:** To create imagery to enhance entertainment content such as video games, movies, TV, videos, recorded music, podcasts, audiobooks, or augmented or virtual reality.
- **Journalistic content:** To create imagery to enhance journalistic content.
- **Marketing:** To create marketing materials for product or service media, product instructions, business promotion, or advertisements. [Microsoft indicates that it should not be used to create advertisements that are personalized or targeted to individuals.]
- **Prototyping and conceptual development:** To generate imagery for ideation or visualization of products or services. This use is applicable only in the context of the scenarios above.

The Whisper model in Azure OpenAI service can be used for various speech recognition and speech translation tasks, such as:

- **Dictation:** To transcribe spoken words in the form of audio files into text.
- **Captioning or transcription:** To transcribe audio files into text for natural language understanding or analytic tasks like summarization and sentiment analysis.
- **Translation:** To translate multilingual audio files into English.

**Types of Models and Uses.** Azure OpenAI provides access to many different models, grouped by family and capability. A model family typically associates models by their intended task. Large language models and generative AI are *compute* intensive services that rely heavily upon graphical processing units. Microsoft indicates that Generative AI is only available from a select number of datacentres, having the requisite capabilities, and that not all models are currently available in all regions. The following table describes model families currently available (April 2024) in Azure OpenAI.

Each model family has a series of models that are further distinguished by capability. These capabilities are typically identified by names, and the alphabetical order of these names generally signifies the relative capability and cost of that model within a given model family.

[Remainder of page left intentionally blank.]

| Model family               | Description                                                                                                                                                                                                                                                                                                                                                                                                              |
|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <a href="#">GPT-4</a>      | A set of models that improve on GPT-3.5 and can understand as well as generate natural language and code.                                                                                                                                                                                                                                                                                                                |
| <a href="#">GPT-3</a>      | A series of models that can understand and generate natural language. This includes the new <a href="#">ChatGPT model</a> .                                                                                                                                                                                                                                                                                              |
| <a href="#">DALL-E</a>     | A series of models that can generate original images from natural language.                                                                                                                                                                                                                                                                                                                                              |
| <a href="#">Codex</a>      | A series of models that can understand and generate code, including translating natural language to code.                                                                                                                                                                                                                                                                                                                |
| <a href="#">Embeddings</a> | A set of models that can understand and use embeddings. An embedding is a special format of data representation that can be easily utilized by machine learning models and algorithms. The embedding is an information dense representation of the semantic meaning of a piece of text. Currently, we offer three families of Embeddings models for different functionalities: similarity, text search, and code search. |

Table 4: Azure Open AI Models

Microsoft indicates that it has published an extensive Transparency Note on the Azure OpenAI service offering<sup>2</sup>. Microsoft's Transparency Notes are part of the company's efforts to put its AI Principles<sup>3</sup> into practice. Microsoft's Transparency Notes are intended to help customers understand how AI technology works, the choices system owners can make that influence system performance and behavior, and the importance of having a "whole system" perspective, looking at the technology, people, and the environment.

**NOTE:** It is useful review both Microsoft's AI Principles and the Azure OpenAI Transparency Note to better understand how Microsoft proposes to deploy the service and the customer's own responsibilities in using the service.

The **GPT-4** model can solve difficult problems with greater accuracy than any of OpenAI's previous models. Microsoft indicates that because of demand access this model is only available by request. GPT-4 is optimized for chat but works well for traditional completions tasks.

GPT-4 has similar limitations as earlier GPT models in that it:

- Is not fully reliable.
- Fabricates.
- Makes reasoning errors.
- May have biases in its outputs.

<sup>2</sup> The Azure OpenAI Transparency Note is available at: <https://learn.microsoft.com/en-us/legal/cognitive-services/openai/transparency-note?tabs=text>.

<sup>3</sup> The Microsoft AI Principles are available at: <https://www.microsoft.com/en-us/ai/principles-and-approach/>.

- Lacks knowledge of events that have occurred after the “cutoff date” for most of its data (September 2021).
- Does not learn from its experience.

However, insofar as GAI is an emerging technology, it is to be noted that GPT-4 significantly reduces fabrications relative to previous models. GPT-4 scores 40% higher than the latest GPT-3.5 in OpenAI’s internal adversarial factuality evaluations.

**GPT-3** is for text completion. The four available **GPT-3** models can understand and generate natural language and can be used for complex intent, cause and effect, summarization for audience. In the order of greater to lesser capability – in terms of power and speed - the GPT-3 models are:

- text-davinci-003.
- text-curie-001.
- text-babbage-001.
- text-ada-001.

Microsoft indicates that **Davinci** is the most capable model and can perform any task the other models can perform, often with less instruction. Microsoft indicates that for applications requiring deep understanding of the content, like summarization for a specific audience and creative content generation, Davinci produces the best results.

While Davinci is stronger when it comes to analyzing complicated text, **Curie** is capable for many nuanced tasks like sentiment classification and summarization. Curie is also good at answering questions and performing Q&A; as a general service chatbot and can be used for language translation, complex classification, text sentiment and summarization.

Microsoft indicates that:

- **Babbage** can perform straightforward tasks like simple classification. It’s also capable when it comes to semantic search, ranking how well documents match up with search queries. It can be used for moderate classification as well as semantic search classification.
- **Ada** is considered the fastest model and can perform tasks like parsing text, address correction and certain kinds of classification tasks that do not require too much nuance.

**ChatGPT model and gpt-35-turbo** are conversational models tuned for chatbots but are distinct models that behave differently than previous GPT-3 models. They excel at creative tasks like content writing and storytelling. Previous models were text-in and text-out, meaning they accepted a prompt string and returned a completion to append to the prompt. However, these models are “conversation-in” and “message-out” that expect a prompt string formatted in a specific chat-like transcript format and return a completion that represents a model-written message in the chat. The prompts used with the ChatGPT model are different than previous models because of the conversational nature and Microsoft indicates that a new Chat API is available for use with this model.

While the ChatGPT model has proven to respond on a variety of subjects, it can still provide erroneous outputs at times. It is important for users to understand this limitation.

The **DALL-E** models generate or manipulate images from text prompts that the user provides.

The **Codex** models are descendants of the base GPT-3 models that can understand and generate code, including translating natural language to code. Their training data contains both natural language and billions of lines of public code from GitHub. These models are most capable in Python and are proficient in over a dozen languages, including C#, JavaScript, Go, Perl, PHP, Ruby, Swift, TypeScript, SQL, and Shell.

In the order of greater to lesser capability, the Codex models are:

- code-davinci-002.
- code-cushman-001.

Similar to GPT-3, **Davinci** is the most capable Codex model and can perform any task the other models can perform, often with less instruction. Microsoft indicates that for applications requiring deep understanding of the content, Davinci produces the best results. Greater capabilities require more *compute* resources, so Davinci costs more and is not as fast as other models.

While Davinci is stronger when it comes to analyzing complicated tasks, **Cushman** is a capable model for many code generation tasks. Cushman typically runs faster than Davinci, as well.

Microsoft offers three families of **Embeddings models** for different functionalities. These functionalities are:

- Similarity
  - These models are good at capturing semantic similarity between two or more pieces of text.
- Text search
  - These models help measure whether long documents are relevant to a short search query. There are two input types supported by this family: *doc*, for embedding the documents to be retrieved, and *query*, for embedding the search query.
- Code search
  - Similar to text search embedding models, there are two input types supported by this family: *code*, for embedding code snippets to be retrieved, and *text*, for embedding natural language search queries.

Each family includes models across a range of capability. The following table indicates the length of the numerical vector returned by the service, based on model capability:

[Remainder of page left intentionally blank.]

| Base Model | Model(s)                           | Dimensions |
|------------|------------------------------------|------------|
| Ada        | models ending in -001 (Version 1)  | 1024       |
| Ada        | text-embedding-ada-002 (Version 2) | 1536       |
| Babbage    |                                    | 2048       |
| Curie      |                                    | 4096       |
| Davinci    |                                    | 12288      |

Table 5: Embedding Models

### C. Customization/Fine Tuning

If a model does not have the accuracy of results to meet customer requirements under prompt engineering and embeddings, or is fabricating outputs (hallucinating), then fine or custom tuning may be appropriate. The Azure OpenAI service lets users tailor the GPT models using an organization's specific datasets using a process known as *fine-tuning*. Fine-tuning a model is the process of taking a pre-trained machine learning model and adjusting its parameters to better suit a specific task or domain where there may be organizational jargon. This can involve fine tuning the model using a new dataset, adjusting its architecture, or tweaking its hyperparameters. This customization provides higher quality results than available just from prompt design; the ability to train on more examples than can fit into a prompt and lower-latency requests.

Customization of a model improves on the “few-shot” learning approach by training the model's weights on the organization's specific prompts and structure. This approach may provide better results without needing to provide examples in prompts. Microsoft indicates that the result is less text sent and fewer tokens processed on every API call. To assist in customization, Azure AI Studio<sup>4</sup> also provides a Create customized model wizard.

Later models, such as GPT4 have been seen require less fine tuning than previous models.

**Preparation of training and validation data.** Training and validation data sets consist of examples of input prompts and output completions. Such data is required to be:

- Formatted as a JSON Lines (“JSONL”) document in which each line represents a single prompt-completion pair. The OpenAI command-line interface includes a data preparation tool that validates, gives suggestions, and reformats training data into a JSONL file ready for fine-tuning.
- Encoded in UTF-8 and include a byte-order mark.
- In a file no greater than 200 MB in size.

<sup>4</sup> Available at: <https://oai.azure.com/>. See also “What is Azure AI Studio”, available at: <https://learn.microsoft.com/en-us/azure/ai-studio/what-is-ai-studio?tabs=home>.

“Prompts for fine-tuning” are different from “prompts for completion” in the use of a GPT model. Prompts for completion often use either detailed instructions or few-shot learning techniques and involve multiple examples. For fine-tuning, Microsoft recommends each training example consists of a single input prompt and its desired completion output. Similarly, Microsoft recommends at least 200 training examples in that each doubling of the dataset size leads to a linear increase in model quality. A training dataset or a validation dataset can be imported from Azure Blob or another shared web location.

One can either use default values for the hyperparameters of the fine-tune job that the wizard runs to train the fine-tuned model, or individually adjust those hyperparameters in the Advanced options pane. The following hyperparameters are available:

| Parameter name           | Description                                                                                                                                                                                                                                                                                 |
|--------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Number of epochs         | The number of epochs to train the model for. An epoch refers to one full cycle through the training dataset.                                                                                                                                                                                |
| Batch size               | The batch size to use for training. The batch size is the number of training examples used to train a single forward and backward pass.                                                                                                                                                     |
| Learning rate multiplier | The learning rate multiplier to use for training. The fine-tuning learning rate is the original learning rate used for pre-training, multiplied by this value.                                                                                                                              |
| Prompt loss weight       | The weight to use for loss on the prompt tokens. This value controls how much the model tries to learn to generate the prompt (as compared to the completion, which always has a weight of 1.0.) Increasing this value can add a stabilizing effect to training when completions are short. |

Table 6: Fine Tuning Hyperparameters

The **Models** page displays information about a customized model in the **Customized models** tab. The tab includes information about the status and job ID of the fine-tune job for a customized model. When the job is completed, the file ID of the result file is also displayed.

After a fine-tune job is started, it may take minutes or hours to complete depending on the model and dataset size. When the fine-tune job has succeeded, it must be deployed to a customer’s customized model to make it available for use with completion calls. After a customized model is deployed, if at any time the deployment remains inactive (i.e., no completions or chat completions calls were made to it) for greater than fifteen (15) days, the deployment will automatically be deleted. The deletion of an inactive deployment does **NOT** delete or affect the underlying customized model, and the customized model can be redeployed at any time. Microsoft indicates that only one deployment is permitted for a customized model. An error message is displayed if an already-deployed customized model is selected.

Azure OpenAI attaches a result file, named results.csv, to each fine-tune job once it's completed to permit an analysis of the training and validation performance of the customer’s customized model. The result file is a CSV file containing the following columns:

| Column name      | Description                                                                                                                                         |
|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| step             | The number of the training step. A training step represents a single pass, forward and backward, on a batch of training data.                       |
| elapsed_tokens   | The number of tokens the customized model has seen so far, including repeats.                                                                       |
| elapsed_examples | The number of examples the model has seen so far, including repeats. Each example represents one element in that step's batch of training data. For |

| Column name                  | Description                                                                                                                                                                                                                                                                                                                             |
|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                              | example, if the <b>Batch size</b> parameter is set to 32 in the <b>Advanced options</b> pane, this value increments by 32 in each training step.                                                                                                                                                                                        |
| training_loss                | The loss for the training batch.                                                                                                                                                                                                                                                                                                        |
| training_sequence_accuracy   | The percentage of completions in the training batch for which the model's predicted tokens exactly matched the true completion tokens.<br>For example, if the batch size is set to 3 and your data contains completions [[1, 2], [0, 5], [4, 2]], this value is set to 0.67 (2 of 3) if the model predicted [[1, 1], [0, 5], [4, 2]].   |
| training_token_accuracy      | The percentage of tokens in the training batch that were correctly predicted by the model.<br>For example, if the batch size is set to 3 and your data contains completions [[1, 2], [0, 5], [4, 2]], this value is set to 0.83 (5 of 6) if the model predicted [[1, 1], [0, 5], [4, 2]].                                               |
| validation_loss              | The loss for the validation batch.                                                                                                                                                                                                                                                                                                      |
| validation_sequence_accuracy | The percentage of completions in the validation batch for which the model's predicted tokens exactly matched the true completion tokens.<br>For example, if the batch size is set to 3 and your data contains completions [[1, 2], [0, 5], [4, 2]], this value is set to 0.67 (2 of 3) if the model predicted [[1, 1], [0, 5], [4, 2]]. |
| validation_token_accuracy    | The percentage of tokens in the validation batch that were correctly predicted by the model.<br>For example, if the batch size is set to 3 and your data contains completions [[1, 2], [0, 5], [4, 2]], this value is set to 0.83 (5 of 6) if the model predicted [[1, 1], [0, 5], [4, 2]].                                             |

Table 7: Contents of Fine-Tuning Results File

Once a customized model has been deployed, it can be used like any other deployed model. When finished with a customized model, a customer can delete the deployed model as well as the uploaded training and validation files that were uploaded to the service, if needed. A customized model cannot be deleted if it has an existing deployment. A deployment must be deleted before a customized model can be deleted.

## D. Deploying a Model

Azure subscribers can deploy a model by creating a resource and starting a deployment. It should be noted that, at this time, access to Azure OpenAI is granted by Microsoft only upon application and is subject to Microsoft's limited access licence terms for Microsoft Azure Terms.<sup>5</sup>

Resources in Azure can be created:

- Within the Azure portal.
- Using the REST APIs, Azure CLI, PowerShell, or customer libraries.
- Via ARM templates.

<sup>5</sup> The starting point for determining applicable legal terms and conditions may be found here: <https://www.microsoft.com/licensing/terms/productoffering/MicrosoftAzure/MCA>.

If the Azure portal is used, there is an Azure OpenAI Service Create Page, where an organization is required to provide specific information pertaining to the organization’s Azure subscription, its resource group, region, and the name selected for the resource. An illustration is provided in the Image below.

Create Azure OpenAI

Basics

Tags

Review + create

Enable new business solutions with OpenAI's language generation capabilities powered by GPT-3 models. These models have been pretrained with trillions of words and can easily adapt to your scenario with a few short examples provided at inference. Apply them to numerous scenarios, from summarization to content and code generation.

**Project details**

Select the subscription to manage deployed resources and costs. Use resource groups like folders to organize and manage all your resources.

Subscription \*

OpenAI Test Subscription

Resource group \*

test-resource-group

Create new

**Instance details**

Region \*

South Central US

Name \*

azure-openai-test-001

Pricing tier \*

Standard S0

[View full pricing details](#)

Review + create

< Previous

Next : Tags >

Image 2: Creation of Azure OpenAI Resource via Azure Portal

Before generating text or inference, a model needs to be selected and deployed. This requires a user to sign in to Azure OpenAI Studio, choose the subscription and OpenAI resource and then, within the OpenAI Studio, create a new deployment.

| Field            | Description                                                                                                                                                                                                                                                      |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Select a model   | Model availability varies by region.For a list of available models per region, see <a href="#">Model Summary table and region availability</a> .                                                                                                                 |
| Deployment name  | Choose a name carefully. The deployment name will be used in your code to call the model via the client libraries and REST API                                                                                                                                   |
| Advanced Options | Content Filter - Assign a content filter to your deployment.<br>Tokens per Minute Rate Limit - Adjust the Tokens per Minute (TPM) to set the effective rate limit for your deployment. You can modify this value at any time via the <a href="#">Quotas</a> menu |

Table 8: Choices to Deploy an Azure OpenAI Model

The deployments table will display a new entry that corresponds to the newly created model. Its deployment status will move to “succeeded” when the deployment is complete and ready for use. With a resource and a model deployed, users can then start making API calls and generating text.

## E. Conversations

The ChatGPT and GPT-4 models are language models that are optimized for conversational interfaces. The models behave differently than the older GPT-3 models. Previous models were text-in and text-out, meaning they accepted a prompt string and returned a completion to append to the prompt. However, as noted, the ChatGPT and GPT-4 models are “conversation-in” and “message-out”. The models expect input formatted in a specific chat-like transcript format and return a completion that represents a model-written message in the chat.

In Azure OpenAI there are two different options for interacting with these types of models:

- Chat Completion API.
- Completion API with Chat Markup Language (ChatML).

The Chat Completion API is a dedicated API for interacting with the ChatGPT and GPT-4 models. This API is the preferred method for accessing these models. **It is also the only way to access the new GPT-4 models.**

ChatML uses the same completion API that would be used for other OpenAI models. It requires a unique token-based prompt format known as Chat Markup Language (ChatML). This provides lower-level access than the dedicated Chat Completion API, but also requires additional input validation and only supports ChatGPT (gpt-35-turbo) models. **The underlying format is more likely to change over time.**

OpenAI trained the ChatGPT and GPT-4 models to accept input formatted as a conversation. The messages parameter takes an array of dictionaries with a conversation organized by role. It is the user’s responsibility to ensure any prompt and completion falls within the token limit. This means that for longer conversations, one needs to keep track of the token count and only send the model a prompt that falls within the limit.

**System role.** The system role - also known as the “system message” - can take the form of a metaprompt and is included at the beginning of the array. This message provides the initial instructions to the model. A user can provide various information in the system role including:

- A brief description of the assistant.
- Personality traits of the assistant.
- Instructions or rules for the assistant to follow.
- Data or information needed for the model, such as relevant questions from an FAQ.

The system role can be customized for a use case or just include basic instructions. The system role/message is optional, but it's recommended to, at least, include a basic one to get the best results.

**Messages.** After the system role, a series of messages between the user and the assistant can be included. To trigger a response from the model, a user message should end by indicating that it's the assistant's turn to respond.

## F. Prompt Construction

While GAI models such as GPT-3, GPT-3.5, and GPT-4 “converse” with the user, they are prompt-based, which simply means interactions consist of text being input with outputs being completed in the form of a response. Subject to their training data and training targets, GPT models attempt to produce the next series of words that are most likely to follow from the previous text. Whatever the prompt, the model responds with what text that it determines to be most likely. The prompt serves to configure the model weights to complete the desired task.

The construction of prompts involves Natural Language Processing (“NLP”) that embeds descriptions of tasks input to prompt the model to output the desired results. While “prompt engineering” is a commonly used term to describe this activity, prompt construction is more art than science. Prompts typically include problem descriptions, instructions on how to solve the problem, and examples of correct problem and solution pairs - all in a natural language format.

As previously noted, in Azure OpenAI there are two different options for interacting with these types of models:

- Chat Completion API – the only way to interact with ChatGPT-4.
- Completion API with Chat Markup Language (ChatML) – used with other models.

With the Chat Completion API there are distinct sections of the prompt that are sent to the API in the form of an array of dictionaries with associated roles: system, user, and assistant. All the components are optional, but at least one must be present, and most prompts include more than one component.

**Instructions.** Instructions are likely to be the most commonly used prompt component. Instructions are simply that: instructions to the model on what to do. While simple in concept, they can be complex in practice.

**Primary Content.** Primary content refers to text that is being processed or transformed by the model. Primary content is typically used in conjunction with instructions. A simple example would be language translation. GPT models can also handle primary content that is structured.

**One-shot/few-shot.** Successful prompts often rely on the practice of “one-shot” or “few-shot” learning. With a “one shot” prompt, the model predicts the answer given only a natural language description of the task. With a “few shot” prompt, one or more examples of the desired behavior of the model is included, typically by using input and output pairs. This is not learning in the sense that the model is permanently changed, but rather a situation where the examples better condition the model to respond as desired.

The use of prompts with no examples is sometimes referred to as “zero-shot” learning. With the Chat Completion API, few-shot learning examples are typically added to the messages array in the form of example user/assistant interactions after the initial system message.

| Learning Type | Prompt                                                                                                                                                                                                                                                                                               | Completion                                                                                                                                                                   |
|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Zero-shot     | Headline: Coach confident injury won't derail Warriors<br>Topic:                                                                                                                                                                                                                                     | The coach is confident that the injury won't derail the Warriors' season. The team is still focused on their goals and that they will continue to work hard to achieve them. |
| Few-shot      | Headline: Twins' Correa to use opt-out, test free agency<br>Topic: Baseball<br>Headline: Qatar World Cup to have zones for sobering up<br>Topic: Soccer<br>Headline: Yates: Fantasy football intel for Week 6<br>Topic: Football<br>Headline: Coach confident injury won't derail Warriors<br>Topic: | Basketball                                                                                                                                                                   |

Table 9: Examples of Learning Types

Without examples, the model seems to be guessing at the desired behavior, while the examples clearly show the model how to operate.

**Cues.** Cues act as the “jumpstart” for the output of the model, helping to direct the model to the desired output. It is often a prefix that the model can build onto. Cues can also be used along with instructions but are not necessary.

In the context of the Chat Completion API instructions take the form of the system message, and few-shot examples are indicated by providing a series of example user/assistant interactions to help prime the model.

**Supporting content.** Supporting content is information that the model can utilize to influence the output in some way. It differs from primary content in that it is not the main target of task, but it is typically used along with primary content. Common examples include contextual information such as the current date, the name of the user, user preferences, and so on.

## G. Generating or Manipulating Text

The completions endpoint can be used for a wide variety of tasks. It provides a simple but powerful text-in, text-out interface to any of the Azure OpenAI models. Text is input as a prompt, and the model will generate a text completion that attempts to match whatever context or pattern provided. Microsoft’s Azure OpenAI Service provides REST API<sup>6</sup> access to OpenAI’s LLMs. Users can also access the service through Python SDK, or Microsoft’s web-based interface in the Azure OpenAI Studio.

The actual completion results may differ because the API is probability based (i.e., has a random probability distribution that may be analyzed statistically but may not be predicted precisely) by default.

<sup>6</sup> A Representational State Transfer (REST) Application Programming Interface (“API”) is a way of accessing web services, simply and with flexibility, without any processing. REST is an architectural style used for creating web services. A REST API is an API that conforms to the design principles of the representational state transfer architectural style.

One might get a slightly different completion every time one is called for, even if the prompt stays the same. You can control this behavior with the “temperature” setting.

This simple, “text in, text out” interface means you can “program” the model by providing instructions or just a few examples of what you'd like it to do. Its success generally depends on the complexity of the task and quality of your prompt. A general rule is to think about how you would write a word problem for a middle school student to solve. A well-written prompt provides enough information for the model to know what you want and how it should respond.

**Prompt Design.** OpenAI's models try to predict what a user wants from the prompt. There are three basic guidelines to creating prompts:

- **Show and tell.** A user must make it clear what is wanted. This is done either through instructions, examples, or a combination of the two.
- **Provide quality data.** If building a classifier or attempting to get the model to follow a pattern, provide enough examples.
- **Check the settings.** The temperature and top\_p settings control how deterministic the model is in generating a response. If asking for a response where there's only one right answer, then these settings are to be set to lower values. If asking for a response that's not obvious, then these settings should be set to higher values. A common mistake made with these settings is assuming that they're “cleverness” or “creativity” controls.

While all prompts result in completions, it can be helpful to think of text completion as its own task in instances where the user wants the API to pick up where the user left off. You can lower the temperature setting to keep the API more focused on the intent of the prompt or increase it to let it go off on a tangent.

One should note that there is a distinction between administrator actions and “user” actions in that administrators can develop pre-prompts or meta prompts.

**Best prompt construction practices.** To obtain the best completions, Microsoft offers the following advice:

- **Be Specific.** Leave as little to interpretation as possible. Restrict the operational space.
- **Be Descriptive.** Use analogies.
- **Double Down.** Sometimes repetition is needed. Give instructions before and after the primary content, use an instruction and a cue, etc.
- **Order Matters.** The order in which information is presented to the LLM is information and may impact the output. Even the order of few-shot examples can matter. This is referred to as recency bias.
- **Give the model an “out”.** It can sometimes be helpful to give the model an alternative path if it is unable to complete the assigned task. For example, when asking a question over a piece of text, include something like “respond with ‘not found’ if the answer is not present”. This can help the model avoid generating false responses.

**Space efficiency.** While the input size increases with each new generation of GPT models, there will continue to be scenarios that provide more data than the model can handle. GPT models break words

into “tokens”. While common multi-syllable words are often a single token, less common words are broken in syllables.

Given this limited space, it is important to be as efficiently as possible.

- Tables – As shown in the examples in the previous section, GPT models can understand tabular formatted data quite easily. This can be a space efficient way to include data, rather than preceding every field with name (such as with JSON).
- White Space – Consecutive whitespaces are treated as separate tokens which can be an easy way to waste space. Spaces preceding a word, on the other hand, are typically treated as part of the same token as the word. It is recommended to carefully watch the usage of whitespace and to not use punctuation when a space alone will do.

**Factual responses.** The API has a lot of knowledge that it's learned from the data it was trained on. It also can provide responses that sound very real but are in fact made up.

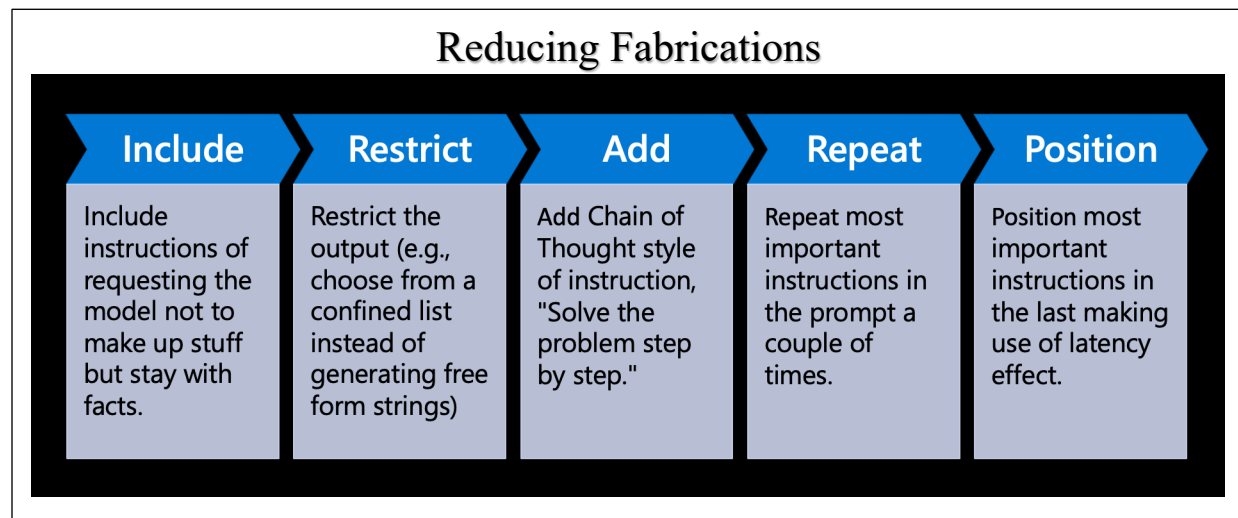


Image 3: How to Reduce Hallucinations

There are two ways to limit the likelihood of the API making up an answer.

1. **Provide a ground truth for the API** If provided with a body of text to answer questions about (like a Wikipedia entry) the API will be less likely to confabulate a response.
2. **Use a low probability and show the API how to say "I don't know"** If the API understands that in cases where it is less certain about a response that saying "I don't know" or some variation is appropriate, it will be less inclined to make up answers.

## H. Working with Codex

Codex can be used for a variety of tasks including:

- Turning comments into code.
- Completing the next line or function in context.
- Bringing knowledge to the user, such as finding a useful library or API call for an application.
- Adding comments.

- Rewriting code for efficiency.

Codex's ability to create and understand code allows it to be used to perform tasks such as explaining what the code in a file does. One way to accomplish this is by putting a comment after a function that starts with "This function" or "This application is." Codex will usually interpret this as the start of an explanation and complete the rest of the text.

The Codex model series is most capable in Python but is also proficient in over a dozen languages including C#, JavaScript, Go, Perl, PHP, Ruby, Swift, TypeScript, SQL, and Shell.

Many of these languages share similar conventions for comments, functions, and other programming syntax. By specifying the language and what version in a comment, Codex is better able to provide a completion for what is wanted.

Setting the API temperature to 0, or close to zero (such as 0.1 or 0.2) tends to give better results in most cases. Unlike GPT-3 models, where a higher temperature can provide useful creative and random results, higher temperatures with Codex models may give very random or erratic responses.

Requesting longer completions in Codex can lead to imprecise answers and repetition. Microsoft recommends limiting the size of the query by reducing `max_tokens` and setting stop tokens. Smaller completions also incur less latency.

Large Codex queries can take tens of seconds to complete. To build applications that require lower latency, such as coding assistants that perform autocompletion, Microsoft recommends consideration of streaming. In streaming, responses will be returned before the model finishes generating the entire completion. Applications that need only part of a completion can reduce latency by cutting off a completion either programmatically or by using creative values for stop. Users can combine streaming with duplication to reduce latency by requesting more than one solution from the API and using the first response returned.

By using examples, users can show Codex how to identify errors in code. In some cases, no examples are required, however demonstrating the level and detail to provide a description can help Codex understand what to look for and how to explain it. Microsoft cautions that a check by Codex for errors is not a substitute for careful review by the user.

## I. Support for Azure OpenAI

Support for Azure OpenAI is provided by Azure and CSEO. Azure OpenAI relies upon the physical infrastructure and security measures associated with Microsoft Azure. The Azure product group provides support services for Microsoft's applications, including authentication, virtual server hosting, and system data storage.

Microsoft Entra ID, formerly known as Azure Active Directory, provides user account management as well as a rights management service. Account management services are hosted on physical servers managed by CSEO. Network access to these servers is controlled by CSEO-managed network devices using rules managed by Microsoft Entra ID and approved by Azure.

The Rights Management Service offering is hosted on virtual servers managed by Azure. Network access to these servers is controlled by Azure devices using rules managed by Microsoft Entra ID and approved by Azure.

Microsoft administrators access Entra ID virtual machines through the Azure Administrative Portal. This access requires smartcard multi-factor authentication. Microsoft administrators access Entra ID's physical servers through remote desktop gateways managed by CSEO. Such access requires smartcard-based multi-factor authentication. Users do not directly interact with Entra ID. Connections between Microsoft Entra ID and a customer's Entra ID Directory infrastructure are protected via FIPS-compliant transport layer security ("TLS").

Azure OpenAI is hosted within the CSEO environment. CSEO implements the network layer and network layer protections and is responsible for physical and environmental security. Network access to the servers is controlled by CSEO managed network devices. Azure is responsible for host machine operating system protections. Network layer protections are implemented by CSEO and are managed in coordination with Azure.

Implementation of network layer security controls between the public Internet and Azure OpenAI is provided by CSEO and/or Azure. CSEO also implements network intrusion detection and denial-of-service protection.

[Remainder of page left intentionally blank.]

## PART 3: AI SAFETY MEASURES

Microsoft has publicly indicated that it is committed to the responsible development and deployment of AI systems and the applications through which users access such systems. With respect to Azure OpenAI, the company has implemented policies and mechanisms to better support the responsible use of AI by its customers. This Part describes the measures implemented by Microsoft as well as what it recommends customers undertake with respect to their use of AI.

### A. Registration

Azure OpenAI requires registration and is currently only available to approved enterprise customers and partners. Customers who wish to use Azure OpenAI are required to submit a registration form<sup>7</sup>.

As part of the registration process, customers are required to attest to any and all use cases for which they will use the service. The use cases from which customers may select will populate in the form after selection of the desired model(s). Customers who wish to add additional use cases after initial onboarding must submit the additional use cases using another form. The use of Azure OpenAI is limited to use cases that have been selected in a registration form. Microsoft indicates that it may require customers to re-verify this information.

Customers who wish to modify content filters and modify abuse monitoring after they have onboarded to the service are subject to additional eligibility criteria and scenario restrictions. Currently, modified content filters and/or modified abuse monitoring for Azure OpenAI Service are only available to managed customers and partners working with Microsoft account teams and have additional use case restrictions.

Microsoft indicates that access to the Azure OpenAI Service is subject to Microsoft's sole discretion based on eligibility criteria and a vetting process, and customers must acknowledge that they have read and understand the Azure terms of service for Azure OpenAI Service.

### B. Code of Conduct

As part of its registration and approval process, Microsoft requires all Azure OpenAI users to adhere to a Code of Conduct, which defines a series of requirements for all Azure OpenAI Service implementations. As well as an extensive series of content prohibitions. This code of conduct is separate and distinct from the Acceptable Use Policy outlined in the Microsoft Online Service and Product Terms.

**Integration Requirements.** Under the Code of Conduct, integrations with Azure OpenAI Service are required to:

- Implement meaningful human oversight.
- Implement strong technical limits on inputs and outputs to reduce the likelihood of misuse beyond the application's intended purpose.
- Test applications thoroughly to find and mitigate undesirable behaviors.

---

<sup>7</sup> Available at:

[https://customervoice.microsoft.com/Pages/ResponsePage.aspx?id=v4j5cvGGr0GRqy180BHbR7en2Ais5pxKtso\\_Pz4b1\\_xUNTZBNzRKNIVQSFhZMU9aV09EVzYxWfDORCQIQCN0PWcu.](https://customervoice.microsoft.com/Pages/ResponsePage.aspx?id=v4j5cvGGr0GRqy180BHbR7en2Ais5pxKtso_Pz4b1_xUNTZBNzRKNIVQSFhZMU9aV09EVzYxWfDORCQIQCN0PWcu.)

- Establish feedback channels.
- Implement additional scenario-specific mitigations.

**Integration Prohibitions.** Similarly, integrations with Azure OpenAI Service are not to:

- Be used in any way that violates Microsoft's Acceptable Use Policy, including but not limited to any use prohibited by law, regulation, government order, or decree, or any use that violates the rights of others.
- Be used in any way that is inconsistent with the Code of Conduct, including the Limited Access requirements, the Responsible AI mitigation requirements, and the Content requirements.
- Exceed the use case(s) identified to Microsoft in connection with a request to use the service.
- Interact with individuals under the age of consent in any way that could result in exploitation or manipulation or is otherwise prohibited by law or regulation.
- Generate or interact with content prohibited in the Code of Conduct.
- Be presented alongside or monetize content prohibited under the Code of Conduct.
- Make decisions without appropriate human oversight if a customer's application may have a consequential impact on any individual's legal position, financial position, life opportunities, employment opportunities, human rights, or result in physical or psychological injury to an individual.
- Infer sensitive information about people without their explicit consent except if used in a lawful manner by a law enforcement entity, court, or government official subject to judicial oversight in a jurisdiction that maintains a fair and independent judiciary.
- Be used for chatbots that (i) are erotic, romantic, or used for companionship purposes, or which are otherwise prohibited by the Code of Conduct; (ii) are personas of specific people without their explicit consent; (iii) claim to have special wisdom/insight/knowledge, unless very clearly labeled as being for entertainment purposes only; or (iv) enable end users to create their own chatbots without oversight.

**Content Requirements.** The content requirements indicated in the Code of Conduct apply to the output of all models developed by OpenAI and hosted in Azure OpenAI and includes any content provided as input to the service and any content generated as output from the service.

As a general statement, Microsoft's Code of Conduct expressly prohibits the use of the Azure OpenAI service for generating content that can inflict harm on individuals or society. It then goes on to identify and outline specific content prohibitions. In particular, the following types of content are prohibited:

**Child sexual exploitation and abuse.** Content that describes, features, or promotes child sexual exploitation or abuse, whether or not prohibited by law, is prohibited. This includes sexual content involving a child or that sexualizes a child.

**Grooming.** Content that describes or is used for purposes of grooming of children. Grooming is defined as the act of an adult building a relationship with a child for the purposes of exploitation, especially sexual exploitation. This includes communicating with a child for the purpose of sexual exploitation, trafficking, or other forms of exploitation.

**Non-consensual intimate content.** Content that describes, features, or promotes non-consensual intimate activity.

**Sexual solicitation.** Content that describes, features, or promotes, or is used for, purposes of solicitation of commercial sexual activity and sexual services. This includes encouragement and coordination of real sexual activity.

**Trafficking.** Content describing or used for purposes of human trafficking. This includes the recruitment of individuals, facilitation of transport, and payment for, and the promotion of, exploitation of people such as forced labor, domestic servitude, sexual slavery, forced marriages, and forced medical procedures.

**Suicide and Self-Injury.** Content that describes, praises, supports, promotes, glorifies, encourages and/or instructs individual(s) on self-injury or to take their life.

**Graphic violence and gore.** Content that describes, features, or promotes graphic violence or gore.

**Terrorism and Violent Extremism.** Content that depicts an act of terrorism; praises, or supports a terrorist organization, terrorist actor, or violent terrorist ideology; encourages terrorist activities; offers aid to terrorist organizations or terrorist causes; or aids in recruitment to a terrorist organization.

**Violent Threats, Incitement, and Glorification of Violence.** Content advocating or promoting violence toward others through violent threats or incitement.

**Hate speech and discrimination** Content that attacks, denigrates, intimidates, degrades, targets, or excludes individuals or groups on the basis of traits such as actual or perceived race, ethnicity, national origin, gender, gender identity, sexual orientation, religious affiliation, age, disability status, caste, or any other characteristic that is associated with systemic prejudice or marginalization.

**Bullying and harassment.** Content that targets one or more individuals or groups with threats, intimidation, insults, degrading or demeaning language or images, promotion of physical harm, or other abusive behavior such as stalking.

**Deception, disinformation, and inauthentic activity.** Content that is intentionally deceptive and likely to adversely affect the public interest, including deceptive or untrue content relating to health, safety, election integrity, or civic participation. Azure OpenAI Service also prohibits inauthentic interactions, such as fake accounts, automated inauthentic activity, impersonation to gain unauthorized information or privileges, and claims to be from any person, company, government body, or entity without explicit permission to make that representation.

**Active malware or exploits.** Content that directly supports unlawful active attacks or malware campaigns that cause technical harms, such as delivering malicious executables, organizing denial of service attacks, or managing command and control servers.

In addition to these specific requirements and prohibitions, Microsoft maintains an open-ended prohibition “for scenarios in which the system is likely to generate undesired content due to limitations in the models or scenarios in which the system cannot be applied in a way that properly manages potential negative consequences to people and society.” Similarly, “Microsoft reserves the right to revise and expand the above Content requirements to address specific harms to people and society” and “[w]e prohibit the use of Azure OpenAI Service for activities that significantly harm other individuals, organizations, or society...”

In connection with the enforcement of these prohibitions, Microsoft maintains a portal<sup>8</sup> to permit the reporting of suspected misconduct.

### Submit Abuse Report (CERT)

Please fill out the following form if you have experienced abuse originating from a Microsoft-hosted site or service. This form should be used to report suspected cyber attacks or abuse originating from Microsoft Online Services, such as Microsoft Azure, Bing, OneDrive, and Office 365. This includes malicious network activity originating from a Microsoft-owned IP address space. It also includes distribution of malicious or illegal content through a Microsoft Online Service. Fields marked with an asterisk (\*) are required.



#### Reporting: URL - Responsible AI 🤖

Relates to Microsoft's Responsible AI principles: reliability and safety, fairness, privacy and security, inclusiveness, transparency and accountability. Only available through the Report Abuse Portal.

< I want to report something else

Image 4: AI Abuse Reporting Form

## C. Abuse Monitoring

To ensure conformity with its Code of Conduct or other applicable product terms, Microsoft conducts abuse monitoring. It does so by detecting and mitigating instances of recurring unacceptable content and/or behaviors. This process is similar to that for virus monitoring in that it is an automated process at first but then involves human review if specific activity is flagged for follow up.

There are several components to Microsoft's abuse monitoring process:

- **Content Classification:** Classifier models detect harmful language and/or images in user prompts (inputs) and completions (outputs).
- **Abuse Pattern Capture:** Azure OpenAI Service's abuse monitoring looks at customer usage patterns and employs algorithms and heuristics to detect indicators of potential abuse. Detected patterns consider, for example, the frequency and severity at which harmful content is detected in a customer's prompts and completions.
- **Human Review and Decision:** When prompts and/or completions are flagged through content classification and abuse pattern capture as described above, authorized Microsoft employees may assess the flagged content, and either confirm or correct the classification or determination based on predefined guidelines and policies. Data can be accessed for human review only by authorized Microsoft employees via Secure Access Workstations with Just-In-Time request approval granted by team managers.
- **Notification and Action:** When a threshold of abusive behavior has been confirmed based on the preceding three steps, the customer is informed of the determination by email. Except in cases of severe or recurring abuse, customers typically are given an opportunity to explain or

<sup>8</sup> Available at: <https://msrc.microsoft.com/report/abuse>.

remediate—and implement mechanisms to prevent recurrence of—the abusive behavior. Failure to address the behavior—or recurring or severe abuse—may result in suspension or termination of the customer’s access to Azure OpenAI resources and/or capabilities.

Some customers may want to use the Azure OpenAI Service for a use case that involves the processing of sensitive, highly confidential, or legally regulated input data but where the likelihood of harmful outputs and/or misuse is low. These customers may conclude that they do not want or do not have the right to permit Microsoft to process such data for abuse detection due to their internal policies or applicable legal regulations. To address these concerns, Microsoft allows customers who meet additional Limited Access eligibility criteria and attest to specific use cases to apply to modify the Azure OpenAI content management features.

## D. Content Filtering

Azure OpenAI Service includes a content filtering system. This system works by running both the prompt and completion through a series of classification models aimed at detecting and preventing the output of harmful content. Microsoft indicates that the content filtering system detects and acts on specific categories of potentially harmful content in both input prompts and output completions.

Variations in API configurations and application design may affect completions and thus filtering behavior.

In addition to the content filtering system, the Azure OpenAI Service performs monitoring to detect content and/or behaviors that suggest use of the service in a manner that may violate applicable product terms.

**Content filtering categories.** The content filtering system integrated in the Azure OpenAI Service contains neural multi-class classification models aimed at detecting and filtering harmful content; the models cover four categories (hate, sexual, violence, and self-harm) across four severity levels (safe, low, medium, and high). Content detected at the 'safe' severity level is labeled in annotations but is not subject to filtering and is not configurable.

| Category  | Description                                                                                                                                                                                                                                                                                                                                                                                                              |
|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Hate      | The hate category describes language attacks or uses that include pejorative or discriminatory language with reference to a person or identity group on the basis of certain differentiating attributes of these groups including but not limited to race, ethnicity, nationality, gender identity and expression, sexual orientation, religion, immigration status, ability status, personal appearance, and body size. |
| Sexual    | The sexual category describes language related to anatomical organs and genitals, romantic relationships, acts portrayed in erotic or affectionate terms, physical sexual acts, including those portrayed as an assault or a forced sexual violent act against one's will, prostitution, pornography, and abuse.                                                                                                         |
| Violence  | The violence category describes language related to physical actions intended to hurt, injure, damage, or kill someone or something; describes weapons, etc.                                                                                                                                                                                                                                                             |
| Self-Harm | The self-harm category describes language related to physical actions intended to purposely hurt, injure, or damage one's body, or kill oneself.                                                                                                                                                                                                                                                                         |

Table 10: Harmful Content Categories

| Category | Description                                                                                                                                                                                                                                                       |
|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Safe     | Content may be related to violence, self-harm, sexual, or hate categories but the terms are used in general, journalistic, scientific, medical, and similar professional contexts, which are appropriate for most audiences.                                      |
| Low      | Content that expresses prejudiced, judgmental, or opinionated views, includes offensive use of language, stereotyping, use cases exploring a fictional world (for example, gaming, literature) and depictions at low intensity.                                   |
| Medium   | Content that uses offensive, insulting, mocking, intimidating, or demeaning language towards specific identity groups, includes depictions of seeking and executing harmful instructions, fantasies, glorification, promotion of harm at medium intensity.        |
| High     | Content that displays explicit and severe harmful instructions, actions, damage, or abuse; includes endorsement, glorification, or promotion of severe harmful acts, extreme or illegal forms of harm, radicalization, or non-consensual power exchange or abuse. |

Table 11: Harmful Content Ratings

The default content filtering configuration is set to filter at the medium severity threshold for all four content harms categories for both prompts and completions. That means that content that is detected at severity level medium or high is filtered, while content detected at severity level low or safe is not filtered by the content filters.

[Remainder of page left intentionally blank.]

| Severity filtered | Configurable for prompts | Configurable for completions | Descriptions                                                                                                                             |
|-------------------|--------------------------|------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| Low, medium, high | Yes                      | Yes                          | Strictest filtering configuration. Content detected at severity levels low, medium and high is filtered.                                 |
| Medium, high      | Yes                      | Yes                          | Default setting. Content detected at severity level low is not filtered, content at medium and high is filtered.                         |
| High              | If approved*             | If approved*                 | Content detected at severity levels low and medium is not filtered. Only content at severity level high is filtered. Requires approval*. |
| No filters        | If approved*             | If approved*                 | No content is filtered regardless of severity level detected. Requires approval*.                                                        |

Table 12: Default Filtering Configuration

The content filtering system supports the following languages: English, German, Japanese, Spanish, French, Italian, Portuguese, and Chinese. Microsoft indicates that it might not be able to detect inappropriate content in languages that it has not been trained or tested to process.

**Filtering Operations.** Microsoft indicates that Azure OpenAI customers who have been approved for modified content filtering may have full content filtering control, including configuring content filters at

severity level high only or turning content filters off. In Azure OpenAI, content filters can be configured at resource level. Once a new configuration is created, it can be associated with one or more deployments.

**Create content filtering configuration**

Content filtering configurations are created within a Resource and can be associated with Deployments.  
[Learn more about configurability here.](#)

The default content filtering configuration is set to filter at the medium severity threshold for all four content harms categories for both, prompts and completions. That means that content that is detected at severity level medium or high is filtered, while content detected at severity level low is not filtered by the content filters.

Create custom configuration name

**Set severity levels**

| Severity  | User prompts (Input)             |                       |                       | Model completions (Output)       |                       |                       |
|-----------|----------------------------------|-----------------------|-----------------------|----------------------------------|-----------------------|-----------------------|
|           | Low                              | Medium                | High                  | Low                              | Medium                | High                  |
| Hate      | <input checked="" type="radio"/> | <input type="radio"/> | <input type="radio"/> | <input checked="" type="radio"/> | <input type="radio"/> | <input type="radio"/> |
| Sexual    | <input checked="" type="radio"/> | <input type="radio"/> | <input type="radio"/> | <input checked="" type="radio"/> | <input type="radio"/> | <input type="radio"/> |
| Self-harm | <input checked="" type="radio"/> | <input type="radio"/> | <input type="radio"/> | <input checked="" type="radio"/> | <input type="radio"/> | <input type="radio"/> |
| Violence  | <input checked="" type="radio"/> | <input type="radio"/> | <input type="radio"/> | <input checked="" type="radio"/> | <input type="radio"/> | <input type="radio"/> |

[Learn more about content filters here](#)

Image 5: Azure Content Configuration Page

When the content filtering system detects harmful content, the user will receive either an error on the API call if the prompt was deemed inappropriate or the “finish\_reason” on the response will be “content\_filter” to signify that some of the completion was filtered. The behavior can be summarized in the following points:

- Prompts that are classified at a filtered category and severity level will return an HTTP 400 error.
- Non-streaming completions calls won't return any content when the content is filtered. The “finish\_reason” value will be set to “content\_filter”. In rare cases with longer responses, a partial result can be returned. In these cases, the “finish\_reason” will be updated.
- For streaming completions calls, segments will be returned to the user as they're completed. The service will continue streaming until either reaching a stop token, length, or when content that is classified at a filtered category and severity level is detected.

## E. Red Teaming

“Red teaming” is a term to describe systematic adversarial attacks for the purpose of testing security vulnerabilities. With the rise of LLMs, the term has evolved to generally describe many ways to probe, test, and attack of AI systems. Red teaming is viewed as an essential practice in the responsible development of systems and features using LLMs.

Microsoft advises customers that they should conduct red teaming to:

- Test the LLM base model and determine whether there are gaps in the existing safety systems.
- Identify and mitigate shortcomings in the existing default filters or mitigation strategies.
- Provide feedback on failures so Microsoft can make improvements.

Because a system is developed using a LLM base model, customers may need to test at several different layers:

- The LLM base model. Testing is usually through an API endpoint.
- The application system. Testing is usually through a UI.
- Both the LLM base model and the application system before and after mitigations are in place.

Iterative red teaming should occur in at least two phases:

1. Open-ended red teaming, where red teamers are encouraged to discover a variety of harms. This can help develop a taxonomy of harms to guide further testing. A taxonomy of undesired LLM outputs for the application system is important to measure the success of specific mitigation efforts.
2. Guided red teaming, where red teamers are assigned to focus on specific harms listed in the taxonomy while alert for any new harms. Red teamers can also be instructed to focus testing on specific features of a system for surfacing potential harms.

Members of a “red team” should have clear instructions:

- As to what harms or system features they will be testing.
- To record findings, specifically:
  - The type of harm that was surfaced.
  - The input prompt that triggered the output.
  - An excerpt from the problematic output.
  - Comments about why the output problematic was considered.

Red teaming findings should be reported at regular intervals to key stakeholders.

## F. Monitoring

As is the case for other Azure resources, Azure OpenAI collects monitoring data and allows customers to track them. Diagnostic settings can be set to define where resource logs and metrics for a particular resource should be sent. Possible destinations include:

- **Activity log:** Subscription-level events that track operations for each Azure resource, for example, creating a new resource or starting a virtual machine. Activity log events are automatically generated and collected for viewing in the customer’s Azure portal. Customers can create a diagnostic setting to send the activity log to Azure Monitor Logs.
- **Platform metrics:** Numerical values that are automatically collected at regular intervals and describe some aspect of a resource at a particular time. Platform metrics are automatically generated and collected in Azure Monitor Metrics.

- **Resource logs:** Provides insight into operations that were performed by an Azure resource. Operation examples might be getting a secret from a key vault or making a request to a database. Resource logs are generated automatically, but customers must create a diagnostic setting to send them to Azure Monitor Log.
- **Virtual machine guest metrics and logs:** Performance and log data from the guest operating system of Azure virtual machines. Customers must install an agent on the virtual machine to collect this data and send it to Azure Monitor Metrics and Azure Monitor Logs.

Platform metrics and the Activity log are collected and stored automatically but can be routed to other locations by using a diagnostic setting. Resource logs are not collected and stored until an organization create a diagnostic setting and route them to one or more locations. Alerts on metrics, logs and the activity log may also be set.

The current subset of metrics available in Azure OpenAI are:

[Remainder of page left intentionally blank.]

| Metric                 | Exportable via Diagnostic Settings? | Metric Display Name                | Unit             | Aggregation Type | Description                                                        | Dimensions                                                      |
|------------------------|-------------------------------------|------------------------------------|------------------|------------------|--------------------------------------------------------------------|-----------------------------------------------------------------|
| BlockedCalls           | Yes                                 | Blocked Calls                      | Count            | Total            | Number of calls that exceeded rate or quota limit.                 | ApiName, OperationName, Region, RatelimitKey                    |
| CustomerErrors         | Yes                                 | Customer Errors                    | Count            | Total            | Number of calls with customer side error (HTTP response code 4xx). | ApiName, OperationName, Region, RatelimitKey                    |
| DataIn                 | Yes                                 | Data In                            | Bytes            | Total            | Size of incoming data in bytes.                                    | ApiName, OperationName, Region                                  |
| DataOut                | Yes                                 | Data Out                           | Bytes            | Total            | Size of outgoing data in bytes.                                    | ApiName, OperationName, Region                                  |
| FineTunedTrainingHours | Yes                                 | Processed FineTuned Training Hours | Count            | Total            | Number of Training Hours Processed on an OpenAI FineTuned Model    | ApiName, ModelDeploymentName, FeatureName, UsageChannel, Region |
| Latency                | Yes                                 | Latency                            | MilliSec<br>onds | Average          | Latency in milliseconds.                                           | ApiName, OperationName, Region, RatelimitKey                    |

| Metric           | Exportable via Diagnostic Settings? | Metric Display Name        | Unit  | Aggregation Type | Description                                                                | Dimensions                                                      |
|------------------|-------------------------------------|----------------------------|-------|------------------|----------------------------------------------------------------------------|-----------------------------------------------------------------|
| Ratelimit        | Yes                                 | Ratelimit                  | Count | Total            | The current ratelimit of the ratelimit key.                                | Region, RatelimitKey                                            |
| ServerErrors     | Yes                                 | Server Errors              | Count | Total            | Number of calls with service internal error (HTTP response code 5xx).      | ApiName, OperationName, Region, RatelimitKey                    |
| SuccessfulCalls  | Yes                                 | Successful Calls           | Count | Total            | Number of successful calls.                                                | ApiName, OperationName, Region, RatelimitKey                    |
| TokenTransaction | Yes                                 | Processed Inference Tokens | Count | Total            | Number of Inference Tokens Processed on an OpenAI Model                    | ApiName, ModelDeploymentName, FeatureName, UsageChannel, Region |
| TotalCalls       | Yes                                 | Total Calls                | Count | Total            | Total number of calls.                                                     | ApiName, OperationName, Region, RatelimitKey                    |
| TotalErrors      | Yes                                 | Total Errors               | Count | Total            | Total number of calls with error response (HTTP response code 4xx or 5xx). | ApiName, OperationName, Region, RatelimitKey                    |

Table 13: Azure OpenAI Metrics

Alerts on metrics, logs and the activity log may also be set.

[Remainder of page left intentionally blank.]



## PART 4: PERSONAL INFORMATION

### A. Data Flows

First and foremost, the Azure OpenAI Service is fully controlled by Microsoft; Microsoft hosts the OpenAI models in Microsoft's Azure environment and the service does NOT interact with any services operated by OpenAI (e.g. ChatGPT, or the OpenAI API).

Customers are responsible for managing the information within their subscription environment. Azure provides mechanisms for logging access to files, applications, and data (such as Azure Diagnostics Services).

Customer access to Azure services begins and ends at Internet-enabled customer locations and, between initiation and completion, travels to Microsoft datacenter. The connections established between customers and Microsoft datacenters are encrypted using FIPS 140-2-compatible Transport Layer Security ("TLS") /Secure Sockets Layer ("SSL").

Transactions involving the Azure Portal is encrypted using TLS 1.2 256-bit encryption. SSL/TLS is mandatory in accessing the Azure Portal or System Management API. Microsoft indicates that critical communications such as calls to the API or intra-Azure communications are encrypted and authenticated.

Subject to reviews where inputs are flagged, data stored in Azure is owned, controlled, and accessed by the customer. It should be noted that Azure customers are entirely responsible for the protection and encryption of their workflow processes surrounding data uploaded and processed within their Azure subscription environment. With respect to Azure OpenAI, customers can select and control data regions, data redundancy/replication, and offload.

Microsoft indicates that it uses industry standard encryption protocols (e.g. TLS) to protect data in transit, between devices and the datacenter. Within the data center, customers can enable encryption for traffic between their own virtual machines and their end users.

**Data Types Processed.** Azure OpenAI processes the following types of data:

- Prompts and generated content via completions, chat completions, images, and embeddings operations.
- Augmented data included with prompts.
- Training and validation data provided by the customer.

Uploaded training data is stored in the Azure OpenAI resource in the customer's Azure tenant. Microsoft indicates that training data uploaded for fine-tuning is not used to train, retrain, or improve any Microsoft or 3rd party base models.

Training data and fine-tuned models:

- Are available exclusively for use by the customer.
- Are stored within the same region as the Azure OpenAI resource.
- Can be double encrypted at rest (by default with Microsoft's AES-256 encryption and optionally with a customer-managed key).
- Can be deleted by the customer at any time.

**Data Use Restrictions.** A customer's prompts (inputs), completions (outputs), embeddings, and training/validation data:

- are NOT available to other customers.
- are NOT available to OpenAI.
- are NOT used to improve OpenAI models.
- are NOT used to improve any Microsoft or 3rd party products or services.
- are NOT used for automatically improving Azure OpenAI models.

Similarly, a customer's fine-tuned Azure OpenAI models are not available to other customers or OpenAI.

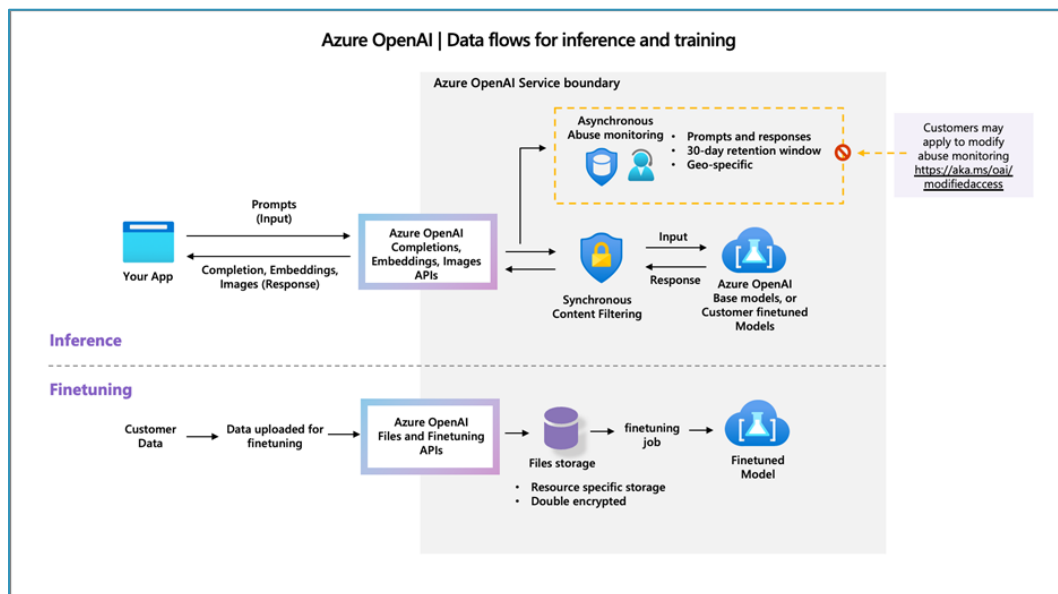


Image 6: Data Flows I

In terms of “process”, a customer/user:

1. Enters a prompt.
2. The Prompt is augmented with meta prompt and other contextual data.
3. The LLM develops a variety of queries of the Customer Data source.
4. The customer's data source returns many responses.
5. The LLM summarizes and grounds the response.
6. The LLM sends natural language response to the customer.

The GPT models within the Azure OpenAI Service are stateless: no prompts or generations are stored in the model.

The Azure OpenAI "on your data" feature lets a customer connect data sources to ground the generated results with their own data. The data remains stored in the data source and location designated by the customer. **No data is copied into the Azure OpenAI service. No data is used to train the foundational model. No data is indexed by the Azure OpenAI service.** When a user prompt is received, the service retrieves relevant data from the connected data source and augments the prompt.

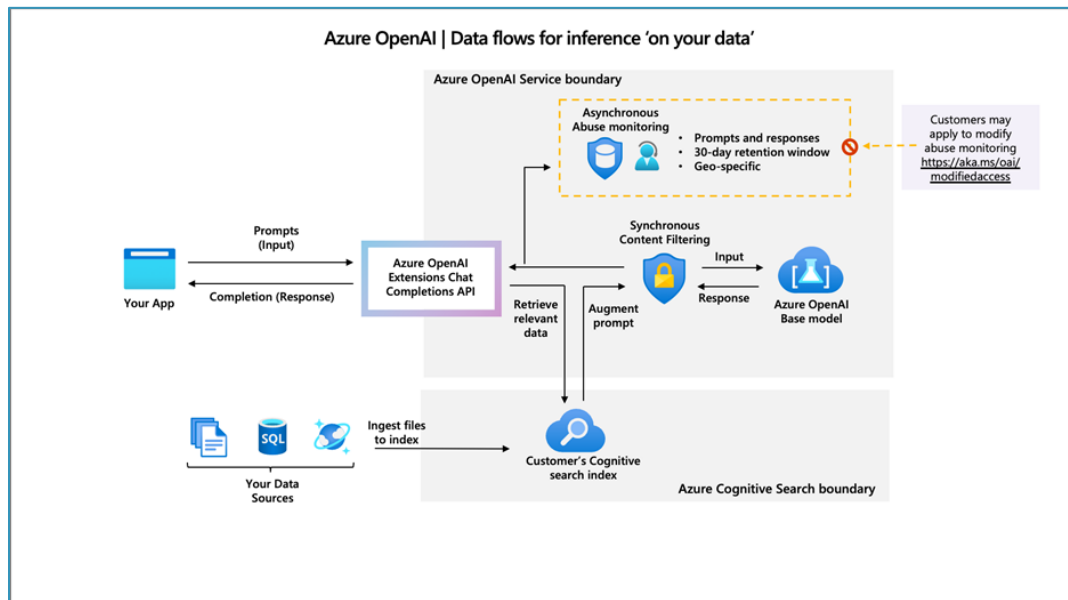


Image 7: Data Flows II (On Customer Data)

**Data Monitoring.** The service is configured to synchronously evaluate the prompt and completion data in real time to check for harmful content types and stops generating content that exceeds the configured thresholds.

Content filtering occurs synchronously as the service processes prompts to generate content. No prompts or generated results are stored in the content classifier models, and prompts and results are not used to train, retrain, or improve the classifier models.

Azure OpenAI abuse monitoring detects and mitigates instances of recurring content and/or behaviors that suggest use of the service in a manner that may violate the Code of Conduct (or other applicable product terms). To detect and mitigate abuse, Azure OpenAI encrypts and stores all prompts and generated content securely for up to thirty (30) days. Microsoft provides a process to request to opt out of abuse monitoring for low risk uses. No prompts or completions are stored if the customer is approved for and elects to configure abuse monitoring off.

The data store where prompts and completions are stored is logically separated by customer resource (each request includes the resource ID of the customer's Azure OpenAI resource). A separate data store is located in each region in which the Azure OpenAI Service is available, and a customer's prompts and generated content are stored in the Azure region where the customer's Azure OpenAI service resource is deployed, within the Azure OpenAI service boundary.

Human reviewers assessing potential abuse, **who may or may not be in the same Azure region as the customer's tenant**, can access prompts and completions data only when that data has been flagged by

the abuse monitoring system. The human reviewers are Microsoft employees who are authorized to access the data via point wise queries using request IDs, Secure Access Workstations, and Just-In-Time request approval granted by team managers. However, If Microsoft approves a customer's request to modify abuse monitoring, then Microsoft does not store any prompts and completions associated with the approved Azure subscription for which abuse monitoring is configured off. In this case, because no prompts and completions are stored at rest in the Service Results Store, the human review process is not possible and is not performed.

## B. Data Elements within Flows

A significant component of a privacy assessment involves the identification of possible (or specific, where known) data elements, and their application to data flows between one place/system/person and another. In providing cloud-based services, Microsoft may hold the types of data described in the following table that can flow from one point to another. The specifics of customer-content data are unknown, but data elements collected by Microsoft for user registration purposes are known.

Microsoft's Data Protection Addendum ("DPA") defines "Personal Data" as:

"any information relating to an identified or identifiable natural person. An identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person."

| Data Category         | Data Elements                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|-----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| User Contact Data     | "User Contact Data" is information to identify and differentiate users of the cloud service. This includes User ID, Organizational ID, and basic user contact information (e.g. phone number or email address). This information is used to by Microsoft staff to troubleshoot service and access issues (e.g. jsmith cannot access file A).                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Customer Content Data | <p>"Customer Data" is defined in the DPA to mean "all data, including all text, sound, video, or image files, and software, that are provided to Microsoft by, or on behalf of, Customer through use of the Online Service. Customer Data does not include Professional Services Data."</p> <p>Customer content consists of data, information, documents, spreadsheets, and other artefacts that are authored, edited, communicated, maintained, and eventually disposed of by the customer. In addition to information input and/or created using Microsoft's "traditional" productivity applications, this also includes prompts (inputs) and results (outputs) created using Azure OpenAI.</p> <p>Specific content will range in type, volume, and sensitivity according to the customer activities in using the Azure OpenAI services.</p> <p>Customer content is not accessible or visible to Microsoft Cloud Services administrators, except in non-routine maintenance situations. In these cases, Microsoft, with explicit consent from the customer, investigates and/or remediates a specific problem with the cloud service in question.</p> |

|                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                 | <p>“Professional Services Data” is defined as “all data, including all text, sound, video, image files or software, that are provided to Microsoft, by or on behalf of a Customer (or that Customer authorizes Microsoft to obtain from a Product) or otherwise obtained or processed by or on behalf of Microsoft through an engagement with Microsoft to obtain Professional Services.”</p> <p>“Professional Services” is defined in the DPA as “the following services: (a) Microsoft’s consulting services, consisting of planning, advice, guidance, data migration, deployment and solution/software development services provided under a Microsoft Enterprise Services Work Order or, when agreed to in the Project Description, under a Cloud Workload Acceleration Agreement that incorporates this DPA by reference; and (b) technical support services provided by Microsoft that help customers identify and resolve issues affecting Products, including technical support provided as part of Microsoft Unified Support or Premier Support Services, and any other commercial technical support services. The Professional Services do not include the Products or, for purposes of the DPA only, Supplemental Professional Services.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Diagnostic Data | <p>“Diagnostic Data” is data collected or obtained by Microsoft in connection with the Online Service. Diagnostic Data may also be referred to as telemetry data. Diagnostic Data does not include Customer Data or Professional Services Data.</p> <p>Diagnostic data is information (specific telemetry data) that Microsoft collects via the inbuilt software customer in Office software and stores for analysis of the usage of the services.<sup>9</sup></p> <p>Microsoft uses such data to provide on Online Services, which consists of</p> <ul style="list-style-type: none"> <li>▪ Delivering functional capabilities as licensed, configured, and used by Customer and its users, including providing personalized user experiences.</li> <li>▪ Troubleshooting (preventing, detecting, and repairing problems).</li> <li>▪ Ongoing improvement (installing the latest updates and making improvements to user productivity, reliability, efficacy, and security).</li> </ul> <p>Microsoft indicates that it also uses such data for legitimate business operations:</p> <ul style="list-style-type: none"> <li>▪ Billing and account management.</li> <li>▪ Compensation (e.g., calculating employee commissions and partner incentives).</li> <li>▪ Internal reporting and modeling (e.g., forecasting, revenue, capacity planning, product strategy).</li> <li>▪ Combatting fraud, cybercrime, or cyber-attacks that may affect Microsoft or Microsoft Products.</li> <li>▪ Improving the core functionality of accessibility, privacy, or energy-efficiency.</li> <li>▪ Financial reporting and compliance with legal obligations (subject to certain limitations on disclosure outlined in the DPA).</li> </ul> |

<sup>9</sup> Further information about required diagnostic data is available at: <https://docs.microsoft.com/en-us/deployoffice/privacy/required-diagnostic-data>. Further information about optional diagnostic data is available at: <https://docs.microsoft.com/en-ca/DeployOffice/privacy/optional-diagnostic-data?toc=/deployoffice/toc.json>.

|  |                                                                                                                                                                                                                                                                                                                                                                                           |
|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <p>Where Microsoft is processing this data for legitimate business operations, Microsoft will process it only for the above purposes.</p> <p>Diagnostic data is stored outside of Canada and is accessible by authenticated administrators both inside and outside of Canada. All service and maintenance data are accessed and contained within Microsoft's global, private network.</p> |
|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

Table 14: Personal Information Data Elements

When providing Online Services, Microsoft indicates that will not use or otherwise process Customer Data or personal data for: (a) user profiling, (b) advertising or similar commercial purposes, or (c) market research aimed at creating new functionalities, services, or products or any other purpose, unless such use or processing is in accordance with a customer's documented instructions. Generally, the uses for which Microsoft uses such data is to provide a customer with the Products and Services and business operations incidental to such provision.

### C. Data Elements Within Microsoft Entra ID

[Annex B](#) contains an extensive list of the attributes that would be "synced" from the on-premises Active Directory to Microsoft Entra ID (formerly known as Azure Active Directory) if used by the customer. These attributes form the Employee Contact Data collected by Microsoft for the provisioning of Azure services, including Azure OpenAI.

At a minimum, the following attributes are required for sync:

- Common name.
- member (applies only to groups).
- samAccountName (applies only to users).
- alias (applies only to groups and contacts).
- displayName (for groups with any mail or proxyAddresses attribute populated).

Most of the attributes described in [Annex B](#) are not considered "personal information" under Canadian data protection laws. However, some elements (e.g. home telephone number), if used, do constitute personal information.

Microsoft indicates that it considers the information in the table is as "business contact information" and, as such, excluded from the scope of the statutes at the federal level (PIPEDA<sup>10</sup> and the Privacy Act<sup>11</sup>) and statutes applicable to "private sector organizations in Alberta<sup>12</sup>, British Columbia<sup>13</sup> and Manitoba<sup>14</sup> as well as laws applicable to public sector organizations in British Columbia<sup>15</sup>, Alberta<sup>16</sup>, Saskatchewan<sup>17</sup> and Ontario<sup>18</sup>. A final determination of whether the data elements held within Entra ID

<sup>10</sup> See *Personal Information Protection and Electronic Documents Act*, SC 2000, c 5, s. 4.01.

<sup>11</sup> See *Privacy Act*, RSC 1985, c P-21 s. 3(f).

<sup>12</sup> See *Personal Information Protection Act*, SA 2003, c P-6.5, s. 1(1)(a).

<sup>13</sup> See *Personal Information Protection Act*, SBC 2003, c 63, s. 1.

<sup>14</sup> See *The Personal Information Protection and Identity Theft Prevention Act*, CCSM c P33.7, s. 1(1) [Not yet in force]

<sup>15</sup> See *Freedom of Information and Protection of Privacy Act*, RSBC 1996, c 165, Sch. 1.

<sup>16</sup> See *Freedom of Information and Protection of Privacy Act*, s.40(1)(bb.1), RSA 2000, c F-25, s. 40(1)(bb.1)

<sup>17</sup> See *Freedom of Information and Protection of Privacy Act*, SS 1990-91, c F-22.01, s. 24(1)(k).

<sup>18</sup> See *Freedom of Information and Protection of Privacy Act*, RSO 1990, c F.31, s. 2(1)(h).

constitutes “personal information” depends on the choices made by the customer for the identification of employees. Customers have full control which attributes are synchronized with Entra ID and may choose to minimize information placed in the directory. It is to be noted that Entra ID does not expose this information publicly, rather it remains accessible only to the authorized user’s community in the same customer tenant.

## D. Data Elements Within Diagnostic Data

Diagnostic data is collected and sent to Microsoft about the use of Azure customer software being used. Some diagnostic data is required, while some diagnostic data is optional. Microsoft gives users the ability to choose whether to send Microsoft required or optional diagnostic data using privacy controls, such as policy settings for organizations. Examples of basic diagnostic information are:

- Problem description, questions, and file attachments.
- Resource health and outage events.
- Resource names and configurations.
- Service advisories related to your resources.
- Resource change history.
- Network topology.

Advanced diagnostic information may also be collected but only with the customer’s consent. Files commonly collected for different services or environments include:

- Microsoft Azure PaaS VM logs.
- Microsoft Azure IaaS VM logs.
- Microsoft Entra logs.

Customers may confirm what diagnostic data is transmitted to Microsoft using the Diagnostic Data Viewer tool.<sup>19</sup> Each data subtype contains a link to Microsoft’s Diagnostic Viewer, which provides further information related to:

- A list of events in that data subtype.
- A description of each event.
- A list of data fields in each event.
- A description of each data field.

---

<sup>19</sup> For further information about this tool, see “Using the Diagnostic Data Viewer with Office”, available at: <https://support.office.com/en-us/article/using-the-diagnostic-data-viewer-with-office-cf761ce9-d805-4c60-a339-4e07f3182855>

## PART 4: PRIVACY ANALYSIS

### A. Introduction

**Framework.** A reasonable framework for a privacy analysis involves consideration of specific legal requirements for the protection of personal information together with a “principles” analysis based on general concepts of privacy. These legal requirements are enacted in legislation and are relevant because an organization that proposes to use Azure OpenAI services may collect personal information from, one or more of jurisdictions, in which such legislation has been enacted.

Personal information protection laws in Canada provide:

- Rules for the collection, use, disclosure, and security of personal information.
- A general right of access to one’s own personal information, subject to specified exceptions.
- A right to request correction or amendment of erroneous personal information.
- A process for the independent review of the decisions of personal information custodians.
- Enforcement mechanisms for contraventions of the legislation.

With respect to legislative requirements, one can identify six types of obligations for public sector institutions and essentially nine for private sector organizations<sup>20</sup>. These categories of rules, and associated exceptions, form the fundamental compliance framework for Canadian institutions or organization.

| Personal Information Protection Requirements |                            |
|----------------------------------------------|----------------------------|
| Public Sector                                | Private Sector             |
| Collection                                   | Accountability             |
| Accuracy                                     | Purpose                    |
| Protection                                   | Consent                    |
| Use                                          | Collection                 |
| Disclosure                                   | Use, Disclosure, Retention |
| Retention                                    | Accuracy                   |
|                                              | Safeguards                 |
|                                              | Access                     |
|                                              | Compliance                 |

Table 15: Personal Information Protection Requirements

This document is intended to serve as a foundational PIA to better inform those who are considering using the Azure OpenAI services or must prepare a PIA. Accordingly, several frameworks are considered in this document:

- For federal public sector organizations:
  - Legislative requirements under the *Privacy Act*<sup>21</sup>.

<sup>20</sup> The federal *Personal Information Protection and Electronic Documents Act*, SC 2000, c 5 has a tenth concept of “openness”.

<sup>21</sup> RSC 1985, c. P-21.

- Guidance issued by the Treasury Board of Canada Secretariat in their *Direction on the Secure Use of Commercial Cloud Services: Security Policy Implementation Notice (SPIN)*<sup>22</sup>.
- Guidance issued by the Treasury Board of Canada Secretariat in their *Guide on the use of generative AI*<sup>23</sup>.
- For provincial public sector organizations in Ontario:
  - Legislative requirements under the *Freedom of Information and Protection of Privacy Act*<sup>24</sup>
- For health sector organizations in Ontario:
  - Legislative requirements under the *Personal Health Information Protection Act, 2004*.<sup>25</sup>

Similarly, since the Office of the Privacy Commissioner of Canada (“OPC”) takes the position that there is a connection between privacy and the *Charter of Rights and Freedoms*<sup>26</sup>, also included is a Charter analysis. This is, in part, because the Supreme Court of Canada has recognized that privacy interests have protection under the Charter and that the *Privacy Act* has quasi-constitutional status.<sup>27</sup>

Finally, for both federal and provincial organizations, data residency requirements in Canada will be examined as well as Privacy Commissioner guidance with respect to the use of service providers.

**Private Sector.** Personal information protection laws governing “private sector” activities have been enacted at the federal and provincial level and generally concern the collection, use and disclosure of personal information by non-public sector organizations in the course of commercial activities. Other than those laws concerning personal health information, Canadian legislation is comprehensive in nature in that they apply to all sectors of activity, subject to constitutional considerations. Four Canadian jurisdictions (Canada, British Columbia, Alberta, and Quebec) have enacted statutes that are in force governing the private sector’s collection, use, storage, and disclosure of personal information.<sup>28</sup> Manitoba has also enacted similar “private sector” legislation but, as of the date of this assessment, it is not yet in force.<sup>29</sup>

## B. Agreements

<sup>22</sup> SPIN is applicable to Government of Canada information that has a security category of Protected B for confidentiality, medium integrity, and medium availability, and applicable to all departments within the meaning of Schedules I, I.1, II, IV and V of the *Financial Administration Act*, RSC., 1985, c. F-11, unless otherwise excluded by specific acts, regulations, or orders-in-council. It is available at: <https://www.canada.ca/en/government/system/digital-government/modern-emerging-technologies/direction-secure-use-commercial-cloud-services-spin.html>

<sup>23</sup> Available at: <https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/responsible-use-ai/guide-use-generative-ai.html>.

<sup>24</sup> RSO. 1990, c F.31

<sup>25</sup> S.O. 2004, c. 3, Sched. A.

<sup>26</sup> See Part 1 of the The Constitution Act, 1982, Schedule B to the Canada Act 1982 (UK), 1982, c 11.

<sup>27</sup> The legal framework for this position can be found in *Dagg v. Canada (Minister of Finance)* [1997] 2 SCR 403; *Canada (Information Commissioner) v. Canada (Commissioner of the Royal Canadian Mounted Police)* [2003] 1 SCR 66; *Lavigne v Canada (Office of the Commissioner of Official Languages)* [2002] 2 SCR 773, and *H.J. Heinz Co. of Canada v. Canada (Attorney General)*[2006] 1 SCR 441.

<sup>28</sup> At the federal level, Part 1 of the *Personal Information Protection and Electronic Documents Act*, SC 2000, c 5. In British Columbia, the *Personal Information Protection Act*, SBC 2003, c 63. In Alberta, the *Personal Information Protection Act*, S. 2003, c P-6.5. In Quebec, *An Act respecting the protection of personal information in the private sector*,<sup>RSQ</sup>, c P-39.1. Québec also has additional provisions related to the protection of personal information in the *Civil Code of Québec*. RSQ 1991, c 64, ss. 35-40.

<sup>29</sup> See *The Personal Information Protection and Identity Theft Prevention Act*, CCSM c P33.7.

The relationship between a cloud service provider and a customer organization<sup>30</sup> is governed by “the agreement(s)” between the two. To meet their accountability obligations under applicable laws and/or government policies, customer organizations must ensure that such agreements have provisions pertaining to the protection of personal information.

**Microsoft Agreements.** With respect to the agreements that govern the use of Microsoft Azure, including Azure OpenAI consideration is to be given to:

**Service Agreement.** The use of the Azure service is governed by the terms and conditions of the agreement under which an organization obtained the services.

- For customers who purchase or renew a subscription (including free trials) online from Microsoft, use is governed by either the Microsoft Customer Agreement ("MCA"), or the Microsoft Online Subscription Agreement ("MOSA")<sup>31</sup>.
- For customers who purchase through another Microsoft Commercial Licensing Program, such as an Enterprise Agreement, use is governed by the licensing agreement under which the services were purchased.

**Product Terms.** The Product Terms details the availability, use terms, and privacy/security commitments for Microsoft Products and Services, including Azure.<sup>32</sup>

With respect to Azure OpenAI, there are service specific terms to note:

*“Limited Access Services*

*Certain Services (or versions thereof) require registration and are subject to limitations on access and use based on Microsoft’s eligibility and use criteria, as updated by Microsoft from time to time (“Limited Access Services”). The following Azure AI Services are Limited Access Services:*

- *Azure AI Speech text to speech custom neural voice*
- *Azure AI Vision Face API*
- *Azure AI Vision celebrity recognition*
- *Azure AI speaker recognition*
- *Azure Video Indexer Applied AI Service*
- *Azure OpenAI Service*
- *Azure OpenAI Service (Modified Content Filtering/Abuse Monitoring)*

*NOTE: In addition to the services listed here, (i) Azure AI Services Previews may be designated, in applicable preview terms, as subject to Limited Access Services terms; and (ii) certain versions of Azure AI Services, such as versions in containers, may be designated, in product documentation or otherwise, as subject to Limited Access Services terms.*

---

<sup>30</sup> In this section of the FPIA, customer or customer organization is referred to as “customer” to be consistent with the terms used in the Microsoft agreements.

<sup>31</sup> The MOSA is available at: <https://azure.microsoft.com/en-us/support/legal/subscription-agreement/>.

<sup>32</sup> The Product Terms are available at: <https://www.microsoft.com/licensing/terms/welcome/welcomepage>.

*Customer may only use Limited Access Services (including when used in a Customer Solution) in accordance with the applicable Product Terms, product documentation, and these Limited Access Services terms; solely for the permitted uses specified in its registration form; and in accordance with any commitments and/or representations made in its Limited Access Services registration form. Customer will provide current, complete, and accurate information in all registration forms and other materials provided to Microsoft pursuant to these Limited Access Service terms. Microsoft may require Customer from time to time to re-verify that all information submitted to Microsoft regarding Customer and Customer's use of the Limited Access Services remains accurate, complete, and up to date, and that Customer is using the Limited Access Services in accordance with the information submitted and these terms. Customer must respond to requests for re-verification from Microsoft within ten (10) business days of receiving a request (requests may be provided via self-certification Azure tools). If Microsoft needs additional information to assure compliance with these terms or eligibility for access to Limited Access Services, Customer will reasonably cooperate with Microsoft to provide such information within thirty (30) business days of request.*

*Microsoft may re-assess Customer's eligibility to access and use Limited Access Services from time to time. If Microsoft determines that Customer no longer meets Microsoft's eligibility and use criteria for a Limited Access Service (or that Customer does not meet eligibility and use criteria for a Service that has become a Limited Access Service), Microsoft will provide Customer with 12 months' notice before discontinuing Customer's access to and use of that Limited Access Service, unless security, legal, or system performance considerations require an expedited discontinuation of access. This does not apply to Previews and does not affect any other rights and remedies available to Microsoft with respect to Customer's use of Services.*

*In addition to Microsoft's right to discontinue access to and use of a Limited Access Service when Customer no longer meets Microsoft's eligibility and use criteria (or Customer does not meet eligibility and use criteria for a Service that has become a Limited Access Service), Microsoft may limit, suspend or terminate Customer's access to a Limited Access Services for non-compliance with any of the terms in this section (including without limitation Customer's use of a Limited Access Service in a manner that is inconsistent with the Customer's Limited Access Service registration form or with requirements in applicable product documentation), without advance notice but only to the extent reasonably necessary under the circumstances.*

#### *Azure OpenAI Service*

*In addition to the Universal Terms for Online Services applicable to Microsoft Generative AI Services and the Limited Access Services terms above, the following terms apply to the use of the Azure OpenAI Service.*

- *Data Use and Access for Abuse Monitoring: Except for the Limited exception below, as part of providing the Azure OpenAI service, Microsoft will temporarily store Inputs and Output Content, solely to monitor for and prevent abusive or harmful uses or outputs of the service. Authorized Microsoft employees may review such data that has triggered our automated systems to investigate and verify potential abuse. For customers who have deployed Azure OpenAI service in the European Economic Area, the authorized Microsoft employees will be located in the European Economic Area. See the Azure*

OpenAI product documentation <https://learn.microsoft.com/azure/ai-services/openai/> for more information.

- *Limited exception. The foregoing Data Use and Access for Abuse Monitoring terms will not apply if and to the extent Customer is approved for and complies with all requirements to use the Azure OpenAI Service with Modified Abuse Monitoring.*
- *Location of Data Processing: Notwithstanding the Location of Data Processing provision in the Universal Terms applicable to Microsoft Generative AI Services, the commitments related to the location of data processing and storage in the Product Terms Privacy & Security Terms for Microsoft Azure Core Services remain in effect for Azure OpenAI Service.*

#### *Azure AI Speech text to speech (TTS) custom neural voice and use of Synthetic Voices*

*Permissions: Customer represents, warrants and certifies that (i) it has explicit written permission from the voice owner(s) contained within its audio files (“Voice Talent”) to use their personal data, including his/her voice likeness to create voice model(s) (“Synthetic Voice(s)”), (ii) Customer’s agreement(s) contemplate the duration of use of the Synthetic Voice and any content limitations and (iii) Customer has shared Microsoft’s disclosure guidance for voice talent (<https://aka.ms/disclosure-voice-talent>) with Voice Talent directly or through Voice Talent’s authorized representative that describes how synthetic voices are developed and operate in conjunction with text to speech services. Microsoft reserves the right to require Customer to provide audio files containing acknowledgements by Voice Talent(s). Customer acknowledges and agrees that Microsoft may use this to perform speaker verification against Customer’s audio training files; however, Microsoft’s retention of audio files does not create or imply an obligation that Microsoft will perform speaker verification.*

*Permitted uses: In addition to compliance with the Acceptable Use Policy, the code of conduct (available at <https://aka.ms/custom-neural-code-of-conduct>) sets the minimum requirements that all TTS implementations must adhere to in good faith. Customer shall have the exclusive right to use the Synthetic Voice(s) created by Customer and made available through use of the Services. Notwithstanding the foregoing or anything to the contrary in the DPA, Customer acknowledges and agrees that Microsoft may retain a copy of each Synthetic Voice created by Customer and may, but is not obligated to, use the Synthetic Voice(s) to investigate and respond to any alleged violations of the service terms. Customer agrees and grants Microsoft a limited nonexclusive irrevocable worldwide license to retain acknowledgment audio voice consent file(s) and a copy of the Synthetic Voice(s) for the limited purposes above. Customer is required to secure and maintain all rights necessary for Microsoft to retain and use the acknowledgment audio files and Synthetic Voice(s) as described in this section without violating the rights of Voice Talent(s) or any other third party or otherwise obligating Microsoft to Customer, Voice Talent or any other third party. This paragraph will survive termination or expiration of Customer’s agreement.*

**Privacy Statement.** The Microsoft Privacy Statement<sup>33</sup> explains the personal data Microsoft processes, how Microsoft processes it, and for what purposes. For the purposes of the Privacy Statement, Azure OpenAI is characterized as “core service”. This is relevant because the applicable Services Agreement or

---

<sup>33</sup> Available at: <https://privacy.microsoft.com/en-ca/privacystatement>.

the Preview Supplemental Terms (see below) may specify lesser or different privacy measures for some Preview services.

**Data Protection Addendum.** The Microsoft Products and Services Data Protection Addendum<sup>34</sup> (“DPA”) sets forth the obligations of both the customer and Microsoft with respect to the processing and security of Customer Data and Personal Data in connection with Azure. The Privacy and Security Terms section of the Product Terms site further sets forth exclusions from the DPA as well as additional commitments for Core Online Services and EU Data Boundary Services.

The DPA, which applies to Azure OpenAI, outlines each party’s obligations with respect to the processing and security of “Customer Data”, “Professional Services Data”, and “Personal Data” by the Products. In the event of any conflict or inconsistency between the DPA and any other terms in Customer’s licensing agreement, the DPA shall prevail. Relevant sections of the DPA are referred to in the course of the Privacy Analysis that follows in this Part.

**Service Level Agreements.** The Service Level Agreements<sup>35</sup> describe commitments around uptime and connectivity for Azure.

**Preview Supplemental Terms.** The Preview Supplemental Terms<sup>36</sup> include additional legal terms that apply to the use of Azure features that are in “beta”, preview, or otherwise not yet released into general availability. These terms supplement terms and exclusions applicable to “Previews” as indicated in a Service Agreement, the Product Terms and the DPA.

**Requirements.** Given personal information protection obligations, what should customers look for in a service agreement? While acknowledging that different jurisdictions may have specific contractual requirements, a useful guide to requirements – whether public or private sector customers is a special investigation report, “*Reviewing the Licensing Automation System of the Ministry of Natural Resources*”<sup>37</sup> issued by the Office of the Information and Privacy Commissioner of Ontario (“IPC”). This special report considered the use of service providers and was prepared in response to a complaint about the Ministry outsourcing the issuance of hunting and fishing licenses to an American company and the associated consequence of personal information being in the United States.

The IPC considered that outsourcing was not problematic if reasonable contractual measures were taken to protect the data. In the of the Ministry of Natural Resources (“MNR”), the IPC noted provisions in the agreement between the MNR and the service provider/agent for:

- *Ownership* – Under the agreement, the Ministry confirmed that it is to be considered as the owner of all data provided by MNR to the service provider.
- *Collection, Use and Disclosure* – Pursuant to the contract, the Agent was prohibited from directly or indirectly using, collecting, or disclosing any personal information for any purposes not authorized by the Ministry.

---

<sup>34</sup> Available at: <https://www.microsoft.com/licensing/docs/view/Microsoft-Products-and-Services-Data-Protection-Addendum-DPA>. The Microsoft Trust Center provides more information on security, privacy, and compliance topics for customers of Azure and other Microsoft Online Services. The Service Trust Portal is a companion feature to the Trust Center that provides access to audit reports, GDPR documentation, compliance guides, and related documents.

<sup>35</sup> Available at: <https://www.microsoft.com/licensing/docs/view/Service-Level-Agreements-SLA-for-Online-Services?lang=1>.

<sup>36</sup> Available at: <https://azure.microsoft.com/en-us/support/legal/preview-supplemental-terms/>.

<sup>37</sup> PC12-39 available at [https://www.ipc.on.ca/images/Findings/2012-06-28-MNR\\_report.pdf](https://www.ipc.on.ca/images/Findings/2012-06-28-MNR_report.pdf).

- *Confidential Information* – Specific contractual obligations were imposed on the Agent. These obligations required the Agent to:
  - Keep the information confidential and secure.
  - Limit the disclosure of confidential information to only those who have a “need to know”.
  - Not to directly or indirectly disclose, destroy, exploit, or use any confidential information (except for the purpose of the contract, or except if required by order of a court or tribunal), without the written consent of the Ministry.
- *Notice of Compelled Disclosure* – If legally compelled to disclose any of the Ministry’s confidential information, the Agent was required to provide the MNR with prompt notice to allow it to seek a protective order or other appropriate remedy to prevent or limit such disclosure.
- *Subcontracting* – The Agent was prohibited from subcontracting all or any part of the contract without the prior written consent of the Ministry.
- *Security* – The Agent was required to:
  - Ensure the security and integrity of all personal information and records in its possession.
  - Implement, use, and maintain the most appropriate products, tools, measures, and procedures to do so.
- *Retention and Destruction* – The Agent was contractually required to return all confidential information to the Ministry before the end of the term of the contract, with no copy or portion kept by the Agent.
- *Audits* – During the life of the contract, the Agent was required to comply with annual audits for privacy and security compliance.
- *Governing law* – The governing law of the contract was required to be that of Ontario and the federal laws of Canada.

The IPC has also issued guidance to Ontario public sector entities entitled “*Thinking About Clouds? Privacy, security and compliance considerations for Ontario public sector institutions*”.<sup>38</sup> This document, in discussing required contractual terms, relies extensively on the MNR Report and states:

*“Contract provisions are critical for ensuring the cloud service provider’s compliance with an institution’s privacy, security and access obligations. Contracts should have provisions that address:*

- *Information ownership.*
- *Limits on information collection, use and disclosure.*
- *Limits on the jurisdictions in which the information may be stored.*
- *Treatment of confidential information (including personal information).*
- *Employee awareness and training.*
- *Limits on subcontracting.*
- *Security management including logging and auditing.*
- *Breach incident response, management and notification.*
- *Information retention and destruction.*
- *Periodic vulnerability assessments.*

---

<sup>38</sup> Available at: <https://www.ipc.on.ca/wp-content/uploads/2016/08/thinking-about-clouds-1.pdf>.

- *The availability of audit results.*
- *Governing law and jurisdiction.*
- *Enforceable remedies for non-compliance.*

*Contractual terms should include specific measurable criteria for judging whether privacy and security standards are being met. Industry standards, corporate guidelines or any other information management obligations should be reflected in contracts and SLAs to ensure that cloud providers adhere to business requirements. Cloud services should be regularly monitored and evaluated to determine whether they should be continued. Cloud service providers should also be able to supply the appropriate documentation to validate that their infrastructure and service models meet your institution's requirements."*

Almost all of these aforementioned requirements can be seen in Microsoft's agreement framework.

With respect to the use of Azure OpenAI, there are two distinct and different aspects to note. The first is, in keeping with its Responsible AI undertakings, Microsoft both logs and, if necessary, flags for review outputs. The second is that users now must abide by a Code of Conduct.

In terms of *notice of compelled disclosure*, Microsoft contractually agrees to provide such notice if not prevented by law from doing so. For *retention and destruction*, Microsoft's position is that – to use a small metaphor – Microsoft provides an “envelope” in which the customer controls retention. The customer adheres to its own retention schedules for all data within that envelope. What Microsoft contractually commits to is the secure destruction of data within the envelope after the Azure service has been terminated. There is no “return” of data. If a customer wants the “return” of data, or a copy of its data, it should download such information prior to service termination.

**Azure OpenAI.** Insofar as Azure OpenAI is an Azure service offering, any examination of Microsoft's obligations starts with the Azure terms and conditions. These “T&Cs” comprise of a series of agreements and understanding which agreement applies and how they interrelate can be challenging – especially for non-lawyers - in the context of conducting a privacy impact assessment. This section is intended to explain what applies and how they relate.

The logging of outputs and adherence to the Code of Conduct are brought the attention of users when attempting to register for the Azure OpenAI service<sup>39</sup>:

---

<sup>39</sup> To register to use Azure OpenAI, see [https://customervoice.microsoft.com/Pages/ResponsePage.aspx?id=v4j5cvGGr0GRqy180BHbR7en2Ais5pxKtso\\_Pz4b1\\_xUNTZBNzRKNIVQSFhZMU9aV09EVzYxWfDORCQIQCN0PWcu.](https://customervoice.microsoft.com/Pages/ResponsePage.aspx?id=v4j5cvGGr0GRqy180BHbR7en2Ais5pxKtso_Pz4b1_xUNTZBNzRKNIVQSFhZMU9aV09EVzYxWfDORCQIQCN0PWcu.)

18

The Azure OpenAI Service is subject to the applicable [Azure Legal Terms](#) (including relevant Product Terms), and preview features are also subject to the [Supplemental Terms of Use for Microsoft Azure Previews](#).

As provided in the Product Terms, your use of the Azure OpenAI Service must comply with the requirements in the [product documentation](#), including the [Code of Conduct for the Azure OpenAI Service](#). \*

☐ I acknowledge that these terms apply to use of the Azure OpenAI Service

19

Please check the box below to attest that you have read the [Data Processing details](#) for the Azure OpenAI service, and you understand and acknowledge that, in order to detect and mitigate harmful use of the Azure OpenAI Service, Microsoft logs the content you send to the Completions and image generations APIs as well as the content it sends back. If content is flagged by the Azure OpenAI service's content filters, the content may be reviewed by an authorized Microsoft full-time employee for purposes of (1) debugging in the event of a failure, (2) investigating patterns of abuse and misuse. \*

☐ Yes, I attest (except if and to the extent I am approved for and configure my application for modified content filtering and/or abuse detection)

Image 8: Azure Open AI Terms (I)

Also present in the General Service Terms is the following:

### Azure AI Content Safety

#### Acceptable Use

Azure AI Content Safety can apply tags to text, image, and certain multi-modal content enabling customers to filter and remove harmful content. Transmitting harmful content to Azure AI Content Safety through the intended use of the service will not by itself be considered a violation of the Acceptable Use Policy, which otherwise applies. Customer agrees to use the system only to filter out and not to collect harmful content.

#### Sample Content

If Customer chooses to provide Microsoft with examples of Customer content ("Sample Content") to help Microsoft tailor the service to Customer's requirements as described in the service documentation, Customer agrees (a) that Microsoft will review and use it in accordance with that documentation, and (b) that Customer will abide by any requirements in that documentation, including the requirement not to include personal, confidential, or commercially sensitive information in Sample Content.

Image 9: Azure OpenAI Terms (II)

When a customer renews or purchases a new subscription to a Product or enters into a work order for a Professional Service, the then-current DPA Terms will apply and will not change during customer's subscription for that Product or term for that Professional Service. When a customer obtains a perpetual license to Software, the then-current DPA Terms will apply (following the same provision for determining the applicable then-current Product Terms for that Software in customer's volume licensing) and will not change during Customer's license for that Software.

**Compliance with Laws.** Microsoft states that it will comply with all laws and regulations applicable to its provision of the Online Services and that are applicable to information technology service providers, including security breach notification law. Microsoft further indicates that is not responsible for

compliance with any laws or regulations applicable to customer or customer's industry that are not generally applicable to information technology service providers.

Conversely, customers are required to comply with all laws and regulations applicable to its use of Online Services, including laws related to privacy, data protection and confidentiality of communications. **Customers are responsible for implementing and maintaining privacy protections and security measures for components that Customer provides or controls**, and for determining whether the Online Services are appropriate for storage and processing of information subject to any specific law or regulation. Customers is also responsible for responding to any request from a third-party regarding Customer's use of an Online Service, such as a request to take down content under applicable intellectual property laws.

**Microsoft DPA: Security Provisions.** One aspect to take particular note of is Appendix A of the DPA contains a table of security provisions put in place by Microsoft. Microsoft expressly states:

*"Microsoft has implemented and will maintain for Customer Data in the Core Online Services the following security measures, which in conjunction with the security commitments in this DPA (including the GDPR Terms), are Microsoft's only responsibility with respect to the security of that data."*

The following table outlines relevant security measures:

| Domain                               | Practices                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|--------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Organization of Information Security | <p><b>Security Ownership.</b> Microsoft has appointed one or more security officers responsible for coordinating and monitoring the security rules and procedures.</p> <p><b>Security Roles and Responsibilities.</b> Microsoft personnel with access to Customer Data or Professional Services Data are subject to confidentiality obligations.</p> <p><b>Risk Management Program.</b> Microsoft performed a risk assessment before processing the Customer Data or launching the Online Services service and before processing Professional Service Data or launching the Professional Services.</p> <p>Microsoft retains its security documents pursuant to its retention requirements after they are no longer in effect.</p>                                                                                                                                                                                                 |
| Asset Management                     | <p><b>Asset Inventory.</b> Microsoft maintains an inventory of all media on which Customer Data or Professional Services Data is stored. Access to the inventories of such media is restricted to Microsoft personnel authorized in writing to have such access.</p> <p><b>Asset Handling</b></p> <ul style="list-style-type: none"><li>- Microsoft classifies Customer Data and Professional Services Data to help identify it and to allow for access to it to be appropriately restricted.</li><li>- Microsoft imposes restrictions on printing Customer Data and Professional Services Data and has procedures for disposing of printed materials that contain such data.</li><li>- Microsoft personnel must obtain Microsoft authorization prior to storing Customer Data or Professional Services Data on portable devices, remotely accessing such data, or processing such data outside Microsoft's facilities.</li></ul> |

| Domain                                   | Practices                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Human Resources Security                 | <p><b>Security Training.</b> Microsoft informs its personnel about relevant security procedures and their respective roles. Microsoft also informs its personnel of possible consequences of breaching the security rules and procedures. Microsoft will only use anonymous data in training.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Physical and Environmental Security      | <p><b>Physical Access to Facilities.</b> Microsoft limits access to facilities where information systems that process Customer Data or Professional Services Data are located to identified authorized individuals.</p> <p><b>Physical Access to Components.</b> Microsoft maintains records of the incoming and outgoing media containing Customer Data or Professional Services Data, including the kind of media, the authorized sender/recipients, date and time, the number of media and the types of such data they contain.</p> <p><b>Protection from Disruptions.</b> Microsoft uses a variety of industry standard systems to protect against loss of data due to power supply failure or line interference.</p> <p><b>Component Disposal.</b> Microsoft uses industry standard processes to delete Customer Data and Professional Services Data when it is no longer needed.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Communications and Operations Management | <p><b>Operational Policy.</b> Microsoft maintains security documents describing its security measures and the relevant procedures and responsibilities of its personnel who have access to Customer Data or Professional Services Data.</p> <p><b>Data Recovery Procedures</b></p> <ul style="list-style-type: none"> <li>- On an ongoing basis, but in no case less frequently than once a week (unless no updates have occurred during that period), Microsoft maintains multiple copies of Customer Data and Professional Services Data from which such data can be recovered.</li> <li>- Microsoft stores copies of Customer Data and Professional Services Data and data recovery procedures in a different place from where the primary computer equipment processing the Customer Data and Professional Services Data are located.</li> <li>- Microsoft has specific procedures in place governing access to copies of Customer Data and Professional Services Data.</li> <li>- Microsoft reviews data recovery procedures at least every six months, except for data recovery procedures for Professional Services and for Azure Government Services, which are reviewed every twelve months.</li> <li>- Microsoft logs data restoration efforts, including the person responsible, the description of the restored data and where applicable, the person responsible and which data (if any) had to be input manually in the data recovery process.</li> </ul> <p><b>Malicious Software.</b> Microsoft has anti-malware controls to help avoid malicious software gaining unauthorized access to Customer Data and Professional Services Data, including malicious software originating from public networks.</p> <p><b>Data Beyond Boundaries</b></p> <ul style="list-style-type: none"> <li>- Microsoft encrypts, or enables Customer to encrypt, Customer Data and Professional Services Data that is transmitted over public networks.</li> </ul> |

| Domain         | Practices                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                | <ul style="list-style-type: none"> <li>- Microsoft restricts access to Customer Data and Professional Services Data in media leaving its facilities.</li> </ul> <p><b>Event Logging.</b> Microsoft logs, or enables Customer to log, access and use of information systems containing Customer Data or Professional Services Data, registering the access ID, time, authorization granted or denied, and relevant activity.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Access Control | <p><b>Access Policy.</b> Microsoft maintains a record of security privileges of individuals having access to Customer Data or Professional Services Data.</p> <p><b>Access Authorization</b></p> <ul style="list-style-type: none"> <li>- Microsoft maintains and updates a record of personnel authorized to access Microsoft systems that contain Customer Data or Professional Services Data.</li> <li>- Microsoft deactivates authentication credentials that have not been used for a period of time not to exceed six months.</li> <li>- Microsoft identifies those personnel who may grant, alter, or cancel authorized access to data and resources.</li> <li>- Microsoft ensures that where more than one individual has access to systems containing Customer Data or Professional Services Data, the individuals have separate identifiers/log-ins.</li> </ul> <p><b>Least Privilege</b></p> <ul style="list-style-type: none"> <li>- Technical support personnel are only permitted to have access to Customer Data and Professional Services Data when needed.</li> <li>- Microsoft restricts access to Customer Data and Professional Services Data to only those individuals who require such access to perform their job function.</li> </ul> <p><b>Integrity and Confidentiality</b></p> <ul style="list-style-type: none"> <li>- Microsoft instructs Microsoft personnel to disable administrative sessions when leaving premises Microsoft controls or when computers are otherwise left unattended.</li> <li>- Microsoft stores passwords in a way that makes them unintelligible while they are in force.</li> </ul> <p><b>Authentication</b></p> <ul style="list-style-type: none"> <li>- Microsoft uses industry standard practices to identify and authenticate users who attempt to access information systems.</li> <li>- Where authentication mechanisms are based on passwords, Microsoft requires that the passwords are renewed regularly.</li> <li>- Where authentication mechanisms are based on passwords, Microsoft requires the password to be at least eight characters long.</li> <li>- Microsoft ensures that de-activated or expired identifiers are not granted to other individuals.</li> <li>- Microsoft monitors, or enables Customer to monitor, repeated attempts to gain access to the information system using an invalid password.</li> </ul> |

| Domain                                   | Practices                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                          | <ul style="list-style-type: none"> <li>- Microsoft maintains industry standard procedures to deactivate passwords that have been corrupted or inadvertently disclosed.</li> <li>- Microsoft uses industry standard password protection practices, including practices designed to maintain the confidentiality and integrity of passwords when they are assigned and distributed, and during storage.</li> </ul> <p><b>Network Design.</b> Microsoft has controls to avoid individuals assuming access rights they have not been assigned to gain access to Customer Data or Professional Services Data they are not authorized to access.</p>                                                                                                                                                                                                                                                                           |
| Information Security Incident Management | <p><b>Incident Response Process</b></p> <ul style="list-style-type: none"> <li>- Microsoft maintains a record of security breaches with a description of the breach, the time period, the consequences of the breach, the name of the reporter, and to whom the breach was reported, and the procedure for recovering data.</li> <li>- For each security breach that is a Security Incident, notification by Microsoft (as described in the “Security Incident Notification” section above) will be made without undue delay and, in any event, within 72 hours.</li> <li>- Microsoft tracks, or enables Customer to track, disclosures of Customer Data and Professional Services Data, including what data has been disclosed, to whom, and at what time.</li> </ul> <p><b>Service Monitoring.</b> Microsoft security personnel verify logs at least every six months to propose remediation efforts if necessary.</p> |
| Business Continuity Management           | <ul style="list-style-type: none"> <li>- Microsoft maintains emergency and contingency plans for the facilities in which Microsoft information systems that process Customer Data or Professional Services Data are located.</li> <li>- Microsoft’s redundant storage and its procedures for recovering data are designed to attempt to reconstruct Customer Data and Professional Services Data in its original or last-replicated state from before the time it was lost or destroyed.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                      |

**Table 16: Microsoft Terms Concerning Security Measures**

**Security Incident Notification.** The DPA contains an express provision concerning security incident notification.

***“Security Incident Notification***

*If Microsoft becomes aware of a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to Customer Data, Professional Services Data, or Personal Data while processed by Microsoft (each a “Security Incident”), Microsoft will promptly and without undue delay (1) notify Customer of the Security Incident; (2) investigate the Security Incident and provide Customer with detailed information about the Security Incident; (3) take reasonable steps to mitigate the effects and to minimize any damage resulting from the Security Incident.*

*Notification(s) of Security Incidents will be delivered to Customer by any means Microsoft selects, including via email. It is Customer’s sole responsibility to ensure Customer maintains accurate contact information with Microsoft for each applicable Product and Professional Service.*

*Customer is solely responsible for complying with its obligations under incident notification laws applicable to Customer and fulfilling any third-party notification obligations related to any Security Incident.*

*Microsoft shall make reasonable efforts to assist Customer in fulfilling Customer's obligation under GDPR Article 33 or other applicable law or regulation to notify the relevant supervisory authority and data subjects about such Security Incident.*

*Microsoft's notification of or response to a Security Incident under this section is not an acknowledgement by Microsoft of any fault or liability with respect to the Security Incident.*

*Customer must notify Microsoft promptly about any possible misuse of its accounts or authentication credentials or any security incident related to the Products and Services."*

While not a contractual obligation, Microsoft has also adopted a policy to notify customers if they believe that a customer account has been targeted or compromised by an individual or group working on behalf of a nation state. This policy has been adopted because a "state-sponsored" attack could be more sophisticated or more sustained than attacks from cybercriminals and others.

These notifications do not mean that Microsoft's own systems have been compromised. If customers receive such a notification, this means that there is evidence the customer account has been targeted. This will allow customers to take additional measures to keep their account secure.

**Customer Obligations.** Customers are to comply with all laws and regulations applicable to their use of Products and Services, including laws related to biometric data, confidentiality of communications, and data protection requirements. Customers are responsible for determining whether the Products and Services are appropriate for storage and processing of information subject to any specific law or regulation and for using the Products and Services in a manner consistent with a customer's legal and regulatory obligations.

## C. Data Residency

### C1. Legislative/Policy Requirements

**Introduction.** Potential customers seeking to deploy Azure OpenAI invariably will ask Microsoft, as a service provider to Canadian organizations, about third party access to the data of those organizations for law enforcement and national security purposes. These public, private and health sector provisions concerning security, storage, or access from outside Canada are discussed below.

**British Columbia.** In November 2021, the Province of British Columbia enacted amendments to the province's Freedom of Information and Protection of Privacy Act<sup>40</sup> ("FOIPPA"). The 2021 amendments included changes to remove restrictions that prevented public bodies from storing information outside of Canada. FOIPPA's data-residency provisions, had previously required personal information to be stored and accessed in Canada, except under limited circumstances.

---

<sup>40</sup> RSBC 1996, c 165

With these changes, public bodies in British Columbia must complete an assessment when sensitive personal information is disclosed to be stored outside of Canada<sup>41</sup>. The level of sensitivity will depend on the type of personal information involved, the context and how it is handled. Sensitive personal information is not defined in FOIPPA, but provincial guidance indicates that such information includes, but is not limited to:

- Personal health information.
- Genetic and biometric data.
- Personal financial information.
- Geolocation data.
- Criminal records.
- Racial or ethnic origin.
- Sexual orientation.
- Religious, philosophical, or political beliefs.

Information not normally considered sensitive may be found to be sensitive, depending on the factual context.

The result of this assessment will be a risk-based decision made by the head of the public body on whether to proceed with the project, taking the following into account:

- Privacy risks.
- Level of privacy risk.
- Risk responses (e.g., mitigations to the privacy risks).
- Any residual/outstanding risks.

The analysis is intended to document the public body's reasoning for accepting the privacy risks in their project, program or system that proposes to store sensitive personal information outside of Canada.

**Alberta.** Alberta amended its Freedom of Information and Protection of Privacy Act<sup>42</sup>, to restrict out-of-country disclosures in two ways. First, disclosure by public bodies is permitted only “for the purpose of complying with a subpoena, warrant or order issued or made by a court, person or body having jurisdiction in Alberta to compel the production of information or with a rule of court binding in Alberta that relates to the production of information”. Second, it was made an offence for a person to “willfully disclose personal information pursuant to a subpoena, warrant or order issued or made by a court, person or body having no jurisdiction in Alberta to compel the production of information or pursuant to a rule of court that is not binding in Alberta.”

Alberta amended its *Health Information Act*<sup>43</sup> in 2006 by inserting three specific provisions<sup>44</sup> to:

---

<sup>41</sup> An assessment is not required if FOIPPA section 33(2)(f) applies. This section authorizes a public body to disclose personal information if the information is made available to the public under an enactment that authorizes or requires the information to be made public.

<sup>42</sup> RSA 2000, c F-25.

<sup>43</sup> RSA 2000, c H-5

<sup>44</sup> See *Health Information Amendment Act, 2006*, SA 2006, c. 18.

- Prohibit compelling a witness to testify or compelling the production of documents except only in response to the direction of a court or tribunal in Canada,
- Require that health information can only be disclosed under an order, warrant or subpoena issued by a court person or body that has jurisdiction in Alberta, and
- Increase the penalties for acting in contravention of the new provisions.

Alberta's *Personal Information Protection Act*<sup>45</sup> was amended in 2009<sup>46</sup> to require an organization - using a service provider outside Canada to collect, use, disclose or store personal information for or on its behalf - to publish, in its policy or practice statement, information as to which countries outside Canada this activity occurs and what purposes the service provider is allowed to use the information.<sup>47</sup>

Notice must be made before or at the time of collection or transfer, in writing or orally, and indicate how an individual may obtain access to written information about the organization's policies and practices with respect to service providers outside Canada and who within the organization can answer questions about the service provider's activities.<sup>48</sup> This requirements concern only those situations where the subject individual has provided consent for the initial collection and use of his or her personal information.

**Manitoba.** Manitoba's *Personal Health Information Act*<sup>49</sup> authorizes the Lieutenant Governor-in-Council to make regulations governing the disclosure of personal health information to persons or bodies outside Manitoba. As of the writing of this assessment, no specific regulations have been promulgated and the *Personal Health Information Regulation*<sup>50</sup> contains no provisions concerning the subject of cross-border or cross-boundary transfers or disclosures.

Manitoba's *Personal Information Protection and Identity Theft Prevention Act*<sup>51</sup> does not contain any provisions concerning data residency.

**Ontario.** Ontario has no general personal information protection law (See [Canada](#) section below).

Ontario's *Personal Health Information Protection Act*<sup>52</sup> ("PHIPA") prohibits of "disclosures" outside of the province unless under certain circumstances. These circumstances are:

- (a) The subject of the information consents to the disclosure.
- (b) The disclosure is permitted by the PHIPA or the regulations under that statute.
- (c) The recipient performs functions similar to the functions performed by a person within the province to whom this disclosure is permitted under subsection 40(2) of PHIPA.
- (d) The following conditions are met:
  - (i) the disclosure is for the purpose of health planning or health administration.
  - (ii) the information relates to health care provided in the province to a person who is a resident of another province or territory of Canada

---

<sup>45</sup> SA 2003 c P-6.5.

<sup>46</sup> See *Personal Information Protection Amendment Act, 2009*, S.A., 2009 c. 50.

<sup>47</sup> S. 6(2).

<sup>48</sup> S. 13.1.

<sup>49</sup> CCSM c P33.5, s. 66(1)(l).

<sup>50</sup> Man Reg 245/97.

<sup>51</sup> CCSM c P33.7. Not in force at the time of this assessment.

<sup>52</sup> SO 2004, c 3, Sch A.

- (iii) the disclosure is made to the government of that other province or territory of Canada.
- (e) The disclosure is reasonably necessary for the provision of health care to the individual and the individual has not expressly instructed the custodian not to make the disclosure in its entirety. or
- (f) The disclosure is reasonably necessary for the payment for the provision of health care to the individual.

Where a custodian discloses personal health information for healthcare purposes and the subject individual has instructed that not all the personal health information be disclosed, the recipient of the limited personal health information is to be apprised of the existence of the instruction and the limited disclosure.<sup>53</sup>

The IPC special investigation report, *“Reviewing the Licensing Automation System of the Ministry of Natural Resources”* is discussed below (See Guidance on the Use of Cloud Computing). The report concerned personal information being stored in the United States. The IPC considered that the storage of personal information outside Canada was permissible provided that reasonable contractual measures were taken to protect the data.

**Québec.** A private sector organization must inform individuals, from whom personal information has been collected, of the possibility that this information may be disclosed outside Québec. This notice must be provided at the time of collection and upon request<sup>54</sup>

An organization is required to conduct an assessment if it (i) wants to transfer personal information outside Québec or (ii) uses a third party located outside Québec to collect, use, disclose or retain personal information on its behalf. The assessment is to consider:

- The sensitivity of the personal information in question.
- The purposes for which such information will be used.
- The safeguards, including contractual safeguards, to be applied.
- The legal regime applicable in the receiving jurisdiction, including the privacy “principles” applicable there.

The personal information may be communicated outside of Québec if the assessment determines that said information would receive adequate protection. In connection with any such transfer, the organization must enter into a written agreement with the third party that considers the results of the assessment and any terms and conditions to mitigate the risks identified in the assessment<sup>55</sup>.

If it is determined that information processed by a non-Canadian service provider will be sufficiently protected with a contract that incorporates the requirements of section 18.3 of the Act, no further action will be necessary. If this is not the case, then the parties are required to agree on measures to reduce that risk.

---

<sup>53</sup> See PHIPA, s. 50(2).

<sup>54</sup> Act respecting the protection of personal information in the private sector, CQLR c P-39.1, s 8, para 2.

<sup>55</sup> Act respecting the protection of personal information in the private sector, CQLR c P-39.1, s 17, para 2.

Québec's public sector legislation, *An Act Respecting Access To Documents Held By Public Bodies And The Protection Of Personal Information*<sup>56</sup>, contains a similar provision to that found in the Private Sector Law.

**New Brunswick.** The Province of New Brunswick has no general personal information protection law (See [Canada](#) section below).

Under New Brunswick's *Personal Health Information Privacy and Access Act*<sup>57</sup> and unless otherwise indicated in the legislation, express consent of an individual is required in relation to the collection, use or disclosure of his or her personal health information by a custodian, including when the custodian discloses information to a person outside New Brunswick.

Information managers providing a public body with information management or information technology services may store personal health information in their custody or in their control outside Canada.<sup>58</sup>

**Nova Scotia.** The Province of Nova Scotia has no general personal information protection law applicable to the private sector (See [Canada](#) section below).

Nova Scotia enacted the *Personal Information International Disclosure Protection Act*<sup>59</sup> ("PIIDPA") in 2006. PIIDPA applies to a broadly stated range of public sector organizations, defined to be any government department, (or government-appointed agency, board, or commission), school board, university, community college, district health authority, or children's aid society. It also applies to the directors, officers and employees of public bodies and all employees and associates of service providers.

Substantively, PIIDPA contains a number of exceptions to the prohibition of disclosure of personal information outside Canada (e.g. the head of the public body determines that it "meets the necessary requirements" of the organization's operation; if there is a law enforcement agreement or treaty in effect; to collect a debt; where the health or safety of individuals need to be protected, or for research purposes as outlined in the legislation).

Section 44 of Nova Scotia's *Personal Health Information Act*<sup>60</sup> also qualifies the ability of custodians to transfer personal health information. The requirements for any transfer are identical to those found in Ontario's PHIPA.

**Newfoundland and Labrador.** The Province of Newfoundland and Labrador has no general personal information protection law applicable to the private sector (See [Canada](#) section below).

Newfoundland and Labrador's *Personal Health Information Act*<sup>61</sup> requires a custodian to ensure compliance with the Act with respect to storage, transfer, copying, modification, use and disposition of personal information whether within or outside the province. Section 13(2) of the statute specifically imposes an obligation to protect the confidentiality of personal health information stored, used, or disclosed outside the province and the privacy of the subject individual. The disclosure of personal

---

<sup>56</sup> RSQ, c A-2.1. See s. 70.1.

<sup>57</sup> SNB 2009, c P-7.05, s. 19.

<sup>58</sup> General Regulation, NB Reg 2010-112, s 22.

<sup>59</sup> SNS 2006, c. 3.

<sup>60</sup> SNS 2010, c 41.

<sup>61</sup> SNL 2008, c P-7.01.

health information to a person outside the province is expressly prohibited unless specific requirements are met.<sup>62</sup> These requirements are identical to those found in Ontario's PHIPA<sup>63</sup>.

**Canada.** The federal *Privacy Act*<sup>64</sup> applies to federal institutions listed in a schedule to the Act. The statute does not contain any data residency provisions.

The *Personal Information Protection and Electronic Documents Act*<sup>65</sup> ("PIPEDA") applies to the "federal private sector" (i.e. works, understandings or businesses) as well as other private sector entities engaged in commercial activities but only in jurisdictions in Canada that do not have legislation that has been designated "substantially similar".

Substantially similar legislation has been enacted (and recognized as such by the federal government) in British Columbia, Alberta, and Quebec, as have personal health information protection statutes in Ontario, New Brunswick, and Newfoundland & Labrador. PIPEDA does not contain any data residency provisions.

However, Schedule 1 of PIPEDA and, in particular, Principle 4.1.3 provides:

*"An organization is responsible for personal information in its possession or custody, including information that has been transferred to a third party for processing. The organization shall use contractual or other means to provide a comparable level of protection while the information is being processed by a third party."*

In considering the interpretation and application of Principle 4.1.3 in the context of cross-border data flows, the Office of the Privacy Commissioner of Canada ("OPC") has issued three findings. While not binding precedents, they nonetheless reflect the Office's views on the subject and serve as useful illustrations.

Case 2005-313<sup>66</sup> concerned a bank sending a notification to its VISA customers amending the credit cardholder agreement. The notification referred to the use of a service provider located in the United States and the possibility that American law enforcement or regulatory agencies being able to obtain access to cardholders' personal information under U.S. law.

The OPC determined that PIPEDA does not prohibit the use of foreign-based third-party service providers and the bank, in keeping with its obligations under Principle 4.1.3, had imposed contractual requirements concerning confidentiality and security with its third-party service providers. Any transfer to a service provider is a management exercise requiring an assessment of security risks. The Privacy Commissioner's finding noted that the personal information of Canadians in the possession of a service provider outside of Canada is subject to the laws of the country in which it is located.

The Privacy Commissioner's position was that transparency was required: any organization having personal information processed outside of Canada should notify its customers that the information may

---

<sup>62</sup> SNL 2008, c P-7.01, s. 47(1).

<sup>63</sup> SNL 2008, c P-7.01, s. 47(2).

<sup>64</sup> RSC 1985, c P-21.

<sup>65</sup> SC 2000, c 5.

<sup>66</sup> Available at: <https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2005/pipeda-2005-313/>.

be available to government authorities under a lawful order made in that country. Because the bank in question provided such notification, indicating to customers that their personal information might be accessed under the provisions of applicable legislation while in the possession of a U.S.-based service provider, the bank was in compliance with PIPEDA.

Finding 2006-333<sup>67</sup> involved a security system provider, a Canadian subsidiary of a U.S. company, which had advised its Canadian customers that it intended to share customer contact information with its parent company by routing incoming home security alarm signals through another monitoring centre in North America. The only personal information shared would be information needed to provide monitoring and security services, such as the customers' home or business addresses, a phone number, and an emergency contact list.

Since the company sent out a notification explaining what it was doing with customers' personal information, the OPC concluded that the obligation under PIPEDA Principle 4.8<sup>68</sup> was satisfied because the company readily made available specific information about its policies and practices relating to the management of personal information.

The third finding, Finding 2008-394<sup>69</sup>, involved a website's e-mail operations that were outsourced to a U.S.-based firm. Existing subscribers were informed in advance that their new login to their account would be an opportunity for them to accept or reject the terms of the services. New e-mail subscribers were also informed, not only of information transfers to the U.S.-based provider but also the potential privacy implications.

The Privacy Commissioner rejected the complaints against the website owner insofar as the email provider had fulfilled its obligations to provide comparable protection under the Act by putting in place adequate contractual provisions. In this case, the Privacy Commissioner's position was re-iterated on two key points:

*"Organizations must be transparent about their personal information handling practices. A company in Canada that outsources personal information processing to a company that operates in another country should notify its customers that the information may be available to the government of that country or its agencies under a lawful order made in that country."*

*"With regard to the issue of customer consent, the Office has taken the position that the sharing of information with a third-party service provider constitutes a "use" for the purposes of the Act. Organizations obtain customer consent for the use of personal information for the provision of services or products when individuals first apply for the service or product. Although service providers may change over time, if the purpose of the current provider's use of the personal information has remained the same, organizations are not required to obtain renewed customer consent for the information use."*

---

<sup>67</sup> Available at: <https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2006/pipeda-2006-333/>.

<sup>68</sup> Principle 4.8 concerns Openness and states: "An organization shall make readily available to individuals specific information about its policies and practices relating to the management of personal information."

<sup>69</sup> Available at: <https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2008/pipeda-2008-394/>.

## C2. Analysis

The legislative provisions described above, IPC views and OPC Findings must be considered by the initial collectors of the personal information in question who then seek to use the Azure OpenAI service.

Of particular significance with respect to Canadian customers using Azure OpenAI, subject to the qualification below, is the fact that *customer content data*, including personal information, remains in Canada and does not reside or is accessed by individuals located elsewhere, unless authorized by statute.

With respect to Azure OpenAI, prompts and responses are processed within the customer-specified geography, but may be processed between regions within the geography for operational purposes (including performance and capacity management). The service is configured to synchronously evaluate the prompt and completion data in real time to check for harmful content types and stops generating content that exceeds the configured thresholds.

The qualification to be noted is that Azure OpenAI abuse monitoring detects and mitigates instances of recurring content and/or behaviors that suggest use of the service in a manner that may violate the code of conduct or other applicable product terms. To detect and mitigate abuse, Azure OpenAI stores all prompts and generated content securely for up to thirty (30) days. (No prompts or completions are stored if the customer is approved for and elects to configure abuse monitoring off, as described below.)

The data store where prompts and completions are stored is logically separated by customer resource (each request includes the resource ID of the customer's Azure OpenAI resource). A separate data store is located in each region in which the Azure OpenAI Service is available, and a customer's prompts and generated content are stored in the Azure region where the customer's Azure OpenAI service resource is deployed, within the Azure OpenAI service boundary. Human reviewers assessing potential abuse can access prompts and completions data only when that data has been flagged by the abuse monitoring system. When prompts and/or completions are flagged by the Abuse Monitoring System, through content classification and abuse pattern capture, authorized Microsoft employees may assess the flagged content, and either confirm or correct the classification or determination based on predefined guidelines and policies.

The human reviewers are authorized Microsoft employees who access the data via point wise queries using request IDs, Secure Access Workstations, and Just-In-Time request approval granted by team managers. For Azure OpenAI Service deployed in the European Economic Area, the authorized Microsoft employees are located in the European Economic Area.

In the case of Azure generally, *system data* is stored both inside and outside of Canada and is accessible by authenticated administrators both inside and outside of Canada. Its use is tightly controlled and limited to the provisioning, maintenance, support, and ongoing operation of cloud services. All service and maintenance data are accessed and contained within Microsoft's global, private network.

Microsoft Entra ID operates as a non-regional service and based on customer requirements, including availability and scalability, may store Microsoft Entra directory data globally. Therefore, *user data* may be stored outside of Canada. Depending upon the specific Customer choices as to what is placed in

Microsoft Entra ID, some of these elements may constitute personal information (e.g. home telephone number). This aspect is, however, entirely within the control of the Customer.

As for potential requests of governmental (including American) authorities for access to Customer Data, Microsoft provides contractual guarantees as to how such access requests will be handled.

As a starting point, no access to Customer Data is permitted without authorization. Microsoft indicates that its staff are unable to access Customer Data within their virtual environments unless expressly given the credentials to gain access. With respect to Azure OpenAI, as with any organization, Microsoft is obligated to comply with the applicable laws, and this includes responding to legal demands for Customer Data.

Customers are responsible for the information they hold in Azure. Microsoft has indicated that its position is that Customers are responsible to address legal requests concerning their data. If Microsoft is served a legal subpoena for access to customer information, the request is redirected to the Customer unless Microsoft is explicitly prevented from doing so.

Microsoft stated policy generally with respect to all its software and services (including the Azure OpenAI service) is as follows:

1. Microsoft does not provide any government with direct and unfettered access to Customer Data. A relevant legal demand is required.
2. If a government wants Customer Data, including for national security purposes, it must follow applicable legal process (i.e. serve a court order or subpoena for content or account information).
3. Microsoft only responds to requests for specific accounts and identifiers. There is no blanket or indiscriminate access to Customer Data. Aggregate data published by Microsoft indicates that only a small fraction —fractions of a percent— of Customers have ever been subject to a government demand related to criminal law or national security.
4. A Microsoft compliance team reviews each request and is tasked to ensure that such requests are valid and that any released data is limited to that specified in the order.

Microsoft's DPA expressly deals with the subject of data transfers and data location:

### ***Data Transfers and Location***

#### ***Data Transfers***

*Customer Data, Professional Services Data, and Personal Data that Microsoft processes on Customer's behalf may not be transferred to, or stored and processed in a geographic location except in accordance with the DPA Terms and the safeguards provided below in this section. Taking into account such safeguards, Customer appoints Microsoft to transfer Customer Data, Professional Services Data, and Personal Data to the United States or any other country in which Microsoft or its Subprocessors operate and to store and process Customer Data, and Personal Data to provide the Products, except as described elsewhere in the DPA Terms.*

*All transfers of Customer Data, Professional Services Data, and Personal Data out of the European Union, European Economic Area, United Kingdom, and Switzerland to provide the Products and Services are subject to the terms of the 2021 Standard Contractual Clauses implemented by Microsoft. In addition, transfers from the United Kingdom are subject to the terms of the IDTA implemented by Microsoft.*

*For purposes of this DPA, the “IDTA” means the international data transfer addendum to the European Commission’s standard contractual clauses for international data transfers issued by the UK Information Commissioner’s Office under S119A(1) of the UK Data Protection Act 2018. Microsoft will abide by the requirements of European Economic Area, United Kingdom, and Swiss data protection law regarding the collection, use, transfer, retention, and other processing of Personal Data from the European Economic Area, United Kingdom, and Switzerland. All transfers of Personal Data to a third country or an international organization will be subject to appropriate safeguards as described in Article 46 of the GDPR and such transfers and safeguards will be documented according to Article 30(2) of the GDPR.*

*In addition, Microsoft is certified to the EU-U.S. and Swiss-U.S. Data Privacy Frameworks, the UK Extension to the EU-U.S. Data Privacy Framework and the commitments they entail. Microsoft agrees to notify Customer if it makes a determination that it can no longer meet its obligation to provide the same level of protection as is required by the principles of the Data Privacy Frameworks.*

#### **Location of Customer Data**

*For the Core Online Services, Microsoft will store Customer Data at rest within certain major geographic areas (each, a Geo) as set forth in the Product Terms.*

*For EU Data Boundary Online Services, Microsoft will store and process Customer Data and Personal Data within the European Union as set forth in the Product Terms.*

*Microsoft does not control or limit the regions from which Customer or Customer’s end users may access or move Customer Data.*

## **D. Guidance on the Use of Cloud Computing Services**

### **D1. The Canadian Landscape**

The use of Azure OpenAI obviously involves using cloud computing-based services. There is public sector guidance on cloud computing provided by the Office of the Information and Privacy Commissioner of British Columbia (“OIPC-BC”) and some degree of private sector guidance from the federal Privacy Commissioner with respect to outsourcing in general. There is also guidance from Treasury Board Secretariat for federal public sector entities. Together, these sources of information allow prospective customers to determine whether a custodian of personal information has taken reasonable steps to ensure the security of the information, including personal information, entrusted to a Cloud-based service provider.

**Canada (OPC).** While the OPC has not issued any guidance specifically with respect to cloud computing for public sector entities, that Office has provided views for private sector organizations with respect to outsourcing of personal data processing across borders, *Guidelines for Processing Personal Data Across Borders* and these considerations would apply whether data in the cloud or otherwise.

**Canada (TBS).** The Treasury Board of Canada Secretariat (“TBS”) has issued guidance as it relates to federal departments adopting cloud-services, and storing information up to and including Protected B. While this guidance is largely a policy on the adoption and use of cloud-services, and places responsibilities on the Government of Canada’s departments, there are identified requirements that departments are to look for when procuring cloud services. The details of this guidance and how Microsoft meets them is described in [Section D2](#) below.

**Ontario.** In 2012, Ontario IPC considered the use of service providers by government in a special investigation report, *“Reviewing the Licensing Automation System of the Ministry of Natural Resources”*<sup>70</sup> (MNR Report”), which formed the basis for its 2016 guidance to Ontario public sector entities entitled *“Thinking About Clouds? Privacy, security and compliance considerations for Ontario public sector institutions”*.<sup>71</sup> (See the section on [Agreements](#) above for identified contractual requirements.)

**British Columbia.** The OIPC-BC has offered guidance on the subject of cloud computing<sup>72</sup>. Part of that guidance concerns “reasonable security arrangements” and requires the public body to review the cloud provider’s security after considering the sensitivity of the information to be stored or processed. For potential customers of any cloud-based service, including Azure OpenAI, there are significant aspects of the privacy and security postures of any service provider to review. These include:

- **Governance** – corporate policies, procedures, and standards with respect to security and privacy.
- **Identity and Access Management** – the controls surrounding access whether by cloud provider employees or customer employees and users.
- **Infrastructure Security** – the management and ongoing maintenance of network, system and application security including layered security controls and patch management.
- **Encryption** – personal information in transit should be encrypted as well as while stored at the cloud provider’s facilities.
- **Contractual provisions** – contracts should include breach notification requirements (“as soon as possible”) in the event of an actual or suspected breach of personal information as well as Cloud facility visitation/audit rights.<sup>73</sup>

With respect to the use of cloud computing services, how Microsoft addresses security requirements are discussed in [Annex A](#). Contractual aspects are discussed in Section 4B ([Agreements](#)) above and elsewhere throughout this Privacy Analysis.

## D2. Treasury Board Guidance on the Use of Cloud Computing

<sup>70</sup> PC12-39 available at [https://www.ipc.on.ca/images/Findings/2012-06-28-MNR\\_report.pdf](https://www.ipc.on.ca/images/Findings/2012-06-28-MNR_report.pdf).

<sup>71</sup> Available at: <https://www.ipc.on.ca/wp-content/uploads/2016/08/thinking-about-clouds-1.pdf>.

<sup>72</sup> See OIPC-BC, “Cloud Computing Guidelines for Public Bodies”, June 2012.

<sup>73</sup> Note, however, the discussion in Part 2 concerning hyperscale cloud and the approach of using independent third-party auditors to assess Microsoft adherence to controls contained in standards documentation. This objective of “visitation/audit rights” may be achieved in other ways and may be viewed as less effective as cloud-based operations evolve.

The Treasury Board of Canada Secretariat (“TBS”) has issued guidance as it relates to federal departments adopting cloud-services, and storing information in the cloud classified up to and including Protected B. The guidance is federal policy for federal government institutions concerning the procurement of cloud-services. The requirements are specific and relate to:

- Baseline Security Controls
- Third-Party Assurance
- Continuous Monitoring
- Information Assurance and Asset Protection
- Secure Software Development
- Data Residency
- Privileged User Access Controls
- Use of Encryption
- Personnel Screening
- Physical Security
- Service Continuity
- Supply Chain Risk Management
- Incident Response

**Baseline Security Controls.** TBS directs departments to the *Government of Canada’s Security Control Profile for Cloud-Based GC IT Services*<sup>74</sup> for a set of recommended baseline security controls to be present and implemented by cloud-service providers.

The Security Control Profile was designed to consider generic departmental requirements when dealing with deliberate and accidental threats. Security controls, applied to cloud service providers, should include:

- Implementation of “Defence-in-depth”.
- An ability to provision users with “least-privilege”.
- An ability to prevent, detect, analyze, respond, and recover from attacks.
- Layered Defence.
- An ability to isolate the customer institution’s tenancy.

How Microsoft adheres to these requirements is described in detail in [Annex A](#).

**Third-Party Assurance.** TBS encourages departments to leverage independent reporting to validate the service provider’s security controls such as:

- ISO/IEC 27001.
- ISO/IEC 27017.
- ISO/IEC 27018.
- Federal Risk and Authorization Management Program (FedRAMP).
- Payment Card Industry Data Security Standard (PCI-DSS).
- Cloud Security Alliance (CSA) Security, Trust and Assurance Registry (STAR).

---

<sup>74</sup> Available at: <https://www.canada.ca/en/government/system/digital-government/modern-emerging-technologies/cloud-services/government-canada-security-control-profile-cloud-based-it-services.html>.

- AICPA Service Organization Controls (SOC) audit reports or certifications.

Microsoft has completed ISO/IEC 27001:2013, ISO/IEC 27018, SOC 1 Type 2, SOC3, and FedRAMP attestations for Azure. Copies of the relevant certificates available through the Microsoft Service Trust Portal.

**Continuous Monitoring.** Cloud-service providers are expected to continuously monitor their cloud services to detect changes in the security posture of the cloud service environment, including:

- Monitoring their security controls.
- Assessing security controls regularly.
- Demonstrating that the security posture is continuously acceptable.

As indicated in [Annex A](#), centralized monitoring, correlation, and analysis systems manage the large amount of information generated by devices within the Azure environment, providing both visibility and alerts to the Microsoft teams that manage the service.

Microsoft administrative operations, including system access, are logged to provide an audit trail if unauthorized or accidental changes are made. In addition to addressing software vulnerabilities, one aspect of security is the minimization of operational weaknesses. For Azure, including Azure OpenAI, Microsoft uses an Operational Security Assurance (“OSA”) framework, which supports continuous monitoring, provides operational security guidelines, and validates adherence to those guidelines. The objective is to increase resiliency by decreasing the amount of time needed to detect and respond to security threats.

OSA is built on the fundamental principles of threat modeling, designing secure configurations, testing operational effectiveness, and promptly responding to and remediating security concerns. The requirements for some domains involve collecting documentation or training staff to ensure that they have skills that ensure work of appropriate quality. Other domains with security requirements can take advantage of automated solutions that are able to demonstrate that operational baseline requirements are being addressed.

The scope of OSA is limited to a set of control objectives or domains most likely to be affected by external Internet-based attack. This set of domains closely aligns with and maps to the control areas that are used by NIST 800-53 and ISO 27001. OSA defines the aspects of these domains by first establishing baseline requirements that each service should meet or exceed. These baseline requirements are then used to establish a test plan that can be used to validate a service’s security during an assessment.

Different sources of information continually feed into the OSA methodology:

- Organizational learning and improvements, used to improve Microsoft services.
- International standards and mature external security practices, such as updates to NIST SP 800-53, ISO 27001, and other relevant practices.
- Security incidents and threats, and the corresponding incident response measures.
- Industry associations and experts.
- Threat intelligence programs using data from Internet services and more than 600 million computers worldwide.

- Security technologies and security solutions that are developed both inside and outside of Microsoft.

**Secure Software Development.** Cloud-based services are expected to be designed and developed following industry best practices (for example, SAFECode Fundamental Practices for Secure Software Development, ISO/IEC 27034 and OWASP) to minimize security issues that could:

- Compromise Government of Canada (GC) information.
- Cause a loss of service.
- Enable other malicious activity.

Azure code development adheres to Microsoft's Security Development Lifecycle ("SDL"), a process that allows developers to build more secure software and address security compliance requirements.

The SDL<sup>75</sup> is a Microsoft-wide, mandatory software development process with the objective of reducing the number and severity of vulnerabilities in Microsoft software. Since 2004, the SDL has been used to institutionalize and embed security requirements into the Microsoft product lifecycle (i.e. from planning to design, development, and deployment phases). After a product is made available to customers, the focus shifts to vulnerabilities. Microsoft indicates that it has created teams have been created to respond to any incidents, and their findings inform the SDL to help improve future products. Microsoft indicates that Microsoft's SDL conforms with ISO 27034.

**Data Residency.** Departments are expected to apply the Directive on Service and Digital<sup>76</sup> when implementing safeguards for electronic data residency. The Directive states that the Departmental CIO is responsible for:

*"Ensuring computing facilities located within the geographic boundaries of Canada or within the premises of a Government of Canada department located abroad, such as a diplomatic or consular mission, be identified and evaluated as a principal delivery option for all sensitive electronic information and data under government control that has been categorized as Protected B, Protected C or is Classified."*

Data location information specific to Microsoft services, including Azure OpenAI, is located online.<sup>77</sup> The DPA also has specific language pertaining to Microsoft's commitments to data transfers and location of Customer Data.

**Identity, Credential and Access Management.** The controls required under this section of the Treasury Board Guidance largely are the responsibility of government departments. The only specific requirement, when accessing cloud-based services, is the use of strong authentication mechanisms, such as two-factor or multi-factor authentication.

Microsoft provides multi-factor authentication for Azure services<sup>78</sup>. The options available are:

<sup>75</sup> Further information concerning SDL is publicly available at: <https://www.microsoft.com/en-us/sdl/default.aspx>.

<sup>76</sup> Located at: <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32601>. See Section 4.4.3.14.

<sup>77</sup> See "Where is Your Data Located", available at: <https://www.microsoft.com/en-ca/trust-center/privacy/data-location>.

<sup>78</sup> Further information concerning authentication is available at: <https://docs.microsoft.com/en-us/azure/active-directory/authentication/concept-mfa-howitworks>.

- “Call my mobile phone”: The user receives a phone call that asks him/her to press the pound key. Once the pound key is pressed, the user is logged in.
- “Text code to my mobile phone”: The user receives a text message containing a six-digit code that he/she must enter into the portal.
- “Call my office phone”: This is the same as “Call my mobile phone”, but it enables the user to select a different phone if he/she does not have a mobile phone readily available.
- “Notify me through app”: The user previously configured a smartphone app (“Authenticator”) and he/she receives a notification in the app that he/she must confirm the login. Smartphone apps are available for Windows Phone, iPhone, and Android devices.
- “Show one-time code in app”. The same smartphone app is used. Instead of receiving a notification, the user starts the app and enters the six-digit code from the app into the portal.

Users and groups can be enabled for Azure Multi-Factor Authentication to prompt for additional verification during the sign-in event. Security defaults are available for all Azure AD tenants to enable the use of the Microsoft Authenticator app for all users.

Users can register themselves for both self-service password reset and Azure Multi-Factor Authentication in one step. Administrators can define what forms of secondary authentication can be used. Azure Multi-Factor Authentication can also be required when users perform a self-service password reset to further secure that process.

For more granular controls, conditional access policies can be used to define events or applications that require MFA. These policies can allow regular sign-in events when the user is on the corporate network or a registered device, but prompt for additional verification factors when remote or on a personal device.

**Network Security.** TBS guidance suggests that cloud-service providers should only make use of CSE-approved cryptographic algorithms and protocols, as outlined in CSE’s *ITSP.40.111 Cryptographic Algorithms for Unclassified, Protected A, and Protected B Information*<sup>79</sup> and CSE’s *ITSP.40.062 Guidance on Securely Configuring Network Protocols*<sup>80</sup>

Encryption methods and protocols used for data at rest and data in transit are described at length in [Annex A](#).

**Personnel Screening.** Cloud-service providers are expected to demonstrate the measures they use to assess, grant, and maintain the required level of security screening for their personnel. TBS requires that security screening be:

- Applied in accordance with, or use an adequate risk-based approach aligned with the definition and practices in the Treasury Board Standard on Security Screening<sup>81</sup> as stated for Reliability Status
- Subject to the provisions of any international information-sharing agreements.

<sup>79</sup> Available at: <https://www.cyber.gc.ca/en/guidance/cryptographic-algorithms-unclassified-protected-and-protected-b-information-itsp40111>

<sup>80</sup> Available at: [https://www.cyber.gc.ca/sites/default/files/cyber/publications/itsap40062-e\\_0.pdf](https://www.cyber.gc.ca/sites/default/files/cyber/publications/itsap40062-e_0.pdf)

<sup>81</sup> Available at: <https://www.tbs-sct.gc.ca/pol/doc-eng.aspx?id=28115>.

Microsoft screens personnel prior to providing access to customer content. "Cloud" background checks are required to be completed prior to creating service team account with access to this data.

Microsoft's "cloud" background check includes checking criminal history. Microsoft personnel requesting additional access to a multi-tenant role type are required to undergo additional screening. Enforcing screening requirements at the time of account creation and permission assignment ensures that personnel will not be inadvertently granted access prior to successful screening.

Azure personnel with "cloud" and "multi-tenant" designations are re-screened every two years. Access to systems is revoked for personnel who do not pass rescreening.

**Physical Security.** Under the TBS Guidance, cloud-service providers are expected to demonstrate measures to ensure asset protection and resilience, such as:

- Physical protection of commercial facilities that host GC data and IT assets.
- Controlled maintenance of information systems and their components to protect their integrity and ensure their ongoing availability.
- Protection of assets that store or process GC data against all forms of tampering, loss, damage, or seizure.

Physical protection measures:

- Must be applied in accordance with, or use an adequate risk-based approach aligned with the physical security controls outlined in the *Government of Canada Security Control Profile for Cloud-Based GC IT Services*<sup>82</sup>
- Must be applied in accordance with or use an adequate risk-based approach aligned with the practices in the Royal Canadian Mounted Police guidance and standards on physical security.
- Are subject to the provisions of any international information-sharing agreements.

[Annex A](#) details the physical security measures Microsoft has in place at its data centres. It should also be noted that Microsoft's data centre facilities have received facilities clearance at Protected B by PSPC Industrial Security.

**Service Continuity.** TBS guidance states that cloud-based services should be designed to take into consideration suitable geographic dispersal and data replication capabilities to meet business continuity objectives.

The Microsoft Canada Data Centres replicate their data across the Toronto and Quebec City facilities to ensure that Customer Data remains available. This approach to data replication is intended to ensure continuous service delivery.

---

<sup>82</sup> Available at: <https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/cloud-services/government-canada-security-control-profile-cloud-based-it-services.html>.

**Service Acquisition.** Cloud-service providers are expected to apply supply chain risk management practices to maintain confidence in the security of the sources of information systems and the IT components used to provide their cloud services.

Microsoft may hire subcontractors to provide certain limited or ancillary services on its behalf. Microsoft indicates that such subcontractors may only access Customer Data to deliver the services they have been retained to provide and are prohibited from using Customer Data for any other purpose. Microsoft confirms that it remains responsible for its subcontractors' compliance with the obligations in the DPA.

Prior to the receipt of any Customer Data, subcontractors will have entered into written agreements with Microsoft requiring that the subcontractor abide by terms no less protective than those described in the DPA. Microsoft will not transfer to any third party (not even for storage purposes) personal data that a customer has provided to Microsoft using the Online Services.

Cloud-service providers are also expected to prohibit unauthorized access to, use, or alteration of GC data hosted in their cloud service environments. This restriction includes implementing measures to support an exit strategy, which includes:

- The removal of all GC data by an agreed method and time frame, in alignment with CSE's *ITSP.40.006 v2\_IT\_Media Sanitization*<sup>83</sup> guidance.
- The ability for the GC to retrieve its data in an agreed format and time frame until the exit process is complete.

Microsoft indicates that no more than 180 days after expiration or termination of Customer's use of an Online Service, Microsoft will disable the account and delete Customer Data from the account. As noted above, there is no return of data to the customer.

Microsoft wipes storage hard drives using a solution that is compliant with NIST 800-88<sup>84</sup> (referenced in ITSP.40.006 V2 for further guidance). For hard drives that cannot be wiped, there is a physical destruction process that destroys them and renders the recovery of information impossible. The appropriate means of disposal is determined by the asset type.

Records of hardware destruction are retained and audited through Microsoft's ISO process. All Azure services utilize approved media storage and disposal management services. Paper documents are destroyed using approved methods at the pre-determined "end-of-lifecycle".

**Incident Response.** Cloud-service providers are expected to notify the Government of Canada when a security incident or breach of government data or their cloud services impacts the government's service. Such notifications should be distributed to:

- Relevant departmental contacts (for example, cloud-based service owner).
- Government of Canada's Computer Incident Response Team.

Microsoft indicates that it will promptly:

---

<sup>83</sup> Available at: <https://www.cyber.gc.ca/en/guidance/it-media-sanitization-itsp40006>.

<sup>84</sup> National Institute of Standards & Technology Special Publication 800-88, Guidelines for Media Sanitization.

- (a) Notify the customer of the Security Incident.
- (b) Investigate the security incident.
- (c) Provide the customer with detailed information about the security incident.
- (d) Take reasonable steps to mitigate the effects and to minimize any damage resulting from the security incident.

While not a contractual obligation, Microsoft has also recently adopted a policy to notify customers if they believe that a customer account has been targeted or compromised by an individual or group working on behalf of a nation state. This policy has been adopted because a “state-sponsored” attack could be more sophisticated or more sustained than attacks from cybercriminals and others.

These notifications do not mean that Microsoft’s own systems have been compromised. If customers receive such a notification, this means that there is evidence the customer account has been targeted. This allows customers to take additional measures to keep their account secure.

## E. Guidance on the Use of Generative AI (for Federal Institutions)

Treasury Board of Canada Secretariat has published guidance for federal institutions considering the use of Generative AI services.<sup>85</sup> This guidance is distinct from the federal government’s *Directive on Automated Decision-Making*<sup>86</sup>, which concerns the use of algorithmic AI but may also be relevant depending on the Generative AI service or tool used. Not all aspects of the TBS Guidance are presented in this FPIA, and the original document should be consulted.

**General Requirements.** Prior to any use of Generative AI, federal institutions must assess and mitigate certain ethical, legal, and other risks. As expected, the level of risk depends on the use case and mitigation measures put in place. Accordingly, federal institutions should “tailor best practices and risk-mitigation measures to each use”.

Federal institutions are directed to consider certain the following principles:

- **“Fair:** ensure that content from these tools does not include or amplify biases and that it complies with human rights, accessibility, and procedural and substantive fairness obligations; engage with affected stakeholders before deployment.
- **Accountable:** take responsibility for the content generated by these tools and the impacts of their use. This includes making sure generated content is accurate, legal, ethical, and compliant with the terms of use; establish monitoring and oversight mechanisms.
- **Secure:** ensure that the infrastructure and tools are appropriate for the security classification of the information and that privacy and personal information are protected; assess and manage cyber security risks and robustness when deploying a system.
- **Transparent:** identify content that has been produced using generative AI; notify users that they are interacting with an AI tool; provide information on institutional policies, appropriate use, training data and the model when deploying these tools; document decisions and be able to provide explanations if tools are used to support decision-making.

---

<sup>85</sup> Available at: <https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/responsible-use-ai/guide-use-generative-ai.html>.

<sup>86</sup> Available at: <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32592>.

- **Educated:** learn about the strengths, limitations, and responsible use of the tools; learn how to create effective prompts and to identify potential weaknesses in the outputs.
- **Relevant:** make sure the use of generative AI tools supports user and organizational needs and contributes to better outcomes for customers; consider the environmental impacts when choosing to use a tool; identify appropriate tools for the task; AI tools aren't the best choice in every situation".

TBS also identified responsibilities of federal institutions. It directs them to:

- Ensure that employees can access and take training on the effective and responsible use of generative AI tools.
- Support employees in improving their knowledge of topics such as detecting biased and inaccurate content.
- Provide access to secure generative AI tools that meet government information, privacy, and security requirements.
- Enable access to online generative AI tools, in alignment with the *Policy on Service and Digital* (requirement 4.4.2.5)<sup>87</sup> and the *Directive on Service and Digital Appendix A: Examples of Acceptable Network and Device Use (Non-Exhaustive List)*<sup>88</sup>.
- Implement oversight and performance management processes to monitor the impacts of these tools, their compliance with applicable laws and policies, and alignment with the FASTER principles.
- Engage with employees to understand their needs.
- Consult with stakeholders such as end-users, customer representative groups and bargaining agents before high-risk deployments.

**Privacy Requirements.** TBS indicates that privacy risks will depend on how the generative AI service is used; how it processes information about individuals and whether it is publicly accessible online or is deployed on the government's secure network. The privacy aspects of TBS's guidance indicate that:

- Public servants must not input personal information into publicly available online generative AI tools.
- Public servants may, however, input personal information into generative AI systems that are controlled or configured by the government when the appropriate privacy and security controls are in place. When using a generative AI tool controlled by the institution, employees are responsible for following all privacy and protection of personal information requirements as they are for any other system.
- If the output of a generative AI tool results in the creation of new personal information, the institution must manage the new information according to privacy requirements.
- When institutions are considering procuring, developing, or deploying a generative AI tool, privacy officials must be consulted to determine whether a Privacy Impact Assessment is needed to identify and mitigate privacy risks ahead of deployment.
- De-identification and the use of synthetic data can help institutions reduce the impact and likelihood of privacy breaches when developing, training, using, and evaluating the outputs of generative AI tools.

<sup>87</sup> Available at: <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32603>.

<sup>88</sup> Available at: <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32707#chaAppendix%20A>.

**Protection Requirements.** With respect to the protection of information, the TBS Guidance recommends:

- Don't enter sensitive or personal information into any tools not managed by the GC.
- Don't submit queries on non-GC managed tools that could undermine public trust if they were disclosed.
- Understand how a system uses input data (for example, whether it's used as training data and whether it's accessible to suppliers).
- Ask legal services, the institutional chief security officer, and the privacy team to review a supplier's terms of use, privacy policy and other legal documents before using any system to process sensitive or proprietary information.
- Use infrastructure and tools that are appropriate for the security classification of the information, in accordance with the *Directive on Security Management*.<sup>89</sup>
- Seek the approval of the institutional chief security officer before using, procuring, or deploying generative AI for protected or other sensitive information.
- Consider the requirements for information and data residency in the *Directive on Service and Digital*<sup>90</sup> and related guidance in the *Guideline on Service and Digital*.<sup>91</sup>
- Use the "opt-out" feature, where possible, to ensure that prompts are not used to train or further develop an AI system."
- Conduct regular system testing before and during the operation of a system to identify and mitigate potential adverse impacts.
- Apply in-depth testing methods to identify and mitigate vulnerabilities (e.g., penetration testing, adversarial testing, or red teaming).
- Conduct independent audits using existing AI risk management frameworks.
- Document and respond to cyber security events and incidents. Update security plans, as needed, to address the evolving threat environment.

**Addressing Bias.** Outputs may amplify biases that are present in the training data; the model's design and, when used, prompt construction. The TBS Guidance offers suggestions to counter such bias, such as:

- Reviewing generated content to make sure it aligns with organizational commitments, values, and ethics, and meets legal obligations.
- Formulating prompts to generate content that provides holistic perspectives and minimizes biases.
- Understanding where the training data came from, what it includes, and how it was selected and prepared.
- Clearly indicating when content has been produced by generative AI.
- Understanding how deploying a generative AI tool might impact different population groups (i.e., consider potential biases in the planning and design stage to mitigate them from the planning and design stage).
- Testing for biases in the data, the model, and outputs before deploying a tool, and on an ongoing basis.

---

<sup>89</sup> Available at: <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32611>.

<sup>90</sup> Available at: <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32601>.

<sup>91</sup> Available at: <https://www.canada.ca/en/government/system/digital-government/guideline-service-digital.html>.

- Regularly monitoring the system for adverse impacts after deployment.

**Addressing Quality.** Generative AI technologies can produce content that appears to be reasonable but is inaccurate, nonsensical, or inconsistent with the source data. The TBS Guidance suggests:

- Clearly indicating that Generative AI was used to develop content.
- Never considering generated content as authoritative and reviewing it for factual and contextual accuracy.
- Assessing the impact of inaccurate outputs.
- Understanding the quality and source of training data.
- Considering the organization's ability to identify inaccurate content before using generative AI. If you can't confirm the quality of the content, don't use it.
- Learn how to create effective prompts and provide feedback to refine outputs to minimize the generation of inaccurate content.
- Not using Generative AI tools as search engines unless sources are provided for verification.
- Assessing training data quality when refining models.
- Using grounding and prompt engineering so the models build responses from only the information the organization provides and controls.
- Informing users that they are interacting with generative AI.
- When content is generated by AI, including links to authoritative sources to provide users with additional context and foster transparency.
- Providing information about the appropriate use of the tools, capabilities and limitations of the system, risk mitigation measures, source of training data and how models were developed.
- Monitoring performance on an ongoing basis.
- Documenting problems, pausing deployment, and updating the tool if performance levels are not achieved.

**Documentation requirements.** As indicated pursuant to the *Directive on Service and Digital*<sup>92</sup>, GC employees are responsible for documenting their activities and decisions of business value. In the case of Generative AI tool, this would involve documenting the steps taken to ensure that the service produces appropriate and accurate outputs as well as the *Directive on Automated Decision Making* is triggered.

The context in which generative AI is used must be considered when evaluating the relative business value of the associated information and data. The business value will inform documentation requirements.

When institutions deploy generative AI tools to support or make administrative decisions, additional documentation requirements related to transparency, quality assurance and reporting apply. These requirements are set out in subsections 6.2, 6.3 and 6.5 of the *Directive on Automated Decision-Making*.

All documentation surrounding the use, development and deployment of generative AI systems under the control of a government institution is subject to the *Access to Information Act* and the *Library and Archives of Canada Act*<sup>93</sup> and must be retained and disposed of accordingly.

<sup>92</sup> Available at: <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32601>.

<sup>93</sup> Available at: <https://laws-lois.justice.gc.ca/eng/acts/L-7.7/>.

## F. Privacy Authorities' Guidance on the Responsible Use of AI

In December 2023, the privacy authorities in Canada, collectively, issued “Principles for responsible, trustworthy and privacy-protective generative AI technologies”. This occurred in the context of a joint investigation of ChatGPT by the privacy authorities for Canada, Québec, British Columbia, and Alberta as well as the fact that privacy authorities globally have expressed concerns about the collection of publicly accessible personal information.

These principles apply generally accepted privacy concepts to current AI practices and are addressed to both AI service/tool providers as well as organizations seeking to use such services/tools, without distinction as to the sector they occupy (i.e., all users subject to public, private and health sector legislation). What follows in this section are only the “AI aspects” relevant to Generative AI service users and readers of this FPIA may wish to review the full text of the Principles Statement.<sup>94</sup>

**Legal Authority and Consent.** Ensure legal authority for collecting and using personal information; when consent is the legal authority, it should be valid and meaningful.

All parties should:

- Know and document their legal authority for collection, use, disclosure, and deletion of personal information that occurs as part of the training, development, deployment, operation, or decommissioning of a generative AI system.
- Ensure that where personal information is sourced from third parties, the third parties have collected it lawfully and have authority to disclose it.
- Be mindful that the inference of information about an identifiable individual (such as outputs about a person from a generative AI system) will be considered a collection of personal information, and as such would require legal authority.
- Where information is sensitive and consent (even where provided) may be inappropriate or inadequate, such as in health care, establish a separate review process which considers both the privacy and ethics of the proposed use of the information, and which is subject to independent oversight.

**Appropriate Purposes.** Collection, use and disclosure of personal information should only be for appropriate purposes.

All parties should also consider the legitimacy of the *manner* of any collection, use and disclosure of personal information in relation to a generative AI system. This includes consideration of whether the use of the generative AI system is appropriate for the specific application.

---

<sup>94</sup> The full text is available at: [https://www.priv.gc.ca/en/privacy-topics/technology/artificial-intelligence/gd\\_principles\\_ai/#wb-cont](https://www.priv.gc.ca/en/privacy-topics/technology/artificial-intelligence/gd_principles_ai/#wb-cont).

Organizations using Generative AI should:

- Avoid prompting a generative AI system to re-identify any previously de-identified data.
- Monitor for, and notify developers or providers of, potential inappropriate uses or biased outcomes that have not been disclosed as a potential limitation of the system.
- Avoid inappropriate uses of generative AI tools, including 'no-go zones' such as the collection, use, or disclosure of personal information that is otherwise unlawful; profiling or categorization that may lead to unfair, unethical, or discriminatory treatment that is contrary to human rights law; the collection, use, or disclosure of personal information for purposes that are known or likely to cause significant harm to individuals or groups, or activities which are known or likely to threaten fundamental rights and freedoms.
- If use of a generative AI system is detected to violate a 'no-go zone', cease the activity.

**Necessity and proportionality:** Establish the necessity and proportionality of using generative AI, and personal information within generative AI systems, to achieve intended purposes.

All parties should use anonymized, synthetic, or de-identified data rather than personal information where the latter is not required to fulfill the identified appropriate purpose(s).

Organizations using Generative AI should:

- Consider whether the use of a generative AI system is necessary and proportionate, particularly where it may have a significant impact on individuals or groups. This means that the tool should be more than simply potentially useful. This consideration should be evidence-based and establish that the tool is both necessary and likely to be effective in achieving the specified purpose.
- Evaluate the validity and reliability of the generative AI tool for the intended purpose. Tools must be accurate throughout the intended lifecycle of the tool and across the variety of circumstances in which they are used.
- Consider whether there is other more privacy-protective technologies that can be used to achieve the same purpose.

**Openness:** Be open and transparent about the collection, use and disclosure of personal information and the potential risks to individuals' privacy.

All parties should:

- Inform individuals what, how, when, and why personal information is collected, used, or disclosed throughout any stage of the generative AI system's lifecycle (including development, training, and operation) for which the party is responsible. Ensure that system outputs that could have a significant impact on an individual or group are meaningfully identified as being created by a generative AI tool.
- Ensure that all information communicated about a generative AI system is designed to be understandable by the intended audience, and made readily available both before, during and after use of the system.

Organizations using Generative AI should:

- Clearly communicate to any affected party whether a generative AI tool will be used as part of a decision-making process, and if so, in what capacity, with what safeguards, and what options or recourse are available to the affected party (particularly where a decision may have a significant impact on an individual). This explanation should also include a general description of the functioning of the system, how it is used to make a decision or take an action, and an overview of potential outcomes.
- Describe what, if any, personal information was used to re-train or refine the generative AI system for their specific use.
- Where a generative AI tool is public facing, ensure that individuals interacting with the tool are aware that they are interacting with a generative AI tool and that they are informed about both privacy risks and any mitigations available to them (such as not entering personal information into a prompt, unless necessary).

**Accountability:** Establish accountability for compliance with privacy legislation and principles and make AI tools explainable.

With specific respect to AI, all parties should:

- Establish a mechanism by which the organization can receive and respond to privacy-related questions or complaints.
- Undertake assessments, such as Privacy Impact Assessments (PIAs) and/or Algorithmic Impact Assessments (AIAs), to identify and mitigate against potential or known impacts that the generative AI system (or proposed use thereof, as applicable) may have with respect to privacy and other fundamental rights.
- Regularly re-visit and re-evaluate accountability measures (including bias testing and assessments), given the evolving nature of both generative AI systems and AI regulation.

Organizations using Generative AI should:

- Know that accountability for decisions rests with the organization, and not with any kind of automated system used to support the decision-making process.
- Ensure that impacted individuals are provided with an effective challenge mechanism for any administrative or otherwise significant decision made about them. This includes maintaining and providing on request sufficient information for that person to be able to understand how a decision was reached and allowing them the opportunity to request human review and/or re-consideration of the decision.
- If the outputs of a generative AI system are not meaningfully explainable, consider whether the proposed use is appropriate.

**Individual Access:** Facilitate individuals' right to access their personal information by developing procedures that enable it to be meaningfully exercised.

All parties should:

- Ensure that procedures exist for individuals to access and correct any information collected about them during their use of the system.

- Develop processes to permit individuals to exercise their ability to access or correct personal information contained in an AI model, particularly where that information may be included in outputs generated in response to a prompt.

Organizations using Generative AI should - where a generative AI system is used as part of a decision-making process - maintain adequate records to allow for requests for access to information about that decision to be meaningfully fulfilled.

**Limiting Collection, Use, and Disclosure:** Limit the collection, use, and disclosure of personal information to only what is needed to fulfill the explicitly specified, appropriate identified purpose.

All parties should:

- Ensure that the collection and use of personal information for training AI tools is limited to what is necessary for the purpose and use anonymized or de-identified data where possible. This can include the use of synthetic data.
- Avoid function creep, and only use personal information for purposes identified at the time of collection or (where permissible) for purposes that are consistent with the purpose for collection.
- Avoid indiscriminate collection of personal information based on assertions about the breadth of potential purposes for a generative AI system.
- Recognize that the public accessibility of data does not mean that it can be indiscriminately collected or used. Personal information that is accessible online is still subject to Canadian legislation or other regulatory instruments – even where that information is defined as being ‘publicly available’.
- Establish and abide by appropriate retention schedules for personal information, including (as applicable) that contained within training data, system prompts, and outputs. These schedules should both (i) limit retention for information that is no longer required, and (ii) ensure that information is retained long enough for individuals to exercise their right to access (particularly where a decision has been made about them).

Organizations using generative AI systems should:

- Ensure that any inferences created about individuals are for specified and disclosed purposes, and that their accuracy can be reasonably assessed and validated.
- Treat any inferences generated about an identifiable individual as personal information.
- Where possible and reasonable, use anonymized or de-identified information within prompts to a generative AI system rather than personal information.
- Where personal information (and, in particular, sensitive, or confidential information) must be entered into a prompt, only do so where authorized.

Unless otherwise required, prompts should not be retained, used for secondary purposes, or disclosed.

**Accuracy:** Personal information must be as accurate, complete, and up to date as is necessary for purposes for which it is to be used.

Organizations using generative AI systems should:

- Ensure that personal information is as accurate, complete, and up to date as necessary for the purpose whenever it must be entered into a generative AI prompt or is used to train a bespoke generative AI model.
- Evaluate the impacts of any accuracy issues or limitations disclosed by the provider or developer of the generative AI system, such as time-bounded or single-source training data, on the use of the system. If this has not been disclosed and is not otherwise available, consider whether the use of the system remains appropriate and/or legally authorized.
- Take reasonable steps to ensure that any outputs from a generative AI tool are accurate as necessary for the purpose, especially if those outputs are used to make or assist in decisions about an individual or individuals, will be used in high-risk contexts, or will be released publicly.
- If the proposed use of a generative AI system relates to a specific group, take appropriate measures to ensure that that group is adequately and accurately represented in the system's training data.
- Be aware that issues regarding the accuracy of training data or outputs may make a generative AI system inappropriate for use (either in general or where such use could have significant impacts on an individual).

**Safeguards:** Establish safeguards to protect personal information and mitigate potential privacy risks.

All parties should:

- Safeguard any personal information collected or used throughout the lifecycle of a generative AI tool with measures commensurate to the sensitivity of the information.
- Maintain ongoing awareness of, and mitigations against, threats that are of particular concern when using generative AI, which include but are not limited to prompt injection attacks (in which carefully crafted prompts bypass filters or make the model perform unanticipated actions); model inversion attacks (in which personal information contained in the model's training data is exposed); and jailbreaking (in which privacy or security controls in the tool are overridden).

Organizations using generative AI systems should:

- Confirm that when using data under their control in the course of preparing, using, or deploying a generative AI system, the use of that data does not negatively impact model safeguards such as by creating or exacerbating biases, increasing the ability to undertake prompt injections, model inversions, or jailbreaks, or otherwise resulting in unauthorized parties being able to extract personal information in the course of using a generative AI system.

## G. Privacy Considerations and Risks in the Use of Generative AI

**It is important to note that the information in this section applies to any Generative AI system and is not specific, or limited, to Azure OpenAI.**

As described earlier in this FPIA, Generative AI involves the use of LLMs for the creation of new content, including text, video, images, audio, and code. The existence of these LLMs begin with “training” data, which may be supplemented by an organization’s data through a “fine tuning” process. The fine tuning and subsequent use of Generative AI tools or services has the potential to introduce new privacy risks, especially if personal information is used as inputs to generate output and/or used to further train the LLM models. This indicates a need to consider new governance programs and instruments to mitigate these privacy risks. The privacy risks to weigh invariably revolve around the “lifecycle” of information, from collection/generation to ultimate disposition.

As a preliminary consideration, to ensure appropriate internal oversight, organizations – whether public or private – should:

- Have a process to research and analyze each AI service prior to use by the organization. This process should consider:
  - Proposed use cases.
  - Privacy and security aspects.
  - Commercial terms of service.
- Maintain a registry of commercial Generative AI services approved for use within the organization. Such a registry should document:
  - Basic accuracy and security practices.
  - Privacy safeguards.
  - Supply chain risk management.
  - How training data for the foundation LLM was sourced.
- Establish an internal “use” policy to ensure that internal users adhere to and comply with that policy.<sup>95</sup> Associated with such a policy should be training to ensure managers/employees/contractors understanding of what is required of them. Policy elements should include:
  - Whether open-source information should be required.
  - Consideration as to whether to prohibit of the use of non-public/confidential information, personal information (including “anonymized” information), and social media information outside of AI systems entirely within the organization’s control.<sup>96</sup>
  - A requirement to opt out of data retention by - and use of input information to train - the Gen AI LLM if that option is available.
  - When using content generated by these tools, users must safeguard privacy, in a manner consistent with legal and corporate policy requirements.
  - To the extent possible, ensure that the use of the service is transparent, source cited, and explainable.
  - A prohibition on the development of inappropriate content.
- Require users to:
  - Manually review each output for accuracy, functional effectiveness and suitability, and intellectual property.
  - Not use any output that includes personal information.

<sup>95</sup> This is especially pertinent when Microsoft requires an organization to adhere to a Code of Conduct concerning the use of Azure Open AI.

<sup>96</sup> This depends on the use case as well as the organization’s program, initiative or activity insofar as personal information may be required. Public sector organizations should also consider whether to prohibit the use of Gen AI-generated content in any decision-making process or any activities that may affect affecting individual rights or safety.

- Report any unintended or inappropriate output.
- Report any potential cybersecurity incidents, data spillage, or fabrication outputs or errors.

The rationale for such policy elements can be found in the following privacy considerations.

**Privacy Consideration 1:** Each Generative AI service is governed by the provider’s privacy policy, terms of service, account registration requirements, and model training. Generative AI services uses input information in accordance with these terms and policies. Accordingly, some may collect information to train their models through “inputs” from users. Once a user discloses any information to a Gen AI service, the organization no longer has control over that information. Users need to (and should be required to) carefully assess the information they are inputting into the service.

**Mitigation Measure:** An organization should examine and assess the provider’s privacy policy/terms of service, and other relevant information to assess any potential privacy, security, or legal risks. Because the rapidly evolving nature of Generative AI services, this should occur on a periodic but nonetheless regular basis. Practices that raise organizational concerns should be noted and addressed in the procurement process as well as in organizational policy and training. It is noted that Microsoft explicitly states that it does not use customer inputs or outputs for training purposes.

**Privacy Consideration 2:** Generative AI tools are known to fabricate or invent/create inaccurate responses and/or provide biased outputs (because of biases in training data).

**Mitigation Measure:** This risk can be mitigated by limiting or prohibiting the use of outputs in any decision-making process or any activity affecting individual rights or safety. Because of this fabrication aspect, users should minimize the use of personal information as inputs and/or actively seek it as outputs (even if anonymized or de-identified). Given the accuracy principle, commonly found in Canadian privacy laws, if the tool generates personally identifiable information in its output, users should consider not using such information for decision-making purposes.<sup>97</sup>

**Privacy Consideration 3:** There is a risk that organizational personnel may not know the risks associated with or proper uses of Generative AI services.

**Mitigation Measure:** This risk can be mitigated if organizational users are aware of – and agree to - the limitations on use prior to being authorized to use a Generative AI tool. Such limitations including the prohibition on the input and use of any generated personal information as well as a mandatory “opt out” of input data being used for training option.

Further, users should be required to complete training on the organization’s AI Use Policy. Awareness tools such as “best practices” statements and Frequently Asked Questions documents should also be considered.

**Privacy Consideration 4:** There is a risk that employees/contractors will not have sufficient training for the Generative AI service.

---

<sup>97</sup> While Generative AI tools are not search engines, it is possible that personal information, publicly available on the Internet, may appear in an output.

**Mitigation Measure:** This risk can be mitigated by requiring all users to complete training prior to use of any Generative AI service. This training should be reviewed and updated as necessary as AI technology and AI services evolve.

**Privacy Consideration 5:** There is a risk that members of the public may not know how the organization's use of a Generative AI tools may affect or impact them.

**Mitigation Measure:** This risk can be mitigated if an (i) appropriate AI use policy is implemented; (ii) appropriate language is inserted in the organization's privacy policy or notice. The AI use policy should:

- Minimize or prohibit the use of Generative AI tools in any decision-making process or in any activities that affect individual rights or safety.
- Minimize or prohibit the use of personal information as an input.
- Cite the source of any Generative AI content in organizational products or services.

Similarly, the organization should publicize how it uses Gen AI in its business operations (at a general and not a technical level) and where further information may be found. The organizational privacy policy or notice should explicitly indicate whether Generative AI is used for decision-making purposes and whether its use involves the use of personal information.

**Privacy Consideration 6:** There is a risk that Generative AI output could include personal information or information that could otherwise affect the privacy of an individual, even where the user did not intend to receive or collect it. If this should occur, it should be noted that any personal information found in an output will be subject to applicable personal information protection laws, even if not originally collected by the organization.

**Mitigation Measure:** This risk can be partially mitigated by ensuring users are aware of an organization's AI Use policy as well as requiring them to report any problems or issues in the use of Generative AI services. Because Gen AI services obtain training data from a variety of sources (e.g., social media, web site scraping, or obtaining data from brokers), the training data used to train the AI service's LLM may include in output data that could impact privacy. This may be mitigated by examining/enquiring as to where the Generative AI service's LLM training data was obtained. The objective should be to obtain "ethically sourced training data". Furthermore, this risk can be minimized by prohibiting decision-making based on outputs, prohibiting the use of personal information as an input, and requiring the reporting of personal information found in outputs. Microsoft indicates that it does not use customer inputs or outputs for LLM training purposes.

**Privacy Consideration 7:** There is a risk that the organization may receive unintended information as part of the outputs.

**Mitigation Measure:** This risk can be partially mitigated by making the use a mechanism to report potential issues mandatory (i.e., unintended, or inappropriate outputs, fabrications, errors, unintended bias, or privacy concerns/incidents). Such a reporting requirement provides organizational awareness of issues and should form part of a mandatory discussion as to how to minimize unintended outputs.

**Privacy Consideration 8:** There is a risk that the organization will not appropriately process outputs that could include personal information.

**Mitigation Measure:** While an organization cannot control the outputs it receives, this risk can be partially mitigated through the establishment and use of a reporting mechanism to address output-related issues. Such a reporting requirement provides organizational awareness of issues and discussion of measures to minimize unintended outputs.

**Privacy Consideration 9:** There is a risk that Gen AI services may receive and use organizational data not intended for public use.

**Mitigation Measure:** This risk can be partially mitigated by a prohibition of the use of non-public information<sup>98</sup> in prompts. Some Generative AI services may also allow users to opt out of their inputs being retained and used to train LLMs (i.e., information submitted as an input is not used to further enhance and develop its algorithm). The organizational AI Use Policy should mandate that if an “opt-out” feature is available, the user will always select it. Microsoft indicates that it does not use customer inputs or outputs for LLM training purposes.

**Privacy Consideration 10:** There is a risk that an organization’s employees/contractors may use the Generative AI service for unauthorized purposes.

**Mitigation Measure:** The appropriate use of a Generative AI service is ultimately the decision of the individual user, acting in a manner consistent with applicable laws, organizational policies, and their individual job responsibilities. This risk can be partially mitigated by having employees/contractors using the Generative AI service (i) complete training specific to Generative AI, privacy, and security; and (ii) review and agree to follow the organization’s AI Use Policy. This ensures users are informed of permitted uses. Furthermore, having - in the customer’s AI Use policy - a reporting requirement for inappropriate use of a Generative AI service supports the enforcement of that AI policy and permits the organization to be aware of – and deal with – unintended actions or consequences.

**Privacy Consideration 11:** There is a risk that user account and other data disclosed during activities within the Gen AI service - as distinct from inputs - may be used for other purposes by the Generative AI service provider.

**Mitigation Measure:** This risk can be partially mitigated. Generative AI service offerings are governed by their own terms of service and/or privacy policies that indicate how (or if) the services uses data. Some Generative AI service providers may use user data and information obtained when troubleshooting issues to further train their models. If the organization carefully reviews the terms of service/privacy notices, this aspect may be noted in license negotiations prior to approval for the use of the service. The use of troubleshooting-related data can also be presented to employees/contractors in training programs so ensure their awareness of this aspect is present when using such services. Microsoft indicates that it does not use inputs or outputs for LLM training purposes.

**Privacy Consideration 12:** There is a risk that the organization will not appropriately retain any output it uses.

---

<sup>98</sup> “Non-public information” would be defined by the organization but may consist of information such as personal information, social media information, work product, communications, information subject to solicitor-customer privilege, confidential business information, and, for government organizations, information classified beyond a certain level (e.g. beyond protected B for Canadian federal organizations).

**Mitigation Measure:** This risk can be mitigated. Information generated essentially becomes a record that should be subject to the organization’s records retention policy/schedule.

**Privacy Consideration 13:** There is a risk that the organization does not have appropriate accountability and auditing processes in place.

**Mitigation Measure:** This risk can be partially mitigated. While it may not be possible, at this time, to completely audit a Generative AI service, that aspect concerns – primarily – outputs. This creates a need to put a greater emphasis on the control of inputs (i.e. no sensitive/confidential information, no personal information). This can be addressed by requiring strict compliance with an AI Use Policy with serious consequences clearly indicated for any failure to adhere to such a policy.

## H. Privacy Act (Canada)

For those institutions subject to the federal *Privacy Act*<sup>99</sup>, section 4 of that statute requires an institution to have authority to collect personal information. This requirement is independent of Microsoft’s receipt of any personal information and is dependent on either (i) a departmental statute or (ii) a statute authorizing a specific program or service. In the context of the *Privacy Act*, Microsoft – in providing the Azure OpenAI service - can be characterized as a service provider to a federal institution.

Section 4 of the *Privacy Act* requires institutions to not collect personal information indiscriminately, and not collect information unless it relates directly to an operating program or activity. The ultimate purposes for which the information is collected, used, or disclosed do not change as a result of any use of the Azure Open AI service. Federal institutions are required by law to not collect information unless it relates directly to an operating program or activity. In terms of use, the inputs as well as outputs of the Azure Open AI service may contain personal information, but this depends entirely on the decision(s) of the institution and the purpose for which it uses the Azure Open AI service.

Microsoft collects additional information (system data and diagnostic data) independently for specific identified purposes, namely (i) processing to provide customer the products and services and (ii) processing for business operations incidental to those Products and Services. System Data does not contain personal information, but Diagnostic Data may. Aside from System Data, Diagnostic Data and User Data, Microsoft does not independently collect personal information but “hosts” whatever information the customer provides. System Data provides no identifying information; User Data is used for user identification purposes; while Diagnostic Data is pseudo-anonymized and used for the purposes noted above and as further described in Microsoft’s Data Protection Addendum (“DPA”).<sup>100</sup>

Section 8 of the *Privacy Act* provides a list of circumstances where personal information may be disclosed without the consent of the individual. Pursuant to s. 7 of the *Privacy Act*, information may be used for the purposes for which it could be disclosed to the institution under subsection 8(2) of the Act. The *Privacy Act* requires that information under the control of a government institution shall not, without the consent of the individual to whom it relates, be used except for the purpose for which the information was obtained or for a use that is consistent with the purpose of the original collection.

---

<sup>99</sup> RSC 1985, c P-21.

<sup>100</sup> See “Microsoft Products and Services Data Protection Addendum (DPA)”, available at: <https://www.microsoft.com/licensing/docs/view/Microsoft-Products-and-Services-Data-Protection-Addendum-DPA>.

The use of the Azure Open AI does not change the purpose for which such information, originally collected by customers, is used by those customers. Furthermore, the functionality of the Azure Open AI does not change the purpose for which such information is to be used by customers.

A federal public sector organization customer will need to assure itself that access by Microsoft personnel is controlled and limited to authorized purposes and that the security measures to prevent any other unauthorized access is in place. [Annex A](#) describes the extensive security measures that Microsoft has implemented. Customers will also have to consider policies to prohibit or limit the use of personal information as an input. See [Privacy Considerations in the Use of Generative AI](#). See also [Treasury Board Guidance on the Use of AI](#). Many of the issues considered in these sections are applicable with respect to institutional use of the Azure OpenAI service and overlap with *Privacy Act* considerations.

Subsection 9(1) of the *Privacy Act* requires the head of institution to retain a record of any use by the institution of personal information contained in a Personal Information Bank (“PIB”) for any use or purpose for which that information is disclosed, for the use or purposes not included in the statements of the uses and purposes in connection with the relevant information bank. To the extent that there are inconsistent uses, Subsection 9(1) requires the record to be attached to the PIB. This requirement is unrelated to Microsoft and is a customer responsibility.

The retention of the information is as specified in customer PIBs. Federal public sector organizations using Azure Open AI service always remain in the control of their customer information while it is safeguarded in the Microsoft Cloud. Customers can configure retention periods, audit logging, access controls and specialized management roles. As part of service resilience, Microsoft applies additional retention capabilities to safeguard data in the event of customer accident. This includes the maintenance of backup copies for a limited period. Microsoft either securely destroys the customer information upon termination of the service or provides a mechanism for the customer to securely destroy (hard deletion) the data. System Data and Diagnostic Data, distinct from any data created in the form of Azure Open AI outputs, is subject to Microsoft retention periods.

The *Privacy Act* requires the customer to take “all reasonable steps to ensure that personal information is as accurate, up-to-date and complete as possible” to minimize, to the extent possible, the possibility that inappropriate information could be used to make a decision about an individual. If the use of Azure OpenAI involves personal information, then practices to guard against/check for fabrications should be followed.

With the disclosure of personal information to third parties, the customer must comply with the requirements of s. 12 of the *Privacy Act*, in that customer procedures are required to be in place to provide notices of correction to third parties to whom Personal Information has been disclosed. A record is to be kept with respect of requests for a review of errors or omissions and corrections or decisions not to correct. Addressing this requirement remains with the customer and is unrelated to Microsoft or the use of Azure OpenAI.

Federal organizations should consider specific use “AI use” policies to limit the use of personal information in Azure OpenAI. Even if used, it is noted that prompts and responses generally do not leave the Customer’s tenant and are not used by Microsoft for training or the purposes. However, if the use of inputs in Azure OpenAI are flagged for review (i.e., for potential violation of the Code of Conduct) violate

the Code of Conduct both inputs and outputs are subject to review by Microsoft personnel, which may be conducted outside of Canada.

## I. Provincial Public Sector Legislation - FIPPA (Ontario)

In each province of Canada, “public sector” legislation<sup>101</sup>, is intended to prevent the unauthorized collection, use and disclosure of personal information by public institutions. Where the collection of such information is authorized and subsequently collected, these statutes provide individuals with the right to access and correct such information, especially if those institutions use the information to make program or benefit-related decisions concerning the individual. While there are variations between jurisdictions in their public sector legislation, such variations are not great and for the purposes of this FPIA, Ontario’s legislation is used for the purposes of illustrating how the use of Azure OpenAI services by a provincial public sector customer may be considered under such legislation.<sup>102</sup>

Ontario’s *Freedom of Information and Protection of Privacy Act* (“FIPPA”) has two main objectives:

- To establish a general right of access, limited only by specific exemptions and exclusions expressly identified in the Act, to all recorded information in the custody or control of institutions subject to the legislation; and
- To protect the privacy of individuals with respect to personal information about themselves in the custody or under the control of those institutions.

While inputs and outputs, entered and created using the Azure OpenAI service, are within the physical custody of Microsoft, the provincial institution is considered to control such “records” since Microsoft is a service provider to the customer institution and Microsoft access is limited to support and Code of Conduct violations. For the purposes of this assessment, the data elements previously identified as Customer Content Data, are found in “records” considered to be in “in the custody or under the control” of the institution and subject to public sector data protection legislation.

Under Ontario’s FIPPA, personal information is defined as:

*“recorded information about an identifiable individual, including,*

*(a) information relating to the race, national or ethnic origin, colour, religion, age, sex, sexual orientation or marital or family status of the individual,*

*(b) information relating to the education or the medical, psychiatric, psychological, criminal or employment history of the individual or information relating to financial transactions in which*

---

<sup>101</sup> The provincial “public sector” data protection statutes are: *Freedom of Information and Protection of Privacy Act*, RSA 2000, c F-25; *Freedom of Information and Protection of Privacy Act*, RSBC 1996, c 165; *Freedom of Information and Protection of Privacy Act*, CCSM c F175; *Right to Information and Protection of Privacy Act*, SNB 2009, c R-10.6; *Access to Information and Protection of Privacy Act*, SNL 2002, c A-1.1; *Freedom of Information and Protection of Privacy Act*, SNS 1993, c 5; Ontario: *Freedom of Information and Protection of Privacy Act*, RSO. 1990, c F.31; Prince Edward Island: *Freedom of Information and Protection of Privacy Act*, RSPEI. 1988, c F-15.01; *An Act respecting access to documents held by public bodies and the protection of personal information*, RSQ, c A-2.1; *Freedom of Information and Protection of Privacy Act*, SS 1990-91, c F-22.01; *Access to Information and Protection of Privacy Act*, S.N.W.T. 1994, c 20; *Access to Information and Protection of Privacy Act (Nunavut)*, SNWT. 1994, c 20; *Access to Information and Protection of Privacy Act*, RSY 2002, c 1.

<sup>102</sup> While not directly relevant for this FPIA, institutions in Ontario should also consider that Province’s *Principles for Ethical Use of AI [Beta]*, available at: <https://www.ontario.ca/page/principles-ethical-use-ai-beta> and that Province’s Transparency Guidelines available at: <https://github.com/ongov/Transparency-Guidelines>.

*the individual has been involved,*  
*(c) any identifying number, symbol or other particular assigned to the individual,*  
*(d) the address, telephone number, fingerprints or blood type of the individual,*  
*(e) the personal opinions or views of the individual except where they relate to another individual,*  
*(f) correspondence sent to an institution by the individual that is implicitly or explicitly of a private or confidential nature, and replies to that correspondence that would reveal the contents of the original correspondence,*  
*(g) the views or opinions of another individual about the individual, and*  
*(h) the individual's name where it appears with other personal information relating to the individual or where the disclosure of the name would reveal other personal information about the individual;<sup>103</sup>*

In Ontario, personal information does not include (i) information about an individual who has been dead for more than thirty years or (ii) the name, title, contact information or designation of an individual that identifies the individual in a business, professional or official capacity.<sup>104</sup>

The obligations under FIPPA may be considered as falling into seven categories. These categories form the fundamental framework for an institution's FIPPA compliance obligations.

**Collection.** Section 38(2) of FIPPA provides that an institution, or any agent or service provider, cannot collect personal information "unless the collection is expressly authorized by statute, used for the purposes of law enforcement or necessary to the proper administration of a lawfully authorized activity."

Section 39(1)(h) of FIPPA requires that personal information be collected directly by an institution unless "another manner of collection is authorized by or under a statute." This collection-related requirement is a customer/institution responsibility. Microsoft's role in providing the Azure OpenAI service does not involve any direct collection of personal information from an institution's customers/customers. To the extent Microsoft does collect personal information from those employees of the institution who use Azure services (i.e. user ID data or Diagnostic Data), such collection may be considered as "necessary for the administration of... [the] activity".

The nature and volume "Customer Content Data" is determined by the institution as a user of the Azure OpenAI service. Microsoft may access personal information only to the extent that an input is flagged for review. This would occur only to the extent that the institution uses personal information in prompts and if an output produces personal information. See [Privacy Considerations in the Use of Generative AI](#). While not applicable to provincial institutions, the [Treasury Board Guidance on the Use of AI](#) may offer some useful advice to consider.

Section 39(2) of FIPPA requires that the subject individual is to be informed of (i) the legal authority for collection; (ii) the principal purpose for the use of the personal information collected; and (iii) the title and contact information of an official who can answer questions about the collection. This obligation goes to the direct collection of personal information for the institution's program or activity and is a customer responsibility. Provincial institutions may wish to consider the Ontario Transparency

---

<sup>103</sup> RSO 1990, c F.31, s. 2(1)

<sup>104</sup> RSO 1990, c F.31, s. 2(2), 2(3).

Guidelines and, if using personal information – whether to fine tune data or in prompts - may wish to consider amendment of their privacy notices to indicate the use of Generative AI tools and services in connection with their program activities.

Section 44 of FIPPA requires “personal information under the control of the institution that is organized or intended to be retrieved by the individual’s name or by an identifying number, symbol or other particular assigned to the individual” to be included in a personal information bank. Compliance with this requirement is done through inclusion of information within the Directory of Records<sup>105</sup>. This obligation is the responsibility of the institution and does not involve Microsoft.

Diagnostic Data is collected by Microsoft, but it is pseudo-anonymized and limited in nature.

**Use.** Section 41(1) of FIPPA permits the use of personal information for (a) the purpose for which that information was obtained, compiled, or disclosed; (b) a use consistent with that purpose; or (c) with the written consent of the individual. An institution needs to comply with the requirements of s. 41(1) of FIPPA in its use of information collected as part of its program or service activities. In terms of outputs generated in using the Azure OpenAI, much will depend on the use cases for which an institution uses the service.

The DPA, which applies to Azure Open AI services defines Customer Data (referred to in the statement as “Customer Data”) as:

*“Customer Data” means all data, including all text, sound, video, or image files, and software, that are provided to Microsoft by, or on behalf of, Customer through use of the Online Service. Customer Data does not include Professional Services Data.*

To the limited extent it uses Customer Data, Microsoft does identify the purposes for which it “uses” data. “Services” here refers to the Azure OpenAI services:

#### ***Nature of Data Processing; Ownership***

*Microsoft will use and otherwise process Customer Data, Professional Services Data, and Personal Data only as described and subject to the limitations provided below (a) to provide Customer the Products and Services in accordance with Customer’s documented instructions and (b) for business operations incident to providing the Products and Services to Customer. As between the parties, Customer retains all right, title and interest in and to Customer Data and Professional Services Data. Microsoft acquires no rights in Customer Data or Professional Services Data, other than the rights Customer grants to Microsoft in this section. This paragraph does not affect Microsoft’s rights in software or services Microsoft licenses to Customer.*

#### ***Processing to Provide Customer the Products and Services***

*For purposes of this DPA, “to provide” a Product consists of:*

- *Delivering functional capabilities as licensed, configured, and used by Customer and its users, including providing personalized user experiences;*

---

<sup>105</sup> Available at <http://www.ontario.ca/document/directory-records>.

- Troubleshooting (preventing, detecting, and repairing problems); and
- Keeping Products up to date and performant, and enhancing user productivity, reliability, efficacy, quality, and security.

For purposes of this DPA, “to provide” Professional Services consists of:

- Delivering the Professional Services, including providing technical support, professional planning, advice, guidance, data migration, deployment, and solution/software development services.
- Troubleshooting (preventing, detecting, investigating, mitigating, and repairing problems, including Security Incidents and problems identified in the Professional Services or relevant Product(s) during delivery of Professional Services); and
- Enhancing delivery, efficacy, quality, and security of Professional Services and the underlying Product(s) based on issues identified while providing Professional Services, including fixing software defects and otherwise keeping Products and Services up to date and performant.

In each case, providing the Products and Services is conducted in view of security obligations under Data Protection Requirements.

When providing Products and Services, Microsoft will not use or otherwise process Customer Data, Professional Services Data, or Personal Data for: (a) user profiling, (b) advertising or similar commercial purposes, or (c) market research aimed at creating new functionalities, services, or products or any other purpose, unless such use or processing is in accordance with Customer’s documented instructions.

#### **Processing for Business Operations Incident to Providing the Products and Services to Customer**

For purposes of this DPA, “business operations” means the processing operations authorized by customer in this section.

Customer authorizes Microsoft:

- (i.) to create aggregated statistical, non-personal data from data containing pseudonymized identifiers (such as usage logs containing unique, pseudonymized identifiers); and
- (ii.) to calculate statistics related to Customer Data or Professional Services Data in each case without accessing or analyzing the content of Customer Data or Professional Services Data and limited to achieving the purposes below, each as incident to providing the Products and Services to Customer.

Those purposes are:

- billing and account management;
- compensation such as calculating employee commissions and partner incentives;
- internal reporting and business modeling, such as forecasting, revenue, capacity planning, and product strategy; and
- financial reporting.

*When processing for these business operations, Microsoft will apply principles of data minimization and will not use or otherwise process Customer Data, Professional Services Data, or Personal Data for: (a) user profiling, (b) advertising or similar commercial purposes, or (c) any other purpose, other than for the purposes set out in this section. In addition, as with all processing under this DPA, processing for business operations remains subject to Microsoft's confidentiality obligations and commitments under Disclosure of Processed Data.*

"Personal Data" is defined by Microsoft as follows:

*"Personal Data" means any information relating to an identified or identifiable natural person. An identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.*

To the extent that Microsoft uses third parties to provide services, Azure OpenAI users can download lists of subcontractors<sup>106</sup>.

In the DPA, Microsoft states:

#### ***Notice and Controls on use of Subprocessors***

*Microsoft may hire Subprocessors to provide certain limited or ancillary services on its behalf. Customer consents to this engagement and to Microsoft Affiliates as Subprocessors. The above authorizations will constitute Customer's prior written consent to the subcontracting by Microsoft of the processing of Customer Data, Professional Services Data, and Personal Data if such consent is required under the Standard Contractual Clauses or the GDPR Terms.*

*Microsoft is responsible for its Subprocessors' compliance with Microsoft's obligations in this DPA. Microsoft makes available information about Subprocessors on a Microsoft website. When engaging any Subprocessor, Microsoft will ensure via a written contract that the Subprocessor may access and use Customer Data, Professional Services Data, or Personal Data only to deliver the services Microsoft has retained them to provide and is prohibited from using Customer Data, Professional Services Data, or Personal Data for any other purpose. Microsoft will ensure that Subprocessors are bound by written agreements that require them to provide at least the level of data protection required of Microsoft by the DPA, including the limitations on disclosure of Processed Data. Microsoft agrees to oversee the Subprocessors to ensure that these contractual obligations are met.*

*From time to time, Microsoft may engage new Subprocessors. Microsoft will give Customer notice and, as applicable, update the website and provide Customer with a mechanism to obtain notice of that update of any new Subprocessor at least 6 months in advance of providing that Subprocessor with access to Customer Data. Additionally, Microsoft will give Customer notice and, as applicable, update the website and provide Customer with a mechanism to obtain notice of that update of any new Subprocessor at least 30 days in advance of providing that Subprocessor with access to Professional Services Data or Personal Data other than that which is contained in Customer Data. If Microsoft engages a new Subprocessor for a new Product or Professional Service*

---

<sup>106</sup> The list of subprocessors is current to 30 November 2023 and is available at:  
<https://servicetrust.microsoft.com/DocumentPage/badc200c-02ab-43d9-b092-ed9b93b9b4a8>.

*that processes Customer Data, Professional Services Data, or Personal Data, Microsoft will give Customer notice prior to availability of that Product or Professional Service.*

*If Customer does not approve of a new Subprocessor for an Online Service or Professional Services, then Customer may terminate any subscription for the affected Online Service or the applicable Statements of Service for the applicable Professional Service, respectively, without penalty or termination fee by providing, before the end of the relevant notice period, written notice of termination. If Customer does not approve of a new Subprocessor for Software, and Customer cannot reasonably avoid use of the Subprocessor by restricting Microsoft from processing data as set forth in the documentation or this DPA, then Customer may terminate any license for the affected software product without penalty by providing, before the end of the relevant notice period, written notice of termination. Customer may also include an explanation of the grounds for non-approval together with the termination notice, in order to permit Microsoft to re-evaluate any such new Subprocessor based on the applicable concerns. If the affected Product is part of a suite (or similar single purchase of services), then any termination will apply to the entire suite. After termination, Microsoft will remove payment obligations for any subscriptions or other applicable unpaid work for the terminated Products or Services from subsequent invoices to Customer or its reseller.*

Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft Employee Handbook, at the time of hire as a condition for employment. All Microsoft's Online Services contingent staff must also sign a non-disclosure agreement at the time of engagement and before being given access to Microsoft's Online Services

Microsoft requires subprocessors to join the *Microsoft Supplier Security and Privacy Assurance Program*.<sup>107</sup> This program is designed to standardize and strengthen data handling practices, and to ensure supplier business processes and systems are consistent with those of Microsoft.

**Disclosure.** An institution is prohibited from disclosing personal information to third parties (other than service providers) unless such disclosure fits within a permitted exception found in Sections 21 or 41 and 42 (1) of FIPPA and provided such disclosure is consistent with the obligations found in the any applicable legislation. The use of Azure OpenAI does not change this obligation. Microsoft and any associated "sub-contractors" are service providers to the institution.

Microsoft indicates that will not disclose Customer Data outside of Microsoft or its controlled subsidiaries and affiliates except (1) as the customer directs, (2) as described in the Online Product and Service Terms, or (3) as required by law.

Microsoft has indicated that it will not disclose Customer Data to law enforcement authorities unless required by law. The company's position is that if a law enforcement authority contacts Microsoft with a demand for Customer Data or Personal Data, Microsoft will attempt to redirect that law enforcement authority/agency to request that data directly from the customer. If compelled to disclose Customer Data or Personal Data to law enforcement, Microsoft will promptly notify the customer and provide a copy of the demand unless legally prohibited from doing so.

---

<sup>107</sup> Further information is available at: <https://www.microsoft.com/en-us/procurement/supplier-contracting.aspx>.

Upon receipt of any other third-party request for Customer Data (such as requests from a customer's end users), Microsoft's position is that it will promptly notify the customer unless prohibited by law or will attempt to redirect the third party to request the Customer Data from the customer.

Except as the customer directs or unless required by law, Microsoft's policy is not to provide any third party: (1) direct, indirect, blanket or unfettered access to Customer Data; (2) the platform encryption keys used to secure Customer Data or the ability to break such encryption; or (3) any kind of access to Customer Data if Microsoft is aware that such data is used for purposes other than those stated in the request.

As it relates to *Personal Data*, Microsoft indicates in the DPA that they will disclose Personal Data for the following stated purposes:

#### ***Disclosure of Processed Data***

*Microsoft will not disclose or provide access to any Processed Data except: (1) as Customer directs; (2) as described in this DPA; or (3) as required by law. For purposes of this section, "Processed Data" means: (a) Customer Data; (b) Professional Services Data; (c) Personal Data; and (d) any other data processed by Microsoft in connection with the Products and Services that is Customer's confidential information under Customer's agreement. All processing of Processed Data is subject to Microsoft's obligation of confidentiality under Customer's agreement.*

*Microsoft will not disclose or provide access to any Processed Data to law enforcement unless required by law. If law enforcement contacts Microsoft with a demand for Processed Data, Microsoft will attempt to redirect the law enforcement agency to request that data directly from Customer. If compelled to disclose or provide access to any Processed Data to law enforcement, Microsoft will promptly notify Customer and provide a copy of the demand unless legally prohibited from doing so.*

*Upon receipt of any other third-party request for Processed Data, Microsoft will promptly notify Customer unless prohibited by law. Microsoft will reject the request unless required by law to comply. If the request is valid, Microsoft will attempt to redirect the third party to request the data directly from Customer.*

*Microsoft will only disclose or provide access to any Processed Data as required by law provided that the laws and practices respect the essence of the fundamental rights and freedoms and do not exceed what is necessary and proportionate in a democratic society and, as applicable, to safeguard one of the objectives listed in Article 23(1) of GDPR.*

*Microsoft will not provide any third party: (a) direct, indirect, blanket, or unfettered access to Processed Data; (b) platform encryption keys used to secure Processed Data or the ability to break such encryption; or (c) access to Processed Data if Microsoft is aware that the data is to be used for purposes other than those stated in the third party's request.*

*In support of the above, Microsoft may provide Customer's basic contact information to the third party.*

Microsoft indicates that it keeps an accurate accounting of disclosures of information held in each system of records under its control, including the date, nature, and purpose of each disclosure of a record.

Whether an institution discloses either inputs or outputs is governed the requirements of FIPPA and the transparency policy that it follows. See, as an example, *Ontario's Trustworthy Artificial Intelligence (AI) Framework*<sup>108</sup> that attempts to provide guidance for the transparent, responsible, and accountable use of AI by the Ontario government.

**Accuracy.** With respect to the use of the Azure OpenAI, the institution is required to have processes to:

- Determine the accuracy, completeness and timeliness of the personal information held.
- Update the information if requested to do so.
- Establish a frequency period, consistent with operational requirements (i.e. which do not interfere with operations) during which personal information is updated.
- Correct erroneous data.

See [Privacy Considerations in the Use of Generative AI](#) for a discussion of the privacy risks associated with the use of Generative AI. Ensuring the accuracy of personal information used in connection with the Azure OpenAI service is entirely an issue for the institution and depends on both its policy concerning the use of personal information as inputs as well as how rigorous it checks outputs.

With respect to non-Customer Content Data, Microsoft has a process to allow customers to correct or amend inaccurate personal information provided to Microsoft. With respect to the use of Azure OpenAI, such data is limited to user account registration data.

**Retention.** An institution is a public body for the purposes of provincial archival legislation. In Ontario, the applicable legislation is the *Archives and Recordkeeping Act*, 2006<sup>109</sup>. Under s. 11(1) of that statute, an institution is required to “prepare a records schedule that sets out, for each class of public records that they create or receive, the length of time the records will be retained and the disposition of the records at the end of their retention period”.

A records schedule is required to:

- Identify and describe the records or classes of records to which it applies.
- Specify how long the records are to be retained by the public body.
- Specify the form in which the records are to be kept.
- Identify the records or classes of records that are records of archival value.
- Specify the transfer of records of archival value at the end of their retention period to the Archives of Ontario or the continued retention of such records in accordance with an agreement between the Ministry and Archivist of Ontario and contain any other information that may be required by the Archivist. 2006.

Section 5 of FIPPA Regulation 460, made pursuant to authority in FIPPA, requires a minimum one-year retention period for personal information that has been used by an institution unless the individual to

---

<sup>108</sup> Available at: <https://www.ontario.ca/page/ontarios-trustworthy-artificial-intelligence-ai-framework>.

<sup>109</sup> SO 2006, c 34, Sch A.

whom the information relates consents to its earlier disposal.

A Directory of Records for provincial government institutions is available for viewing online.<sup>110</sup> The directory describes the kinds of personal information kept by each provincial government organization.

Since Azure OpenAI data may constitute new types of information – including personal information if it is processed by the service - it is the responsibility of the institution to determine whether its entries in this Directory should be amended because of the use of the Azure OpenAI service.

Customers may apply their data retention policies to output data and should ensure that (i) current retention schedules cover such data or, if not, (ii) establish new retention schedules. With respect to Microsoft service, Customer Data is stored in a redundant environment with robust backup, restore, and failover capabilities to enable availability, business continuity, and rapid recovery. Multiple levels of data redundancy are implemented, ranging from redundant disks to guard against local disk failure to continuous, full data replication to a geographically dispersed datacenter. All Azure services undergo an annual validation of backup/recovery practices.

Microsoft indicates that it wipes storage hard drives using a solution that is compliant with National Institute of Standards & Technology (“NIST”) guidance.<sup>111</sup> For hard drives that cannot be wiped, there is a physical destruction process that destroys them and renders the recovery of information impossible. The appropriate means of disposal is determined by the asset type.

Records of hardware destruction are retained and audited through Microsoft’s ISO process. All Microsoft services utilize approved media storage and disposal management services. To the extent that there may be relevant paper documents kept, such documents are destroyed using approved methods at the pre-determined “end-of-lifecycle”.

**Protection.** The protection of information is not expressly addressed in FIPPA but obligations concerning the security of personal information may be found in its regulations and can be characterized as broad.

Section 4 of the *General Regulation*<sup>112</sup> provides a requirement to put in place reasonable measures to prevent unauthorized access, while the *Disposal of Personal Information Regulation*<sup>113</sup> (“Regulation 459”) requires any disposal of information to be done in such a manner so as to ensure it cannot be reconstructed or retrieved.

See [Annex A](#) for a description of safeguard measures deployed by Microsoft as well as the audit measures used to support Microsoft’s deployed safeguards.

Microsoft provides role-based security training to personnel with assigned security roles and responsibilities. All appropriate Microsoft Staff take part in a security-training program and are recipients of periodic security awareness updates when applicable. All contractors are required to take any training determined to be appropriate to the services they provide and the role(s) they perform.

---

<sup>110</sup> Available at: <http://www.mgs.gov.on.ca/en/infoaccessandprivacy/index.htm>.

<sup>111</sup> See National Institute of Standards & Technology Special Publication 800-88, Guidelines for Media Sanitization.

<sup>112</sup> RRO 1990, Reg 460.

<sup>113</sup> RRO 1990, Reg 459.

All Microsoft staff are required to enrol in a security awareness training course within the first 30 days of their employment or transfer into the organization. Annual “refresher” training is also mandated for Microsoft staff. Non-operational personnel - anyone that is involved in development and quality assurance - are also required to take the mandatory training offered by Online Services Security, as well as training associated with the operating procedures related to asset handling, incident response, and change control. Security training is also required when there is a significant change to the system environment.

**Access & Correction.** Section 47(1) of FIPPA provides an individual with a right of access to information held about that person by an institution. Exceptions exist where there is information related to an investigation, or “third party” information (information provided by another person who may be affected by the release of information).

Section 47(2) of FIPPA provides a right of correction to any individual regarding his or her personal information and allows an individual to request correction of personal information. Where there is disagreement as to a proposed correction or where a correction was requested and not made, a statement of disagreement is to be attached to the information reflecting any correction that was requested but not made. Third parties are to be notified of any correction or statement of disagreement.

With respect to access to personal information held by an institution as well as an individual’s right to correct that information, institutions address such access requests in accordance with FIPPA and government freedom of information procedures. A formal freedom of information request may be made in writing by completing a request form<sup>114</sup> or writing a letter and forwarding the completed request form or letter to the "Freedom of Information and Privacy Coordinator" at the applicable institution.

The use of the Azure OpenAI service will not cause any change in:

- An individual’s right to access and correct personal information held by an institution.
- The way access to personal information may be provided by an institution.
- The medium by which individuals may request access to his or her personal information from an institution.
- The institution’s access procedures.
- How an individual can challenge the accuracy and completeness of their personal information held by an institution.

With respect to non-Customer Content Data, Microsoft has a process to allow customers to correct or amend inaccurate personal information, as appropriate. Information as to how to contact Microsoft is available online and using an online web form. As for Customer Content Data held by Microsoft in connection with the use of the Azure OpenAI, the features and functionality of the services allow customers to remain in control of content stored within the service.

---

<sup>114</sup> The form is available at the Information and Privacy Commissioner’s site: <https://www.ipc.on.ca/images/Resources/up-1request.pdf>.

Whether an institution is obliged to provide access to either inputs or outputs is likely to be decided within the framework of existing laws and the substantive nature of those inputs or outputs (i.e. does a mandatory or discretionary exemption apply to the input or output).

## J. Provincial Health Sector Legislation – PHIPA (Ontario)

One normally considers personal health information held by health information custodians to be processed and stored in electronic health/medical records or in hospital information systems. Generative AI is an emerging technology and health organizations – as well as everyone else – are attempting to determine appropriate use cases. At first glance, healthcare itself; health research, and productivity gains in healthcare business administration are plausible candidates for the use of Generative AI. Accordingly, there is a need to consider the effect of personal health information statutes on the possible combination of personal health information (even if initially de-identified) and Generative AI – in this instance, Azure OpenAI.

While having a focus on health information “custodians” or “trustees”, many of the concepts embodied in personal health sector legislation will be familiar to those with knowledge of Canadian personal information protection legislation. These personal health information laws create a series of obligations for custodians of such information who are required, in turn, to ensure that their service providers, affiliates and information managers also meet certain requirements.

Substantively, except for Alberta, Canadian provincial health information protection legislation is extensively similar in nature. The main difference under Alberta’s law is that it does not require consent so long as the intended collection or use is authorized by legislation<sup>115</sup> but does require it for disclosure<sup>116</sup>. In all other jurisdictions, the collection, use or disclosure of personal health information may occur either with the individual’s consent or as authorized by the applicable statute.

Because of this national “similarity”, for the purposes of this FPIA, Ontario’s *Personal Health Information Protection Act, 2004*<sup>117</sup> (“PHIPA”) is used as the basis of this assessment as is the assessment questionnaire provided by Ontario’s Information and Privacy Commissioner.

Ontario’s PHIPA, in creating a statutory framework for the collection, use and disclosure of personal health information in Ontario, applies to the management and safeguarding of “personal health information” held by a “health information custodian” (“HIC”). A HIC is a person or organization that has custody or control of personal health information because of, or in connection with, the person’s or organization’s powers or duties and is listed in s. 3 of PHIPA. This concept of “custodian” is similarly used in other Canadian jurisdictions.

PHIPA also applies to a certain extent to “agents” of providers, and “health information network providers”. This application to service providers is another concept found in Canadian health privacy legislation (in some provinces, this is characterized as an “information management service provider”).

---

<sup>115</sup> *Health Information Act*, RSA 2000, c H-5, ss 18 and 25.

<sup>116</sup> *Health Information Act*, RSA 2000, c H-5, s 34.

<sup>117</sup> *Personal Health Information Protection Act, 2004*, SO 2004, c. 3, Sch A.

Such a provider is defined as an entity that processes the records of a HIC or that provides information technology services with respect to such records<sup>118</sup>.

Microsoft, as a provider of Azure OpenAI and **to the extent it is used in a manner that involves personal health information** is a not HIC for the purposes of provincial legislation. In the other provinces in which it operates it could be classified as an “information manager”; in Ontario, it could be viewed as a service provider that, because of such status, is subject to s. 10(4) of PHIPA and the associated General Regulation.

The responses provided below apply in the context of Microsoft being a service provider hosting and processing Customer Data within its data centers. The use of the Azure OpenAI service does not change this aspect. As can be seen in [Privacy Authorities’ Guidance on the Responsible Use of AI](#) above, most AI-related requirements fall on the institution.

### Service Provider Requirements

| Service Provider Requirements – PHIPA s. 10(4) |                                                                                                                                                                                                                                               |                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Citation                                       | Requirement                                                                                                                                                                                                                                   | Comment                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| General, O Reg 329/04, s. 6(1) #1              | “The person shall not use any personal health information to which it has access in the course of providing the services for the health information custodian except as necessary in the course of providing the services.”                   | Aside from possible access for support purposes and to check for a Code of Conduct violation when inputs are flagged for follow-up, Microsoft does not use any Customer Content Data.                                                                                                                                                                                                                                                                               |
| General, O Reg 329/04, s. 6(1) #2              | “The person shall not disclose any personal health information to which it has access in the course of providing the services for the health information custodian.”                                                                          | Microsoft does not disclose the Customer Content Data to third parties unless authorized or required by law. Requests for access will be referred to the HIC.                                                                                                                                                                                                                                                                                                       |
| General, O Reg 329/04, s. 6(1) #3              | “The person shall not permit its employees or any person acting on its behalf to be able to have access to the information unless the employee or person acting on its behalf agrees to comply with the restrictions that apply to the person | Policies and procedures enforce access controls on a “least privilege” basis for operational systems and Customer Data (See Access and Lockbox discussions in <a href="#">Annex A</a> ). Access to personal information is restricted to supporting and operating the Azure OpenAI service or to check for possible Code of Conduct violations.<br><br>Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft |

<sup>118</sup> See, for example, *Health Information Act*, RSA 2000, c H-5, s 66(1); *Personal Health Information Act*, CCSM, c. P33.5, s 1(1); *Personal Health Information Privacy and Access Act*, SNB 2009, c P-7.05, s 1; *Personal Health Information Act*, SNL 2008, c P-7.01, s. 2(1)(l); *Health Information Protection Act*, SS 1999, c H-0.021, s. 2(j); and *Personal Health Information Act*, SNS 2010, c 41, ss. 24, 28; *Health Information Act*, SNWT 2014, c 2, s 13; and *Health Information Privacy And Management Act*, SY 2013, c 16.

|  |                                     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|--|-------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | who is subject to this subsection.” | <p>Employee Handbook, at the time of hire as a condition for employment. All Microsoft’s Online Services contingent staff must also sign a non-disclosure agreement at the time of engagement and before being given access to Microsoft’s Online Services.</p> <p>Microsoft requires their subprocessors to join the <i>Microsoft Supplier Security and Privacy Assurance Program (“SSPA”)</i>. This program is designed to standardize and strengthen data handling practices, and to ensure supplier business processes and systems are consistent with those of Microsoft.</p> <p>The SSPA is in place to deliver Microsoft’s data processing instructions to their suppliers in the form of Microsoft’s Data Protection Requirements.</p> |
|--|-------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

The table below addresses questions raised in Parts A and B of the Ontario Information and Privacy Commissioner’s *PHIPA Privacy Impact Assessment Questionnaire*. The questions in Part A relate to privacy management and the responses are limited to the measures implemented by Microsoft; the questions in Part B relate specifically to the Azure OpenAI service.

#### Part A: Organizational Privacy Management

| No. | Question                                                                                                 | Yes | No | Comment                                                                                                                                                                                                                                                                                                                                                                            |
|-----|----------------------------------------------------------------------------------------------------------|-----|----|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A1  | Is there an organizational strategic plan or business plan that addresses privacy protection?            | X   |    | Microsoft has a mature privacy and security program, with an identified management and governance framework for both privacy and information security. Both privacy and security are addressed in a series of comprehensive policy documents.                                                                                                                                      |
| A2  | Does your organization have a written privacy policy or statement of information practices?              | X   |    | <p>Compliance with this requirement is a customer responsibility.</p> <p>In terms of Microsoft providing notice to end users, Microsoft provides a Privacy Statement<sup>119</sup> in which it defines what constitutes Customer Data and the purposes for which it uses such data. See also the Data Protection Addendum referred to in the Online Product and Service Terms.</p> |
| A3  | Have privacy policies or procedures been developed for various aspects of the organization’s operations? | X   |    | See Response A2.                                                                                                                                                                                                                                                                                                                                                                   |
| A4  | Do the privacy policies or procedures that you identified in response to questions A2 and A3             |     |    |                                                                                                                                                                                                                                                                                                                                                                                    |

<sup>119</sup> Available at: <https://privacy.microsoft.com/en-US/privacystatement>.

| No. | Question                                                                                                                                                                                                                                                                                           | Yes | No | Comment                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|-----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|     | ensure the following:                                                                                                                                                                                                                                                                              |     |    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| A4a | Personal health information is collected in accordance with PHIPA and other applicable legislation.                                                                                                                                                                                                | X   |    | The collection of personal health information is the responsibility of the HIC.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| A4b | Individual consent is obtained in accordance with section 18 of PHIPA where consent is required                                                                                                                                                                                                    | X   |    | Responsibility for obtaining consent rests with the HIC. Microsoft serves as a service provider or information manager to those HICs.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| A4c | A written public statement about the organization's information practices, who to contact with privacy questions or complaints, and how to obtain access or request correction of a record of personal health information is readily available to individuals, as outlined in section 16 of PHIPA. |     | X  | <p>The HIC, as collector of PHI, has the obligation to inform the individual as to the provider's privacy practices. Requests for access or correction are referred to the HIC.</p> <p>In terms of Microsoft providing notice to end users, Microsoft provides a Privacy Statement<sup>120</sup> in which it defines what constitutes Personal Data and the purposes for which it uses such data. See also the Data Protection Addendum referred to in the Online Product and Service Terms.</p> <p>Microsoft's Privacy Trust Centre provides information as to what constitutes Customer Data, how it is safeguarded, and who has access to it.</p> |
| A4d | Individuals are entitled to request access to and correction of their own personal health information as provided for under sections 52-55 of PHIPA, subject to exceptions.                                                                                                                        | X   |    | See Response A4c. Microsoft is a service provider/information manager to the HIC.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| A4e | There is a record retention schedule for records of personal health information that outlines the minimum and maximum lengths of time personal health information may be retained as well as procedures outlining the manner by which personal health information will be securely destroyed       |     | X  | <p>Record retention is the HIC's responsibility and subject to the HIC's own record retention policies. The Azure OpenAI service allows customers to apply their own data retention policies by maintaining the data until such time as the customer disposes of the information.</p> <p>Microsoft indicates that it wipes storage hard drives using a solution that is compliant with NIST 800-88<sup>121</sup>. For hard drives that cannot be wiped, there is a</p>                                                                                                                                                                               |

<sup>120</sup> Available at: <https://privacy.microsoft.com/en-US/privacystatement>.

<sup>121</sup> National Institute of Standards & Technology Special Publication 800-88, Guidelines for Media Sanitization.

| No. | Question                                                                                                                                                                                                                                                          | Yes | No | Comment                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|-----|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|     |                                                                                                                                                                                                                                                                   |     |    | physical destruction process that renders the recovery of information impossible. The appropriate means of disposal is determined by the asset type.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| A5  | Are administrative, technical and physical safeguards in place at the organization to protect personal health information against theft, loss, unauthorized use or disclosure and unauthorized copying, modification or disposal pursuant to section 12 of PHIPA? | X   |    | See <a href="#">Annex A</a> for a description of safeguard measures deployed by Microsoft as well as the audit measures used to support the deployed safeguards.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| A6  | Is there an appointed privacy contact person in the organization?                                                                                                                                                                                                 | X   |    | Compliance with this requirement is a customer responsibility.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| A7  | Does a reporting process exist to ensure that the organization's management is informed of any privacy compliance issues?                                                                                                                                         | X   |    | See <a href="#">Annex A</a> for a description of safeguard measures deployed by Microsoft.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| A8  | Are senior executives actively involved in the development, implementation and/or promotion of your organization's privacy program?                                                                                                                               | X   |    | Compliance with this requirement is a customer responsibility.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| A9  | Are employees or agents with access to personal health information in your organization provided training related to privacy protection?                                                                                                                          | X   |    | <p>Policies and procedures enforce access controls on a "least privilege" basis for operational systems and Customer Data (See Access and Lockbox discussions in <a href="#">Annex A</a>). Access to personal information is restricted to supporting and operating the Azure OpenAI services.</p> <p>Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft Employee Handbook, at the time of hire as a condition for employment. All Microsoft's staff must also sign a non-disclosure agreement at the time of engagement and before being given access to Microsoft service offerings.</p> <p>Microsoft requires their subprocessors to join the <i>Microsoft Supplier Security and</i></p> |

| No. | Question                                                                                                                                                                                                              | Yes | No | Comment                                                                                                                                                                                                         |
|-----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|     |                                                                                                                                                                                                                       |     |    | <i>Privacy Assurance Program.</i> This program is designed to standardize and strengthen data handling practices, and to ensure supplier business processes and systems are consistent with those of Microsoft. |
| A10 | Have policies and procedures been developed concerning the management of privacy breaches, including the notification of individuals when the confidentiality of their personal health information has been breached? | X   |    | See <a href="#">Annex A</a> for a description of safeguard measures deployed by Microsoft.                                                                                                                      |

### Part B: Project Privacy Management

| No. | Question                                                                                                                                                                                                                                                                                   | Yes | No | Comment                                                                                                                                                                                                                                                         |
|-----|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| B1  | Has a summary of the proposed or existing information system, technology or program been prepared, including a description of the requirements for the system, technology or program and a description of how the information system, technology or program will or does meet those needs? | X   |    | Compliance with this requirement is a customer responsibility. However, Microsoft has extensive documentation online describing the functionality of Azure OpenAI services, including a transparency statement.                                                 |
| B2  | Has a listing of all Personal Health Information or data elements that will be or are collected, used or disclosed in the proposed or existing information system, technology or program been prepared?                                                                                    | X   |    | This question assumes that personal health information is entered into the Azure OpenAI service. To the extent it may occur, such data elements would involve unstructured data.                                                                                |
| B3  | Have diagrams been prepared depicting the flow of Personal Health Information in the proposed or existing information system, technology or program?                                                                                                                                       |     | X  | Not applicable. Azure OpenAI is not designed for the direct collection or use of personal health information.                                                                                                                                                   |
| B4  | Have documents been prepared showing which persons, positions or employee categories will have access to which elements or records of Personal Health Information?                                                                                                                         | X   |    | Policies and procedures enforce access controls on a “least privilege” basis for operational systems and Customer Data (See Access and Lockbox discussions in <a href="#">Annex A</a> ). Access to personal information by Microsoft personnel is restricted to |

|    |                                                                                                                                                                                                                                                     |   |   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---|---|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                                                                                                                                                                                                                     |   |   | operating and supporting customer use of the Azure OpenAI service.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| B5 | Does consent from the individual or an authorized substitute decision-maker provide the primary basis for the collection, use and disclosure of Personal Health Information for the proposed or existing information system, technology or program? | X |   | Compliance with this requirement is a customer responsibility. Microsoft serves as either a “service provider” or an “information manager” to HICs.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| B6 | Have you documented the purposes for which Personal Health Information will be or is collected, used or disclosed in the information system, technology or program?                                                                                 | X |   | <p>Compliance with this requirement is a customer responsibility.</p> <p>Microsoft states in the DPA that Customer Data (as defined in the DPA) will be used only to provide the customer with the Microsoft Online Services, including purposes compatible with providing those services. Microsoft’s terms of use also permit checking to see if Code of Conduct violations have occurred if inputs or outputs are flagged by an automated system.</p> <p>Microsoft personnel will not process Customer Data without authorization from Customer. Microsoft will not use Customer Data or derive information from it for any advertising or similar commercial purposes.</p> |
| B7 | Is Personal Health Information collected, used, disclosed or retained exclusively for the identified purposes and for purposes that an individual would reasonably consider consistent with those purposes?                                         | X |   | See Response B6.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| B8 | Will Personal Health Information in the proposed or existing information system, technology or program be linked or cross-referenced to other information in other information systems technologies or programs?                                    |   | X | <p>Compliance with this requirement is a customer responsibility.</p> <p>The Azure OpenAI service does not have any interface with private and public information systems, which permit the exchange of information, including personal health information.</p>                                                                                                                                                                                                                                                                                                                                                                                                                |
| B9 | Will Personal Health Information collected or used in the information system,                                                                                                                                                                       | X |   | Policies and procedures enforce access controls on a “least privilege” basis for operational systems and Customer Data                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

|     |                                                                                                                                                                                                                     |   |   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|-----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---|---|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|     | technology or program be disclosed to any persons who are not employees or agents of the responsible organization?                                                                                                  |   |   | <p>(See Access and Lockbox discussions in <a href="#">Annex A</a>). Access to personal information is restricted to supporting and operating the Azure OpenAI service and for checks in the event of a suspected Code of Conduct violation.</p> <p>Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft Employee Handbook, at the time of hire as a condition for employment. All Microsoft's staff must also sign a non-disclosure agreement at the time of engagement and before being given access to Microsoft's services.</p> <p>Microsoft requires their subprocessors to join the <i>Microsoft Supplier Security and Privacy Assurance Program</i>. This program is designed to standardize and strengthen data handling practices, and to ensure supplier business processes and systems are consistent with those of Microsoft.</p> |
| B10 | Have you made arrangements to provide full disclosure of all purposes for which the information system, technology or program will collect Personal Health Information?                                             |   | X | <p>Compliance with this requirement is a customer responsibility.</p> <p>Microsoft does state in the DPA that Customer Data (as defined in the DPA) will be used only to provide the customer with the Azure OpenAI, including purposes compatible with providing those services. Unless there is a violation of the Code of Conduct, Microsoft personnel will not process Customer Data without authorization from Customer. Microsoft, however, even in that instance, will not use Customer Data or derive information from it for any advertising or similar commercial purposes.</p>                                                                                                                                                                                                                                                                                                            |
| B11 | Have communications products and/or a communications plan been developed to fully explain the information system, technology or program to individuals and how their Personal Health Information will be protected? | X |   | <p>Compliance with this requirement is a customer responsibility.</p> <p>In terms of Microsoft providing notice to end users, Microsoft provides a Privacy Statement<sup>122</sup> in which it defines what constitutes Customer Data and the purposes for which it uses such data.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |

<sup>122</sup> Available at: <https://privacy.microsoft.com/en-US/privacystatement>.

|     |                                                                                                                                                                                                                                                                                                                                                             |   |   |                                                                                                                                                                                                                               |
|-----|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---|---|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| B12 | Does the proposed or existing information system, technology or program involve the collection, use or disclosure of any Personal Health Information beyond Ontario's borders?                                                                                                                                                                              |   | X | Customer Content Data held by Microsoft in connection with Azure OpenAI service will be stored in Canada.                                                                                                                     |
| B13 | Has an assessment been completed to identify potential risks to the privacy of individuals whose Personal Health Information is collected, used, retained or disclosed by the proposed or existing information system, technology or program?                                                                                                               | X |   | Compliance with this requirement is a customer responsibility.<br><br>This document is intended to support customer privacy assessments.                                                                                      |
| B14 | If potential risks to privacy have been identified, have means to avert or mitigate those risks been incorporated into the design and/or implementation of the proposed or existing information system, technology or program?                                                                                                                              | X |   | Application, network, and physical security measures have been implemented. A security incident management protocol exists.<br><br>See <a href="#">Annex A</a> for a description of safeguard measures deployed by Microsoft. |
| B15 | Has an assessment been completed to identify whether other health information custodians have implemented the same or a similar information system, technology or program, the risks to privacy experienced by other health information custodians and the means implemented by these other health information custodians to avert or mitigate these risks? |   | X | Compliance with this requirement is a customer responsibility.                                                                                                                                                                |
| B16 | Have key stakeholders been provided with an opportunity to comment on the sufficiency of privacy protections and their implications on the proposed or existing information system, technology or program?                                                                                                                                                  |   | X | Compliance with this requirement is a customer responsibility.                                                                                                                                                                |
| B17 | Will users be trained in the requirements for protecting Personal Health Information and will they be made aware of                                                                                                                                                                                                                                         | X |   | Compliance with this requirement is a customer responsibility.                                                                                                                                                                |

|      |                                                                                                                                                                                                                                                                    |   |   |                                                                                                                                                                                                                                                                                                                                     |
|------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---|---|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|      | the relevant notification procedures if Personal Health Information is stolen, lost or accessed by unauthorized persons?                                                                                                                                           |   |   | Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft Employee Handbook, at the time of hire as a condition for employment. All Microsoft's staff must also sign a non-disclosure agreement at the time of engagement and before being given access to Microsoft's services. |
| B18  | Have security policies and procedures to protect Personal Health Information against theft, loss, unauthorized use or disclosure and unauthorized copying, modification or disposal been documented?                                                               | X |   | See <a href="#">Annex B</a> for a description of safeguard measures deployed by Microsoft.                                                                                                                                                                                                                                          |
| B19  | Have privacy policies or procedures been developed for various aspects of the operations for the proposed or existing information system, technology or program?                                                                                                   | X |   | Compliance with this requirement is a customer responsibility.<br><br>In terms of Microsoft providing notice to end users, Microsoft provides a Privacy Statement <sup>123</sup> in which it defines what constitutes Customer Data and the purposes for which it uses such data.                                                   |
| B20  | Do the privacy policies or procedures that you identified in question B19 ensure the following:                                                                                                                                                                    |   |   |                                                                                                                                                                                                                                                                                                                                     |
| B20a | Personal Health Information in the proposed or existing information system, technology or program is collected in accordance with <i>PHIPA</i> and other applicable legislation;                                                                                   | X |   | Compliance with this requirement is a customer responsibility.                                                                                                                                                                                                                                                                      |
| B20b | Individual consent is obtained in accordance with section 18 of <i>PHIPA</i> for the proposed or existing information system, technology or program where consent is required;                                                                                     |   | X | Obtaining consent is the responsibility of the HIC.                                                                                                                                                                                                                                                                                 |
| B20c | A written public statement about the purposes for which the proposed or existing information system, technology or program collects, uses or discloses Personal Health Information is readily available to individuals as outlined in section 16 of <i>PHIPA</i> ; | X |   | Compliance with this requirement is a customer responsibility.<br><br>Microsoft states in the DPA that Customer Data (as defined in the DPA) will be used only to provide the customer with the Azure OpenAI, including purposes compatible with providing those services.                                                          |

<sup>123</sup> Available at: <https://privacy.microsoft.com/en-US/privacystatement>.

|      |                                                                                                                                                                                                                                                                                                                                                                                                                                           |   |   |                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---|---|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|      |                                                                                                                                                                                                                                                                                                                                                                                                                                           |   |   | <p>Microsoft has extensive documentation online describing the functionality of the Azure OpenAI service, including a transparency statement.</p> <p>Unless in connection with a violation of the Code of Conduct, Microsoft personnel will not process Customer Data without authorization from Customer.</p> <p>Microsoft will not use Customer Data or derive information from it for any advertising or similar commercial purposes.</p> |
| B20d | Individuals are entitled to request access to and correction of their own Personal Health Information in the proposed or existing information system, technology or program as provided for under sections 52-55 of <i>PHIPA</i> , subject to certain exceptions;                                                                                                                                                                         | X |   | In the event such a request is received, individuals are directed to the HIC for any access or correction requests.                                                                                                                                                                                                                                                                                                                          |
| B20e | There is a record retention schedule for records of Personal Health Information that outlines the minimum and maximum lengths of time Personal Health Information may be retained in the proposed or existing information system, technology or program, as well as procedures outlining the manner by which Personal Health Information in the proposed or existing information system, technology or program may be securely destroyed. |   | X | <p>This obligation falls upon the HIC in that decisions about record retention are made by the HIC.</p> <p>Microsoft has established retention periods for backup storage. Microsoft also has secure disposal procedures for storage media.</p>                                                                                                                                                                                              |
| B21  | Does the proposed or existing information system, technology or program provide functionality for the logging of the insertion, access, modification or disclosure of Personal Health Information as well as an interface to audit                                                                                                                                                                                                        | X |   | See <a href="#">Annex A</a> for a description of safeguard measures deployed by Microsoft as well as the audit measures to support the deployed safeguards.                                                                                                                                                                                                                                                                                  |

|  |                                         |  |  |  |
|--|-----------------------------------------|--|--|--|
|  | those logs for unauthorized activities? |  |  |  |
|--|-----------------------------------------|--|--|--|

## K. Necessity and Proportionality Test (Federal Institutions)

For public sector organizations subject to the jurisdiction of the federal Privacy Commissioner, the OPC takes the position that there is a connection between privacy and the *Charter of Rights and Freedoms*. This is, in part, because the Supreme Court of Canada has recognized that privacy interests have protection under the Charter and that the *Privacy Act* has quasi-constitutional status.<sup>124</sup>

Because of this interpretation, the OPC uses an additional four-part test to assess the impact of initiatives on the privacy of the subject individual(s). This four-part test, originally articulated by the Supreme Court of Canada in the 1986 decision of *R. v. Oakes*<sup>125</sup>, is used as a framework for determining reasonable limitations on rights and freedoms in a free and democratic society. The OPC has adapted this test for privacy purposes to determine whether the intrusion on privacy of a federal initiative is proportional to the benefit. This concept also appears in the AI guidance provided by Canadian privacy authorities: See [Privacy Authorities' Guidance on the Responsible Use of AI](#).

For federal initiatives that concern privacy-invasive technologies (e.g., the use of SIN; the collection of evidence and investigation processes; the use of medical records); the program or initiative should demonstrate that:

- Its activities are necessary to achieve a specific and legitimate purpose.
- It is likely to be effective in achieving that purpose.
- The intrusion on privacy is proportional to the benefit to be derived.
- This course of action, among all others, is the least privacy-invasive to achieve the desired results.

**Necessity.** *Is the measure demonstrably necessary to meet a specific need? The rationale should be clear and specific.*

Since the “measure” is the use of the Azure OpenAI service, the question can be characterized as whether there is a rational connection between what information is sought and why. In this context, what will be important to make this determination will be (i) the “use case” for the use of a Generative AI service; (ii) whether personal information is used an input, and (iii) whether personal information is generated as an output.

Microsoft uses System Data and Diagnostic Data to maintain and improve the Azure OpenAI service and there is a rational connection between the data collected by Microsoft and the need for the data.

**Effectiveness.** *Will the program or initiative be effective in meeting the need?*

<sup>124</sup> The legal framework for this position can be found in *Dagg v. Canada (Minister of Finance)* [1997] 2 SCR 403; *Canada (Information Commissioner) v. Canada (Commissioner of the Royal Canadian Mounted Police)* [2003] 1 SCR 66; *Lavigne v Canada (Office of the Commissioner of Official Languages)* [2002] 2 SCR 773, and *H.J. Heinz Co. of Canada v. Canada (Attorney General)* [2006] 1 SCR 441.

<sup>125</sup> [1986] 1 SCR 103.

In part, an “effectiveness” analysis will need answers to the same questions as the “necessity” analysis. Here, there will likely be an emphasis on the “why” – the use case for using any Generative AI service. Personal information, with respect to institutional users of the Azure OpenAI service, is only collected for the purposes of user authentication and to a certain extent (with respect to Diagnostic Data) to maintain and improve the service. Any personal information used by customers of Microsoft as inputs (and received as outputs) would be considered Customer Content Data and not under the control of Microsoft.

**Proportionality.** *Is the loss of privacy proportional to the need?*

While identification/authorization occurs, there is little loss of privacy in the use of productivity and collaborative software. System Data and Diagnostic Data are either anonymized or pseudo-anonymized. Customer Content Data is not accessible by Microsoft personnel except in limited support circumstances or in the event of a suspected Code of Conduct violation. Whether personal information is used as inputs will likely be significant to determine whether any loss of privacy occurs or, alternatively, is proportional to the need.

**Minimal Intrusiveness.** *Is there a less privacy-invasive way of achieving the same end?*

Institutions are to show how the collection, use and disclosure of personal information are undertaken in the least privacy invasive manner possible and requires consideration of alternatives if they exist. The “privacy invasiveness” will be contextual and will depend on the amount of personal information collected by Microsoft’s customers and used through their use of the Azure OpenAI service.

Information being collected from institutional employees for authentication purposes will not change insofar as the types of information and purpose is related to the authentication that already occurs within Entra ID Directory (formerly named Azure Active Directory). Diagnostic Data is pseudo-anonymized and is limited in nature.

With respect to the use of personal information as inputs – which affects the generation of outputs, the degree to which a customer uses personal information will be important. Whether “intrusiveness” can be minimized will depend on the customer use case. A “less privacy-invasive” way to consider in the use of the Azure OpenAI service would be to:

- Minimize or eliminate the use of personal information as inputs.
- Review outputs for the presence of personal information (in the event the LLM can discern identities from de-identified or anonymized information).
- If personal information is used as an input, consider the use of differential privacy to add “noise” to possible outputs.

## L. Private Sector Legislation – CSA Code

For private sector organizations, a privacy analysis can be conducted using the ten fair information practice principles of the Canadian Standards Association *Model Code for the Protection of Personal*

*Information* (“Code”)<sup>126</sup>. While new federal legislation is under consideration<sup>127</sup> the concepts embodied in the Code are retained in the proposed statute and effectively moved directly into legislative provisions as opposed to the Code forming a schedule to the legislation as was done in the case of PIPEDA. These principles inform not only the current and proposed federal private sector legislation but also those statutes found in British Columbia<sup>128</sup>, Alberta<sup>129</sup> and Manitoba<sup>130</sup>. Québec’s private sector legislation is discussed in a separate section below. Any analysis using the Code is modified where there are specific statutory requirements or deviations from the Code.

The Code principles are:

- Accountability
- Identifying Purpose
- Consent
- Limiting Collection
- Limiting Use, Disclosure and Retention
- Accuracy
- Safeguards
- Openness
- Access
- Challenging Compliance

**Accountability.** Under the Code, an organization is responsible for personal information under its control. At a minimum, such responsibility requires the designation of one or more individuals to be accountable for the organization’s compliance with the principles described in the Code. This accountability extends to information that has been transferred to a third party for processing and obliges the organization to use contractual or other means to provide a comparable level of protection while the information is being processed by that third party.

Meeting these expectations requires evidence of a mature administrative structure not only for privacy but also AI Governance. This includes having risks accepted at an appropriate senior level; documenting procedures; ensuring appropriate training is conducted and refreshed regularly; including privacy protective language in all contracts with third parties handling providing AI services; and ensuring that that privacy compliance audits are undertaken on a regular basis.

Microsoft may be characterized as a service provider to a private sector customer in the provision of Azure OpenAI services. Because of this role, the primary responsibility for legal/privacy compliance with

---

<sup>126</sup> The text of the CSA Code forms Schedule 1 to PIPEDA and is available at: [http://www.canlii.org/en/ca/laws/stat/sc-2000-c-5/latest/sc-2000-c-5.html#SCHEDULE\\_1\\_121957](http://www.canlii.org/en/ca/laws/stat/sc-2000-c-5/latest/sc-2000-c-5.html#SCHEDULE_1_121957).

<sup>127</sup> See Bill C-27, *An Act to enact the Consumer Privacy Protection Act, the Personal Information and Data Protection Tribunal Act and the Artificial Intelligence and Data Act and to make consequential and related amendments to other Acts*.

<sup>128</sup> *Personal Information Protection Act*, SBC 2003, c 63, available at: <https://www.canlii.org/en/bc/laws/stat/sbc-2003-c-63/latest/sbc-2003-c-63.html>.

<sup>129</sup> *Personal Information Protection Act*, SA 2003, c P-6.5, available at: <http://www.canlii.org/en/ab/laws/stat/sa-2003-c-p-6.5/latest/sa-2003-c-p-6.5.htm>.

<sup>130</sup> *The Personal Information Protection and Identity Theft Prevention Act*, CCSM c P33.7, available at: <http://www.canlii.org/en/mb/laws/stat/ccsm-c-p33.7/latest/ccsm-c-p33.7.html>. As of the date of this assessment, this legislation is not yet in force.

the Code lies with the customers who use the service. To the extent that Microsoft directly collects personal information, it is accountable for such information.

Generally, a customer's privacy and access framework is (or should be) designed to provide internal policies, procedures, and an administrative structure to comply with its legal requirements. Customers must determine how the information it uses - including with the use of Azure OpenAI services - will nestle within their own information management regime. Most of this regime should already be established since the information collection, use and disclosure activities involving customer content data are independent of the functionality of Azure OpenAI.

Satisfying the accountability principle vis-à-vis Microsoft in connection with the use of the Azure OpenAI service means having an agreement with Microsoft adequately addressing privacy and security requirements and identifying who is accountable for "relations" with Microsoft for service management. ***Of note, is the fact that the customer will be obliged to adhere to a Code of Conduct with respect to its use of the Azure OpenAI service.***

Usually, data residency is raised as a possible accountability issue in the use of service providers and, generally notice of location of data is expected in customer privacy statements/policies. In this instance, Customer Content Data remains within Canada except in an instance where inputs have been flagged as being in contravention of the Code of Conduct. If this occurs the inputs and outputs will be subject to human review, which may occur outside of Canada. This may constitute a "no" or "low" probability privacy risk, especially if personal information is not used in inputs. However, the risk level will ultimately depend on the use case.

To the extent that Microsoft makes use of third parties in connection with the Azure OpenAI, Microsoft customers can download lists of subcontractors<sup>131</sup>. With respect to subprocessors, Microsoft's DPA states:

#### ***Notice and Controls on use of Subprocessors***

*Microsoft may hire Subprocessors to provide certain limited or ancillary services on its behalf. Customer consents to this engagement and to Microsoft Affiliates as Subprocessors. The above authorizations will constitute Customer's prior written consent to the subcontracting by Microsoft of the processing of Customer Data, Professional Services Data, and Personal Data if such consent is required under the Standard Contractual Clauses or the GDPR Terms.*

*Microsoft is responsible for its Subprocessors' compliance with Microsoft's obligations in this DPA. Microsoft makes available information about Subprocessors on a Microsoft website. When engaging any Subprocessor, Microsoft will ensure via a written contract that the Subprocessor may access and use Customer Data, Professional Services Data, or Personal Data only to deliver the services Microsoft has retained them to provide and is prohibited from using Customer Data, Professional Services Data, or Personal Data for any other purpose. Microsoft will ensure that Subprocessors are bound by written agreements that require them to provide at least the level of data protection required of Microsoft by the DPA, including the limitations on disclosure of*

---

<sup>131</sup> The list of subprocessors is current to 30 November 2023 and is available at: <https://servicetrust.microsoft.com/DocumentPage/badc200c-02ab-43d9-b092-ed9b93b9b4a8>.

*Processed Data. Microsoft agrees to oversee the Subprocessors to ensure that these contractual obligations are met.*

*From time to time, Microsoft may engage new Subprocessors. Microsoft will give Customer notice and, as applicable, update the website and provide Customer with a mechanism to obtain notice of that update of any new Subprocessor at least 6 months in advance of providing that Subprocessor with access to Customer Data. Additionally, Microsoft will give Customer notice and, as applicable, update the website and provide Customer with a mechanism to obtain notice of that update of any new Subprocessor at least 30 days in advance of providing that Subprocessor with access to Professional Services Data or Personal Data other than that which is contained in Customer Data. If Microsoft engages a new Subprocessor for a new Product or Professional Service that processes Customer Data, Professional Services Data, or Personal Data, Microsoft will give Customer notice prior to availability of that Product or Professional Service.*

*If Customer does not approve of a new Subprocessor for an Online Service or Professional Services, then Customer may terminate any subscription for the affected Online Service or the applicable Statements of Service for the applicable Professional Service, respectively, without penalty or termination fee by providing, before the end of the relevant notice period, written notice of termination. If Customer does not approve of a new Subprocessor for Software, and Customer cannot reasonably avoid use of the Subprocessor by restricting Microsoft from processing data as set forth in the documentation or this DPA, then Customer may terminate any license for the affected software product without penalty by providing, before the end of the relevant notice period, written notice of termination. Customer may also include an explanation of the grounds for non-approval together with the termination notice, in order to permit Microsoft to re-evaluate any such new Subprocessor based on the applicable concerns. If the affected Product is part of a suite (or similar single purchase of services), then any termination will apply to the entire suite. After termination, Microsoft will remove payment obligations for any subscriptions or other applicable unpaid work for the terminated Products or Services from subsequent invoices to Customer or its reseller.*

Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft Employee Handbook, at the time of hire as a condition for employment. All Microsoft's Online Services contingent staff must also sign a non-disclosure agreement at the time of engagement and before being given access to Microsoft's Online Services

Microsoft requires their subprocessors to join the *Microsoft Supplier Security and Privacy Assurance Program*<sup>132</sup>. This program is designed to standardize and strengthen data handling practices, and to ensure supplier business processes and systems are consistent with those of Microsoft.

**Identifying Purpose.** To the extent personal information is collected, the purposes are to be identified by the organization at or before the time the information is collected. This requirement is like the one found under Ontario's FIPPA. The collection of personal information for permitted purposes is a customer responsibility since Microsoft has no role in the collection of Customer Content Data. Customers should indicate to their employees that User Data and Diagnostic Data will be collected by Microsoft and that Microsoft will use such data for the purposes referred to below.

---

<sup>132</sup> Further information is available at: <https://www.microsoft.com/en-us/procurement/supplier-contracting.aspx>.

The DPA, which applies to Azure OpenAI service defines Customer Data (referred to in the statement as “Customer Data”) as:

*“Customer Data” means all data, including all text, sound, video, or image files, and software, that are provided to Microsoft by, or on behalf of, Customer through use of the Online Service. Customer Data does not include Professional Services Data.*

“Personal Data” is defined by Microsoft as follows:

*“Personal Data” means any information relating to an identified or identifiable natural person. An identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.*

To the limited extent it uses Customer Data, Microsoft does identify the purposes for which it “uses” data. “Services” here refers to the Microsoft services, which includes the Azure OpenAI service:

#### ***Nature of Data Processing; Ownership***

*Microsoft will use and otherwise process Customer Data, Professional Services Data, and Personal Data only as described and subject to the limitations provided below (a) to provide Customer the Products and Services in accordance with Customer’s documented instructions and (b) for business operations incident to providing the Products and Services to Customer. As between the parties, Customer retains all right, title and interest in and to Customer Data and Professional Services Data. Microsoft acquires no rights in Customer Data or Professional Services Data, other than the rights Customer grants to Microsoft in this section. This paragraph does not affect Microsoft’s rights in software or services Microsoft licenses to Customer.*

#### ***Processing to Provide Customer the Products and Services***

*For purposes of this DPA, “to provide” a Product consists of:*

- *Delivering functional capabilities as licensed, configured, and used by Customer and its users, including providing personalized user experiences;*
- *Troubleshooting (preventing, detecting, and repairing problems); and*
- *Keeping Products up to date and performant, and enhancing user productivity, reliability, efficacy, quality, and security.*

*For purposes of this DPA, “to provide” Professional Services consists of:*

- *Delivering the Professional Services, including providing technical support, professional planning, advice, guidance, data migration, deployment, and solution/software development services.*
- *Troubleshooting (preventing, detecting, investigating, mitigating, and repairing problems, including Security Incidents and problems identified in the Professional Services or relevant Product(s) during delivery of Professional Services); and*

- *Enhancing delivery, efficacy, quality, and security of Professional Services and the underlying Product(s) based on issues identified while providing Professional Services, including fixing software defects and otherwise keeping Products and Services up to date and performant.*

*In each case, providing the Products and Services is conducted in view of security obligations under Data Protection Requirements.*

*When providing Products and Services, Microsoft will not use or otherwise process Customer Data, Professional Services Data, or Personal Data for: (a) user profiling, (b) advertising or similar commercial purposes, or (c) market research aimed at creating new functionalities, services, or products or any other purpose, unless such use or processing is in accordance with Customer's documented instructions.*

***Processing for Business Operations Incident to Providing the Products and Services to Customer***

*For purposes of this DPA, "business operations" means the processing operations authorized by customer in this section.*

*Customer authorizes Microsoft:*

- (i.) *to create aggregated statistical, non-personal data from data containing pseudonymized identifiers (such as usage logs containing unique, pseudonymized identifiers); and*
- (ii.) *to calculate statistics related to Customer Data or Professional Services Data in each case without accessing or analyzing the content of Customer Data or Professional Services Data and limited to achieving the purposes below, each as incident to providing the Products and Services to Customer.*

*Those purposes are:*

- *billing and account management;*
- *compensation such as calculating employee commissions and partner incentives;*
- *internal reporting and business modeling, such as forecasting, revenue, capacity planning, and product strategy; and*
- *financial reporting.*

*When processing for these business operations, Microsoft will apply principles of data minimization and will not use or otherwise process Customer Data, Professional Services Data, or Personal Data for: (a) user profiling, (b) advertising or similar commercial purposes, or (c) any other purpose, other than for the purposes set out in this section. In addition, as with all processing under this DPA, processing for business operations remains subject to Microsoft's confidentiality obligations and commitments under Disclosure of Processed Data.*

Microsoft indicates in its service terms that it does not use Customer Data or derive information from it for any advertising or similar commercial purposes. With specific reference to the Azure OpenAI service, Microsoft indicates that it does not use Customer Data to train any LLM.

Microsoft also indicates that it uses Personal Data to operate their business. This includes analysing performance, meeting legal obligations, developing their workforce, and conducting research.

**Consent.** The Consent Principle requires that the knowledge and consent of the individual are required for the collection, use, or disclosure of the individual/data subject's personal information. A further qualification is that the reasonable expectations of the subject individual must be met as well. It is expected that such consent will usually be obtained at the time of collection and that the purposes are stated in a manner where the individual can reasonably understand the proposed use and disclosure of personal information.

Under this principle, notification language on forms or websites, containing a clear description of the purpose for collection, would be expected. Consent, for private sector organizations, also requires an ability to withdraw – whether in whole or in part – such consent. The responsibility for consent - both for customer customers and employees – remains with the customer. Microsoft, as a service provider, has no specific obligation here concerning consent.

**Limiting Collection.** The collection of personal information is to be limited to that which is necessary for the identified purposes. This implies an obligation to ensure that the amount and the type of information collected are strictly necessary to fulfill the stated need. Another way to describe this concept is “data minimization”.

Collection of personal information or third-party data is the responsibility of the customer. Microsoft's collection of data – with respect to the use of the Azure OpenAI service (or any Azure service) is for user registration purposes and system management purposes. Microsoft has indicated that the data elements collected for user administration and support purposes has been the subject of a data minimization exercise to reduce the number of type of data elements to what is considered required. The number and nature of the data elements collected by Microsoft are reasonable and necessary in connection with the purposes of their collection.

**Limiting Use, Disclosure and Retention.** The general rule is that personal information is not to be used or disclosed for purposes other than those for which it was collected, except with the consent of the individual or as required by, or allowed in, legislation. Customers are expected to have retention schedules to meet the requirements of the limiting retention principle. Once personal information is no longer required for the identified purposes it is to be securely destroyed, erased, or made anonymous.

**Disclosure.** Microsoft indicates in its DPA that it will not disclose Customer Data outside of Microsoft or its controlled subsidiaries and affiliates except as indicated:

***Disclosure of Processed Data***

*Microsoft will not disclose or provide access to any Processed Data except: (1) as Customer directs; (2) as described in this DPA; or (3) as required by law. For purposes of this section, “Processed Data” means: (a) Customer Data; (b) Professional Services Data; (c) Personal Data; and (d) any other data processed by Microsoft in connection with the Products and Services that is Customer's confidential information under Customer's agreement. All processing of Processed Data is subject to Microsoft's obligation of confidentiality under Customer's agreement.*

*Microsoft will not disclose or provide access to any Processed Data to law enforcement unless required by law. If law enforcement contacts Microsoft with a demand for Processed Data,*

*Microsoft will attempt to redirect the law enforcement agency to request that data directly from Customer. If compelled to disclose or provide access to any Processed Data to law enforcement, Microsoft will promptly notify Customer and provide a copy of the demand unless legally prohibited from doing so.*

*Upon receipt of any other third-party request for Processed Data, Microsoft will promptly notify Customer unless prohibited by law. Microsoft will reject the request unless required by law to comply. If the request is valid, Microsoft will attempt to redirect the third party to request the data directly from Customer.*

*Microsoft will only disclose or provide access to any Processed Data as required by law provided that the laws and practices respect the essence of the fundamental rights and freedoms and do not exceed what is necessary and proportionate in a democratic society and, as applicable, to safeguard one of the objectives listed in Article 23(1) of GDPR.*

*Microsoft will not provide any third party: (a) direct, indirect, blanket, or unfettered access to Processed Data; (b) platform encryption keys used to secure Processed Data or the ability to break such encryption; or (c) access to Processed Data if Microsoft is aware that the data is to be used for purposes other than those stated in the third party's request.*

*In support of the above, Microsoft may provide Customer's basic contact information to the third party.*

Microsoft indicates that it keeps an accurate accounting of disclosures of information held in each system of records under its control, including date, nature, and purpose of each disclosure of a record.

**Retention.** Microsoft allows customers to apply their own data retention policies by maintaining the data until such time as the customer disposes of the information. Customer Content Data is stored in a redundant environment with robust backup, restore, and failover capabilities to enable availability, business continuity, and rapid recovery. Multiple levels of data redundancy are implemented, ranging from (i) redundant disks to guard against local disk failure to (ii) continuous, full data replication to (iii) a geographically dispersed datacenter. Microsoft, in connection with providing Azure-based services, undergoes an annual validation of backup/recovery practices.

Microsoft indicates that it wipes storage hard drives using a solution that is compliant with NIST 800-88<sup>133</sup>. For hard drives that cannot be wiped, there is a physical destruction process that renders the recovery of information impossible. The appropriate means of disposal is determined by the asset type.

Records of hardware destruction are retained and audited through Microsoft's ISO process. All Microsoft services utilize approved media storage and disposal management services. Paper documents are destroyed by approved means at the pre-determined end-of- life cycle.

With respect to retention, Microsoft's DPA states:

***Data Retention and Deletion***

*At all times during the term of Customer's subscription or the applicable Professional Services engagement, Customer will have the ability to access, extract and delete Customer Data stored in each Online Service and Professional Services Data.*

---

<sup>133</sup> National Institute of Standards & Technology Special Publication 800-88, Guidelines for Media Sanitization.

*Except for free trials and LinkedIn services, Microsoft will retain Customer Data that remains stored in Online Services in a limited function account for 90 days after expiration or termination of Customer's subscription so that Customer may extract the data. After the 90-day retention period ends, Microsoft will disable Customer's account and delete the Customer Data and Personal Data stored in Online Services within an additional 90 days, unless authorized under this DPA to retain such data.*

*For Personal Data in connection with the Software and for Professional Services Data, Microsoft will delete all copies after the business purposes for which the data was collected or transferred have been fulfilled or earlier upon Customer's request, unless authorized under this DPA to retain such data.*

*The Online Service may not support retention or extraction of software provided by Customer. Microsoft has no liability for the deletion of Customer Data, Professional Services Data, or Personal Data as described in this section.*

**Accuracy.** The concept of "accuracy" as a principle is related to "use" in that if information is used to make a decision it should be as accurate and up to date as possible to ensure that inappropriate information will not be used to make a decision about an individual.

With respect to data it collects, Microsoft has a process to allow customers to correct or amend inaccurate personal information, as appropriate. As for Customer Content Data, the features and functionality of the Azure OpenAI allow customers to remain in control of their content stored within the service. To the extent that a customer does not use Generative AI outputs for decisions, this is not an issue. To the extent a customer may use it for decision-making, outputs should be reviewed to ensure no fabrications are present - or no unintended bias exists - that may influence any decisions about individuals.

**Safeguards.** Personal information is to be protected by security safeguards appropriate to the sensitivity of the information. This principle requires particular care to be used for data at rest and in transit, as well as the disposal or destruction of personal information.

See [Annex A](#) for a description of safeguard measures deployed by Microsoft as well as audit measures to support the deployed safeguards.

Microsoft provides role-based security training to personnel with assigned security roles and responsibilities. All appropriate Microsoft Staff take part in a security-training program and are recipients of periodic security awareness updates when applicable. All contract staff are required to take any training determined to be appropriate to the services being provided and the role they perform.

All staff are required to enroll in a security awareness training course within the first 30 days of their employment or transfer into the organization. Non-operational personnel - anyone that is involved in development and quality assurance - are also required to take the mandatory training offered by Online Services Security, as well as training associated with the operational procedures related to asset handling, incident response, and change control. Security training is also required when there is a significant change to the system environment.

With respect to safeguards, Microsoft explicitly states in its DPA:

## **Data Security**

### **Security Practices and Policies**

*Microsoft will implement and maintain appropriate technical and organizational measures to protect Customer Data, Professional Services Data, and Personal Data against accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data transmitted, stored or otherwise processed. Those measures shall be set forth in a Microsoft Security Policy. Microsoft will make that policy available to Customer, along with other information reasonably requested by Customer regarding Microsoft security practices and policies.*

*In addition, those measures shall comply with the requirements set forth in ISO 27001, ISO 27002, and ISO 27018. A description of the security controls for these requirements is available to Customers.*

*Each Core Online Service also complies with the control standards and frameworks shown in the table in the Product Terms. Each Core Online Service and Professional Service implements and maintains the security measures set forth in Appendix A for the protection of Customer Data and Professional Services Data.*

*Microsoft implements and maintains the security measures set forth in Annex II of the 2021 Standard Contractual Clauses for the protection of Personal Data within the scope of the GDPR.*

*Microsoft may add industry or government standards at any time. Microsoft will not eliminate ISO 27001, ISO 27002, ISO 27018 or any standard or framework in the table for Core Online Services in the Product Terms, unless it is no longer used in the industry and it is replaced with a successor (if any).*

### **Data Encryption**

*Customer Data and Professional Services Data (each including any Personal Data therein) in transit over public networks between Customer and Microsoft, or between Microsoft data centers, is encrypted by default.*

*Microsoft also encrypts Customer Data stored at rest in Online Services and Professional Services Data stored at rest. In the case of Online Services on which Customer or a third-party acting on Customer's behalf may build applications (e.g., certain Azure Services), encryption of data stored in such applications may be employed at the discretion of Customer, using either capabilities provided by Microsoft or obtained by Customer from third parties.*

### **Data Access**

*Microsoft employs least privilege access mechanisms to control access to Customer Data and Professional Services Data (including any Personal Data therein). Role-based access controls are employed to ensure that access to Customer Data and Professional Services Data required for service operations is for an appropriate purpose and approved with management oversight. For*

*Core Online Services and Professional Services, Microsoft maintains Access Control mechanisms described in the table entitled “Security Measures” in Appendix A; and there is no standing access by Microsoft personnel to Customer Data, and any required access is for a limited time.*

### **Customer Responsibilities**

*Customer is solely responsible for making an independent determination as to whether the technical and organizational measures for Products and Services meet Customer’s requirements, including any of its security obligations under applicable Data Protection Requirements. Customer acknowledges and agrees that (taking into account the state of the art, the costs of implementation, and the nature, scope, context and purposes of the processing of its Personal Data as well as the risks to individuals) the security practices and policies implemented and maintained by Microsoft provide a level of security appropriate to the risk with respect to its Personal Data. Customer is responsible for implementing and maintaining privacy protections and security measures for components that Customer provides or controls (such as devices enrolled with Microsoft Intune or within a Microsoft Azure customer’s virtual machine or application).*

### **Auditing Compliance**

*Microsoft will conduct audits of the security of the computers, computing environment, and physical data centers that it uses in processing Customer Data, Professional Service Data, and Personal Data, as follows:*

- *Where a standard or framework provides for audits, an audit of such control standard or framework will be initiated at least annually.*
- *Each audit will be performed according to the standards and rules of the regulatory or accreditation body for each applicable control standard or framework.*
- *Each audit will be performed by qualified, independent, third party security auditors at Microsoft’s selection and expense.*

*Each audit will result in the generation of an audit report (“Microsoft Audit Report”), which Microsoft will make available at <https://servicetrust.microsoft.com/> or another location identified by Microsoft. The Microsoft Audit Report will be Microsoft’s Confidential Information and will clearly disclose any material findings by the auditor. Microsoft will promptly remediate issues raised in any Microsoft Audit Report to the satisfaction of the auditor. If Customer requests, Microsoft will provide Customer with each Microsoft Audit Report. The Microsoft Audit Report will be subject to non-disclosure and distribution limitations of Microsoft and the auditor.*

*To the extent Customer’s audit requirements under the Data Protection Requirements cannot reasonably be satisfied through audit reports, documentation or compliance information Microsoft makes generally available to its customers, Microsoft will promptly respond to Customer’s additional audit instructions. Before the commencement of an audit, Customer and Microsoft will mutually agree upon the scope, timing, duration, control and evidence requirements, and fees for the audit, provided that this requirement to agree will not permit Microsoft to unreasonably delay performance of the audit. To the extent needed to perform the audit, Microsoft will make the processing systems, facilities and supporting documentation relevant to the processing of Customer Data, Professional Services Data, and Personal Data by Microsoft, its Affiliates, and its Subprocessors available. Such an audit will be conducted by an*

*independent, accredited third-party audit firm, during regular business hours, with reasonable advance notice to Microsoft, and subject to reasonable confidentiality procedures. Neither Customer nor the auditor shall have access to any data from Microsoft's other customers or to Microsoft systems or facilities not involved in providing the applicable Products and Services. Customer is responsible for all costs and fees related to such audit, including all reasonable costs and fees for any and all time Microsoft expends for any such audit, in addition to the rates for services performed by Microsoft. If the audit report generated as a result of Customer's audit includes any finding of material non-compliance, Customer shall share such audit report with Microsoft and Microsoft shall promptly cure any material non-compliance.*

*Nothing in this section of the DPA varies or modifies the GDPR Terms or affects any supervisory authority's or data subject's rights under the Data Protection Requirements. Microsoft Corporation is an intended third-party beneficiary of this section.*

### **Security Incident Notification**

*If Microsoft becomes aware of a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to Customer Data, Professional Services Data, or Personal Data while processed by Microsoft (each a "Security Incident"), Microsoft will promptly and without undue delay (1) notify Customer of the Security Incident; (2) investigate the Security Incident and provide Customer with detailed information about the Security Incident; (3) take reasonable steps to mitigate the effects and to minimize any damage resulting from the Security Incident.*

*Notification(s) of Security Incidents will be delivered to Customer by any means Microsoft selects, including via email. It is Customer's sole responsibility to ensure Customer maintains accurate contact information with Microsoft for each applicable Product and Professional Service. Customer is solely responsible for complying with its obligations under incident notification laws applicable to Customer and fulfilling any third-party notification obligations related to any Security Incident.*

*Microsoft shall make reasonable efforts to assist Customer in fulfilling Customer's obligation under GDPR Article 33 or other applicable law or regulation to notify the relevant supervisory authority and data subjects about such Security Incident.*

*Microsoft's notification of or response to a Security Incident under this section is not an acknowledgement by Microsoft of any fault or liability with respect to the Security Incident. Customer must notify Microsoft promptly about any possible misuse of its accounts or authentication credentials or any security incident related to the Products and Services.*

**Openness.** Organizations are expected to be open about their policies and practices with respect to the management of personal information. Descriptions of such policies and practices are to be made available in a form that is generally understandable.

The information made available shall include:

- The name/title and address of the person who is accountable for the personal information policies and practices and to whom complaints or inquiries or requests for recourse can be forwarded.

- The means of gaining access to personal information.
- A description of the type of personal information held including an account of its use.
- Information that explains the policies and procedures surrounding the use of personal information.

Generally, compliance with the openness principle is a customer responsibility. In terms of Microsoft providing notice to end users, Microsoft provides a Privacy Statement<sup>134</sup> in which it defines what constitutes Customer Data and the purposes for which it uses such data.

Specifically, with respect to Azure OpenAI, Microsoft also publishes a Transparency Note<sup>135</sup> that are intended to explain understand how its AI technology works, the choices system owners can make that influence system performance and behavior, and the importance of taking a holistic approach (i.e. considering technology, the people, and the environment). Microsoft has also published and adheres to AI Principles.<sup>136</sup>

**Access.** Under the Code, individuals have a right to access their own personal information and to request that corrections be made.

With respect to the information it collects, Microsoft has a process to allow customers to correct or amend inaccurate personal information, as appropriate. As for Customer Content Data, the features and functionality within the Azure OpenAI service – subject to the Code of Conduct - allow customers to remain in control of their content stored within the service. Information as to how to contact Microsoft is available through the Online Privacy Statement and through an online web form.

Whether or not to grant access to inputs (prompts) and outputs is the responsibility of customers. If no personal information is used in the use of the Azure OpenAI service, this is not an issue.

**Challenging Compliance.** Organizations are required to have procedures in place to address complaints or inquiries pertaining to the handling of personal information. The complaint process is to be easily accessible and simple to use. Where a complaint is justified, systemic problems are to be addressed through the amendment of applicable policies and practices.

Microsoft's Privacy Statement and Microsoft's terms of service both contain language as to how to contact Microsoft concerning complaints and/or inquiries. Microsoft's DPA contain the following statement:

*If Customer believes that Microsoft is not adhering to its privacy or security commitments, Customer may contact customer support or use Microsoft's Privacy web form, located at <http://go.microsoft.com/?linkid=9846224>. Microsoft's mailing address is:*

**Microsoft Enterprise Service Privacy**  
Microsoft Corporation  
One Microsoft Way  
Redmond, Washington 98052 USA

<sup>134</sup> Available at: <https://privacy.microsoft.com/en-ca/privacystatement>.

<sup>135</sup> Available at: <https://learn.microsoft.com/en-us/legal/cognitive-services/openai/transparency-note?tabs=text>.

<sup>136</sup> Available at: <https://www.microsoft.com/en-ca/ai/responsible-ai?rtc=1>.

*Microsoft Ireland Operations Limited is Microsoft's data protection representative for the European Economic Area and Switzerland. The privacy representative of*

*Microsoft Ireland Operations Limited can be reached at the following address:*

**Microsoft Ireland Operations, Ltd.**

*Attn: Data Protection*

*One Microsoft Place*

*South County Business Park*

*Leopardstown*

*Dublin 18, D18 P521, Ireland*

## M. Québec Private Sector Law

For private sector organizations operating in the Province of Québec, the personal information of individuals residing in that province is subject to personal information protection legislation<sup>137</sup> (the "Private Sector Law"). Québec's Private Sector Law applies to both to the activities of "for profit" and non-profit organizations as well as to personal information held by a professional order<sup>138</sup>. Enforcement of the law, when required, is undertaken by the Commission d'accès à l'information ("CAI").

Microsoft may be characterized as a service provider to a private sector customer in the provision of the Azure OpenAI service. Because of this role, the primary responsibility for legal/privacy compliance with Québec's Private Sector Law lies with the customers who use the service.

**Consent.** An organization may only collect, use, or disclose personal information about an individual with the consent of that individual, as authorized by law, or with deemed consent as determined by statute.<sup>139</sup>

In Québec, consent must be clear, free, and informed and be given for specific purposes. In addition, consent must be requested for each purpose and in clear and simple language. If a request for consent is made in writing, it must be presented separately from any other information provided to the person concerned. If the data subject requests, assistance is to be provided to help them understand the scope of the consent requested.

For individuals under 14 years of age, consent of an individual is to be given by the person having parental authority or by the tutor; for individuals 14 or older, consent is to be given by the minor, by the person having parental authority or by the tutor. Consent is valid only for the time necessary to achieve the purposes for which it was requested. Any consent not given in accordance with the Private Sector Law is void.<sup>140</sup>

With respect to:

---

<sup>137</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1.

<sup>138</sup> But only to the extent provided for by the *Professional Code*: RSQ, c C-26; See *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 1.

<sup>139</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 13 and *Civil Code of Québec*, art. 37

<sup>140</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 14.

- Customer Content Data, Microsoft plays no role in obtaining consent and responsibility for obtaining such consent lies with the Customer.
- User Data, consent is implied by actions taken to register the user to use the Azure OpenAI service.
- Diagnostic Data, to the extent such data may be considered Personal Data, consent is implied by actions taken by users to use the Azure OpenAI service.

With respect to customer use of personal information – in the form of Azure OpenAI inputs or outputs – customers should endeavour to communicate to customers and to obtain their general consent to the use of Generative AI services. This communication should describe, at a minimum and with sufficient detail, the purposes for which such services are used; what personal information data elements are used; whether any decisions are made about individuals and, if so, which decisions

**Collection.** Québec’s Private Sector Law requires that information be collected directly and only from the subject individual unless certain circumstances apply. Indirect collection is allowed where authorized by law or the individual has provided consent. Such indirect collection may also occur when there is a serious reason to do so; it is the individual’s interests and direct collection cannot happen in a timely manner, or where direct collection would result in the collection of inaccurate information.<sup>141</sup>

Collection requires the individual to be notified<sup>142</sup>, at the time of collection or upon request, of the:

- Purposes for which the information is collected.
- Means by which the information is collected.
- Rights of access and rectification provided by law.
- Person’s right to withdraw consent to the communication or use of the information collected.

The information to be provided must be given to the person concerned in clear and simple language, regardless of the means used to collect the personal information.

If applicable, the person concerned is to be informed of the name of any third person for whom the information is being collected; the name(s) of the third persons or categories of third persons to whom it is necessary to communicate the information for the purposes indicated, and the possibility that the information could be communicated outside Québec.

On request, the data subject is to also be informed of the personal information collected from them, the categories of persons who have access to the information within the organization, the retention period, and the contact information of the person in charge of the protection of personal information.

In Québec, as with all jurisdictions in Canada, an organization may collect, use and disclose personal information without consent if authorized or required by law.<sup>143</sup> Any collection, use or disclosure of personal information for the supply of a product or service is limited to that necessary to provide the product or service, or as authorized by law or if the request for the product or service is not lawful.<sup>144</sup>

<sup>141</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 6.

<sup>142</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 8.

<sup>143</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, ss. 6, 13, and 18.

<sup>144</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1), s. 9.

Microsoft directly collects User Data as well as Diagnostic Data, to the extent the latter may be considered Personal Data. As for the purposes for which such data is used, see the next section on Use.

Microsoft plays no role in the collection personal information contained within Customer Content Data and adhering to the foregoing requirements, with respect to such data, is the responsibility of the customer. With respect to the Azure OpenAI service, if used, personal information conceivably would be used to create inputs and/or finetune the LLM. Personal information may also appear in outputs if it is used as an input or is insufficiently de-identified or not anonymized. If personal information is not used at all (as inputs or to fine tune an LLM) then there should not be an issue although outputs should always be reviewed to ensure no fabrications are present.

**Use.** In Canadian personal information protection statutes, “use” is inextricably linked to “purpose”. Québec permits the use of personal information only for the purposes for which it was collected unless consent is obtained or unless authorized by law.<sup>145</sup>

Microsoft identifies the following purposes for which it “uses” data in its Privacy Statement as well as specifically in the DPA. The DPA describes the purposes for which such Personal Data is used by Microsoft as follows:

***Nature of Data Processing; Ownership***

*Microsoft will use and otherwise process Customer Data, Professional Services Data, and Personal Data only as described and subject to the limitations provided below (a) to provide Customer the Products and Services in accordance with Customer’s documented instructions and (b) for business operations incident to providing the Products and Services to Customer. As between the parties, Customer retains all right, title and interest in and to Customer Data and Professional Services Data. Microsoft acquires no rights in Customer Data or Professional Services Data, other than the rights Customer grants to Microsoft in this section. This paragraph does not affect Microsoft’s rights in software or services Microsoft licenses to Customer.*

***Processing to Provide Customer the Products and Services***

*For purposes of this DPA, “to provide” a Product consists of:*

- *Delivering functional capabilities as licensed, configured, and used by Customer and its users, including providing personalized user experiences;*
- *Troubleshooting (preventing, detecting, and repairing problems); and*
- *Keeping Products up to date and performant, and enhancing user productivity, reliability, efficacy, quality, and security.*

*For purposes of this DPA, “to provide” Professional Services consists of:*

- *Delivering the Professional Services, including providing technical support, professional planning, advice, guidance, data migration, deployment, and solution/software development services.*

---

<sup>145</sup> An Act respecting the Protection of Personal Information in the Private Sector, RSQ c P-39.1, ss. 12-13.

- Troubleshooting (preventing, detecting, investigating, mitigating, and repairing problems, including Security Incidents and problems identified in the Professional Services or relevant Product(s) during delivery of Professional Services); and
- Enhancing delivery, efficacy, quality, and security of Professional Services and the underlying Product(s) based on issues identified while providing Professional Services, including fixing software defects and otherwise keeping Products and Services up to date and performant.

*In each case, providing the Products and Services is conducted in view of security obligations under Data Protection Requirements.*

*When providing Products and Services, Microsoft will not use or otherwise process Customer Data, Professional Services Data, or Personal Data for: (a) user profiling, (b) advertising or similar commercial purposes, or (c) market research aimed at creating new functionalities, services, or products or any other purpose, unless such use or processing is in accordance with Customer's documented instructions.*

***Processing for Business Operations Incident to Providing the Products and Services to Customer***

*For purposes of this DPA, "business operations" means the processing operations authorized by customer in this section.*

*Customer authorizes Microsoft:*

- (i.) *to create aggregated statistical, non-personal data from data containing pseudonymized identifiers (such as usage logs containing unique, pseudonymized identifiers); and*
- (ii.) *to calculate statistics related to Customer Data or Professional Services Data*

*in each case without accessing or analyzing the content of Customer Data or Professional Services Data and limited to achieving the purposes below, each as incident to providing the Products and Services to Customer.*

*Those purposes are:*

- *billing and account management;*
- *compensation such as calculating employee commissions and partner incentives;*
- *internal reporting and business modeling, such as forecasting, revenue, capacity planning, and product strategy; and*
- *financial reporting.*

*When processing for these business operations, Microsoft will apply principles of data minimization and will not use or otherwise process Customer Data, Professional Services Data, or Personal Data for: (a) user profiling, (b) advertising or similar commercial purposes, or (c) any other purpose, other than for the purposes set out in this section. In addition, as with all processing under this DPA, processing for business operations remains subject to Microsoft's confidentiality obligations and commitments under Disclosure of Processed Data.*

Microsoft indicates that it does not use Customer Data or derive information from it for any advertising or similar commercial purposes.

“Personal Data” is defined by Microsoft to mean:

*“any information relating to an identified or identifiable natural person. An identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.”*

**Disclosure.** In Québec, if disclosure has occurred, the recipient may further disclose the information – only to the extent necessary – to perform his or her duties or to meet the purposes for which he/she received the information.<sup>146</sup>

In addition to disclosure to one’s own legal advisor, any permitted disclosure may occur for reasons related to:

- The prevention, detection, repression or prosecution of criminal or statutory offences.
- The existence of, or reasonable belief that there is, a life, health or safety-threatening situation.
- A requirement under a law or a collective agreement, whether to an individual or a public institution.
- Debt collection.
- Research or statistical purposes.
- The existence of a power to compel communication of the information.<sup>147</sup>

Microsoft’s position on the disclosure of data held by is described in the DPA as follows:

#### ***Disclosure of Processed Data***

*Microsoft will not disclose or provide access to any Processed Data except: (1) as Customer directs; (2) as described in this DPA; or (3) as required by law. For purposes of this section, “Processed Data” means: (a) Customer Data; (b) Professional Services Data; (c) Personal Data; and (d) any other data processed by Microsoft in connection with the Products and Services that is Customer’s confidential information under Customer’s agreement. All processing of Processed Data is subject to Microsoft’s obligation of confidentiality under Customer’s agreement.*

*Microsoft will not disclose or provide access to any Processed Data to law enforcement unless required by law. If law enforcement contacts Microsoft with a demand for Processed Data, Microsoft will attempt to redirect the law enforcement agency to request that data directly from Customer. If compelled to disclose or provide access to any Processed Data to law enforcement, Microsoft will promptly notify Customer and provide a copy of the demand unless legally prohibited from doing so.*

---

<sup>146</sup> An Act respecting the Protection of Personal Information in the Private Sector, RSQ c P-39.1, ss. 18 and 18.1.

<sup>147</sup> An Act respecting the Protection of Personal Information in the Private Sector, RSQ c P-39.1, ss. 18 and 18.1.

*Upon receipt of any other third-party request for Processed Data, Microsoft will promptly notify Customer unless prohibited by law. Microsoft will reject the request unless required by law to comply. If the request is valid, Microsoft will attempt to redirect the third party to request the data directly from Customer.*

*Microsoft will only disclose or provide access to any Processed Data as required by law provided that the laws and practices respect the essence of the fundamental rights and freedoms and do not exceed what is necessary and proportionate in a democratic society and, as applicable, to safeguard one of the objectives listed in Article 23(1) of GDPR.*

*Microsoft will not provide any third party: (a) direct, indirect, blanket, or unfettered access to Processed Data; (b) platform encryption keys used to secure Processed Data or the ability to break such encryption; or (c) access to Processed Data if Microsoft is aware that the data is to be used for purposes other than those stated in the third party's request. In support of the above, Microsoft may provide Customer's basic contact information to the third party.*

To the extent that personal information is used within the Azure OpenAI service, disclosure obligations are the responsibility of the customer. Outputs, if disclosed, should be subject to prior review to ensure no personal information is present and there is no information that could lead to the identification of an individual.

Microsoft indicates that it keeps an accurate accounting of disclosures of information held in each system of records under its control, including date, nature, and purpose of each disclosure of a record.

**Outsourcing and cross-border transfers.** Communicating personal information to a service provider (or a mandatary/agent) does not require the consent of an individual. Service agreements, however, are to be in writing and contain provisions:

- Specifying the measures to protect the confidentiality of the personal information.
- Ensuring use is limited to the performance of services.  
Ensuring destruction or return following the end of the contract.
- Requiring prompt notification in the event of an actual or suspected data incident or breach.
- Permitting any verification relating to confidentiality requirements.<sup>148</sup>

With respect to cross-border transfers, organizations, before communicating personal information outside Québec, “must conduct an assessment of privacy-related factors”, considering the:

- Sensitivity of the information.
- Purposes for which it is to be used.
- Protection measures that would apply to the information.
- Legal framework applicable in the State to which the information would be communicated, including the legal framework's degree of equivalency with the personal information protection principles applicable in Québec.<sup>149</sup>

---

<sup>148</sup> An Act respecting the Protection of Personal Information in the Private Sector, RSQ c P-39.1, s 18.3.

<sup>149</sup> An Act respecting the Protection of Personal Information in the Private Sector, RSQ c P-39.1, s. 17.

Organizations may conduct research without consent in that they can disclose personal information to a person or body wishing to use the information for study or research purposes or to produce statistics, provided a privacy impact assessment indicates that:

- The objective of the research can be achieved only if the information is communicated in a form allowing the persons concerned to be identified.
- It is unreasonable to require the person or body to obtain the consent of the persons concerned.
- The objective of the research outweighs the impact of communicating and using the information on the privacy of the persons concerned.
- The personal information is used in such a manner as to ensure confidentiality.
- Only the necessary information is communicated.<sup>150</sup>

Microsoft does not use User Data or Customer Content Data for research purposes but does use the limited Personal Data collected for the purposes identified in its Privacy Statement and DPA. It is to be noted that where a customer has inputs that violate the Code of Conduct, such inputs will be reviewed by a Microsoft employee and that employee may be located outside of Canada.

**Access.** Under the Private Sector Law, there is a general right of access to one's own personal information<sup>151</sup>. In the event of death, heirs and family members have special rights of access to the deceased's health information.<sup>152</sup>

Subject to specific exceptions, access to personal information must be provided to the subject individual so long as it is reasonable to do so. In addition, the organization must also describe the purposes for which the information is used and, if disclosed the names of recipients and the context of the disclosure<sup>153</sup>. In Québec, if requested, reasonable accommodation must be provided to people with disabilities to allow them to exercise the right of access<sup>154</sup>.

Québec's legislation, both in the *Civil Code* and the Private Sector Law, differs from the other jurisdictions with respect to the exemptions to access. Under the *Civil Code*, information may not be disclosed where there is a serious and legitimate reason for refusing access or where the information may seriously prejudice a third person.<sup>155</sup>

An organization, characterized as a "person carrying on an enterprise", must refuse to disclose personal information:

- Where disclosure would likely reveal personal information about a third party or even that party's existence, and the disclosure may cause that person serious harm, unless the third-

---

<sup>150</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 21. See also sections 21.0.1 and 21.0.2 for further qualifications for researchers seeking to use personal information for research purposes.

<sup>151</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, ss. 8 and 27

<sup>152</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 31. See also *Rouleau v. Centre de santé et de services sociaux de Montmagny-L'Islet*, [2006] CAI 377.

<sup>153</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, ss. 8 and 27. For Québec, see also CCQ, s. 39.

<sup>154</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 27.

<sup>155</sup> Civil Code of Québec, s. 39.

party consents to disclosure or where the life, health or safety of the person concerned is threatened<sup>156</sup>.

- To a testamentary administrator, a life insurance beneficiary, an heir, or a successor, except where such disclosure concerns the interests or rights of the person requesting it in his or her capacity as such<sup>157</sup>. This is qualified in that disclosure about a deceased person may be made to the spouse or a close relative of the person if knowledge of the information could help the applicant in the grieving process and if the deceased person did not record in writing his refusal to grant such a right of access.<sup>158</sup>
- To an individual under 14 years of age as to the existence or disclosure of a record containing personal information “of a medical or social nature”, except where requested by the minor’s attorney in the context of judicial proceedings<sup>159</sup>.

Discretionary exceptions (i.e. the organization may disclose if it chooses) can be used in two situations:

- A person carrying on a professional health care enterprise may temporarily refuse access to personal information if such access would result in serious harm to the applicant’s health. Other types of enterprises may also refuse access, provided that the applicant is offered the opportunity of designating a health care professional to receive the information<sup>160</sup>.
- Where disclosure would be likely hinder an inquiry, the purpose of which is the prevention, detection, or repression of criminal or statutory offences, or would be likely to affect judicial proceedings<sup>161</sup>.

In Québec, a refusal to provide access or rectification (correction) must be given in writing, with reasons and information as to the recourse open to the individual.<sup>162</sup>

Generally, responsibilities with respect to access requests to Customer Content Data remain with the customer. Microsoft has a process to allow customers to correct or amend inaccurate personal information, as appropriate. Information as to how to contact Microsoft is available through the Microsoft Privacy Statement and using an online web form.

The features and functionality of the Azure OpenAI service allow customers to remain in control of Customer Content Data stored within the service. The use of the service will not cause any change in:

- An individual’s right to access and correct personal information.
- The way access to personal information may be provided by an organization.
- The medium by which individuals may request access to his or her personal information from an organization.
- The customer’s access procedures.

---

<sup>156</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 40.

<sup>157</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 41.

<sup>158</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 40.1.

<sup>159</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 38.

<sup>160</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 37.

<sup>161</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 39.

<sup>162</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s.34.

- How an individual can challenge the accuracy and completeness of his or her personal information held by the customer.

Customers should be aware that their inputs and outputs of the Azure OpenAI service - that contain personal information - may be subject to access requests.

**Correction.** An individual may request the correction or rectification of an error or omission in personal information under the control of an organization<sup>163</sup>. The subject individual must make the request in writing with sufficient detail to enable, with a reasonable effort, the identification of the personal information or correction being sought.<sup>164</sup>

If inaccurate or incomplete personal information is determined to exist, the organization must correct the information as soon as reasonably possible.<sup>165</sup> If it decides not to do so, a notation is to be made on the record that the correction was requested but not made.<sup>166</sup>

If an organization has disclosed incorrect information to other organizations, each of those organizations must be notified of the corrected information.<sup>167</sup> In Québec, the organization must notify every person that received the information in the preceding six months and, where applicable, the person who provided that information.<sup>168</sup>

Responsibility for the correction of Personal Data within Customer Content Data remains with the customer. This would, in the context of using the Azure OpenAI service, include inputs, outputs and any personal information used to fine tune the LLM.

As for User Data and Diagnostic Data, to the extent it is considered to constitute Personal Data, Microsoft has a process to allow customers to correct or amend inaccurate personal information, as appropriate.

**Accuracy.** Each organization in Québec is to ensure that any personal information is accurate and up to date when used to make a decision about an individual.<sup>169</sup> Unlike other jurisdictions in Canada, Québec's legislation permits "accuracy" to be achieved through the deletion of personal information, when personal information has been collected or generated but not in a manner authorized by law.<sup>170</sup> This ability to request the deletion of personal information argues for greater transparency by customers concerning their use of Generative AI as well as obtaining an appropriate consent to collect and use personal information. To the extent that customers do not use personal information within the Azure OpenAI service to make a decision about an individual, then no compliance issue arises.

Microsoft has a process to allow customers to correct or amend inaccurate personal information, as appropriate. The Azure OpenAI service does not affect customer control of Customer Content Data.

---

<sup>163</sup> *Civil Code of Québec*, ss. 38, 40.

<sup>164</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 30.

<sup>165</sup> *Civil Code of Québec*, ss. 38, 40.

<sup>166</sup> *Civil Code of Québec*, ss. 38, 40.

<sup>167</sup> *Civil Code of Québec*, ss. 38, 40.

<sup>168</sup> *Civil Code of Québec*, s. 40.

<sup>169</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 11; see also *Civil Code of Québec*, s. 40.

<sup>170</sup> *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 28.

**Retention.** Given amendments that came into force in 2023, Québec’s statute requires an organization must - subject to any preservation period provided under any legislation - destroy or anonymize personal information, when the purposes for which personal information was collected or used are achieved. Information is considered anonymized “if it is reasonably foreseeable in the circumstances that it irreversibly no longer allows the person to be identified directly or indirectly.” Information is to be anonymized according to generally accepted best practices and according to the criteria and terms determined by regulation.<sup>171</sup>

With respect to Personal Data collected by Microsoft, the DPA states:

#### ***Data Retention and Deletion***

*At all times during the term of Customer’s subscription or the applicable Professional Services engagement, Customer will have the ability to access, extract and delete Customer Data stored in each Online Service and Professional Services Data.*

*Except for free trials and LinkedIn services, Microsoft will retain Customer Data that remains stored in Online Services in a limited function account for 90 days after expiration or termination of Customer’s subscription so that Customer may extract the data. After the 90-day retention period ends, Microsoft will disable Customer’s account and delete the Customer Data and Personal Data stored in Online Services within an additional 90 days, unless authorized under this DPA to retain such data.*

*For Personal Data in connection with the Software and for Professional Services Data, Microsoft will delete all copies after the business purposes for which the data was collected or transferred have been fulfilled or earlier upon Customer’s request, unless authorized under this DPA to retain such data.*

*The Online Service may not support retention or extraction of software provided by Customer. Microsoft has no liability for the deletion of Customer Data, Professional Services Data, or Personal Data as described in this section.*

Microsoft allows customers to apply their data retention policies by maintaining the data until such time as the customer disposes of such information. Customer data is stored in a redundant environment with robust backup, restore, and failover capabilities to enable availability, business continuity, and rapid recovery. Multiple levels of data redundancy are implemented, ranging from (i) redundant disks to guard against local disk failure to (ii) continuous, full data replication to (iii) a geographically dispersed datacenter. All Microsoft services undergoes an annual validation of backup/recovery practices.

Microsoft indicates that it wipes storage hard drives using a solution that is compliant with NIST 800-88<sup>172</sup>. For hard drives that cannot be wiped there is a physical destruction process that renders the recovery of information impossible. The appropriate means of disposal is determined by the asset type.

---

<sup>171</sup> An Act respecting the Protection of Personal Information in the Private Sector, RSQ c P-39.1, s. 23. The Anonymization Regulation came into force on 30 May 2024, except with respect to a requirement to record certain prescribed information in a register, which comes into force on 1 January 2025. The Anonymization Regulation is available at: [https://www.publicationsduquebec.gouv.qc.ca/fileadmin/gazette/pdf\\_encrypte/lois\\_reglements/2024A/106829.pdf](https://www.publicationsduquebec.gouv.qc.ca/fileadmin/gazette/pdf_encrypte/lois_reglements/2024A/106829.pdf).

<sup>172</sup> National Institute of Standards & Technology Special Publication 800-88, Guidelines for Media Sanitization.

Records of hardware destruction are retained and audited through Microsoft's ISO process. All Microsoft services utilize approved media storage and disposal management services. Paper documents, should they exist, are destroyed by approved means at the pre-determined end-of- life cycle.

**Security.** With respect to security, Québec's Private Sector Law requires:

*A person carrying on an enterprise must take the security measures necessary to ensure the protection of the personal information collected, used, communicated, kept or destroyed and that are reasonable given the sensitivity of the information, the purposes for which it is to be used, the quantity and distribution of the information and the medium on which it is stored.*<sup>173</sup>

See [Annex A](#) for a description of safeguard measures deployed by Microsoft and the audit measures used to support the deployed safeguards.

Microsoft provides role-based security training to personnel with assigned security roles and responsibilities when required by information system changes. All appropriate Microsoft Staff take part in a security-training program and are recipients of periodic security awareness updates when applicable. All Contractor Staff are required to take any training determined to be appropriate to the services being provided and the role they perform.

All staff are required to enrol in a security awareness training course within the first 30 days of their employment or transfer into the organization. Non-operational personnel, anyone that is involved in development and quality assurance, are also required to take the mandatory training offered by Online Services Security, as well as training associated with the operational procedures related to Asset Handling, Incident Response, and Change Control. Security training is also required when there is a significant change to the system environment.

Microsoft's DPA states:

### **Data Security**

#### **Security Practices and Policies**

*Microsoft will implement and maintain appropriate technical and organizational measures to protect Customer Data, Professional Services Data, and Personal Data against accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data transmitted, stored or otherwise processed. Those measures shall be set forth in a Microsoft Security Policy. Microsoft will make that policy available to Customer, along with other information reasonably requested by Customer regarding Microsoft security practices and policies.*

*In addition, those measures shall comply with the requirements set forth in ISO 27001, ISO 27002, and ISO 27018. A description of the security controls for these requirements is available to Customers.*

---

<sup>173</sup> An Act respecting the Protection of Personal Information in the Private Sector, RSQ c P-39.1, s. 10.

*Each Core Online Service also complies with the control standards and frameworks shown in the table in the Product Terms. Each Core Online Service and Professional Service implements and maintains the security measures set forth in Appendix A for the protection of Customer Data and Professional Services Data.*

*Microsoft implements and maintains the security measures set forth in Annex II of the 2021 Standard Contractual Clauses for the protection of Personal Data within the scope of the GDPR.*

*Microsoft may add industry or government standards at any time. Microsoft will not eliminate ISO 27001, ISO 27002, ISO 27018 or any standard or framework in the table for Core Online Services in the Product Terms, unless it is no longer used in the industry and it is replaced with a successor (if any).*

### **Data Encryption**

*Customer Data and Professional Services Data (each including any Personal Data therein) in transit over public networks between Customer and Microsoft, or between Microsoft data centers, is encrypted by default.*

*Microsoft also encrypts Customer Data stored at rest in Online Services and Professional Services Data stored at rest. In the case of Online Services on which Customer or a third-party acting on Customer's behalf may build applications (e.g., certain Azure Services), encryption of data stored in such applications may be employed at the discretion of Customer, using either capabilities provided by Microsoft or obtained by Customer from third parties.*

### **Data Access**

*Microsoft employs least privilege access mechanisms to control access to Customer Data and Professional Services Data (including any Personal Data therein). Role-based access controls are employed to ensure that access to Customer Data and Professional Services*

*Data required for service operations is for an appropriate purpose and approved with management oversight. For Core Online Services and Professional Services, Microsoft maintains Access Control mechanisms described in the table entitled "Security Measures" in Appendix A; and there is no standing access by Microsoft personnel to Customer Data, and any required access is for a limited time.*

### **Customer Responsibilities**

*Customer is solely responsible for making an independent determination as to whether the technical and organizational measures for Products and Services meet Customer's requirements, including any of its security obligations under applicable Data Protection Requirements. Customer acknowledges and agrees that (taking into account the state of the art, the costs of implementation, and the nature, scope, context and purposes of the processing of its Personal Data as well as the risks to individuals) the security practices and policies implemented and maintained by Microsoft provide a level of security appropriate to the risk with respect to its Personal Data. Customer is responsible for implementing and maintaining privacy protections and security measures for components that Customer provides or controls (such as devices*

enrolled with Microsoft Intune or within a Microsoft Azure customer's virtual machine or application).

### **Auditing Compliance**

Microsoft will conduct audits of the security of the computers, computing environment, and physical data centers that it uses in processing Customer Data, Professional Service Data, and Personal Data, as follows:

- Where a standard or framework provides for audits, an audit of such control standard or framework will be initiated at least annually.
- Each audit will be performed according to the standards and rules of the regulatory or accreditation body for each applicable control standard or framework.
- Each audit will be performed by qualified, independent, third party security auditors at Microsoft's selection and expense.

Each audit will result in the generation of an audit report ("Microsoft Audit Report"), which Microsoft will make available at <https://servicetrust.microsoft.com/> or another location identified by Microsoft. The Microsoft Audit Report will be Microsoft's Confidential Information and will clearly disclose any material findings by the auditor. Microsoft will promptly remediate issues raised in any Microsoft Audit Report to the satisfaction of the auditor. If Customer requests, Microsoft will provide Customer with each Microsoft Audit Report. The Microsoft Audit Report will be subject to non-disclosure and distribution limitations of Microsoft and the auditor.

To the extent Customer's audit requirements under the Data Protection Requirements cannot reasonably be satisfied through audit reports, documentation or compliance information Microsoft makes generally available to its customers, Microsoft will promptly respond to Customer's additional audit instructions. Before the commencement of an audit, Customer and Microsoft will mutually agree upon the scope, timing, duration, control and evidence requirements, and fees for the audit, provided that this requirement to agree will not permit Microsoft to unreasonably delay performance of the audit. To the extent needed to perform the audit, Microsoft will make the processing systems, facilities and supporting documentation relevant to the processing of Customer Data, Professional Services Data, and Personal Data by Microsoft, its Affiliates, and its Subprocessors available. Such an audit will be conducted by an independent, accredited third-party audit firm, during regular business hours, with reasonable advance notice to Microsoft, and subject to reasonable confidentiality procedures. Neither Customer nor the auditor shall have access to any data from Microsoft's other customers or to Microsoft systems or facilities not involved in providing the applicable Products and Services. Customer is responsible for all costs and fees related to such audit, including all reasonable costs and fees for any and all time Microsoft expends for any such audit, in addition to the rates for services performed by Microsoft. If the audit report generated as a result of Customer's audit includes any finding of material non-compliance, Customer shall share such audit report with Microsoft and Microsoft shall promptly cure any material non-compliance.

Nothing in this section of the DPA varies or modifies the GDPR Terms or affects any supervisory authority's or data subject's rights under the Data Protection Requirements. Microsoft Corporation is an intended third-party beneficiary of this section.

### ***Security Incident Notification***

*If Microsoft becomes aware of a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to Customer Data, Professional Services Data, or Personal Data while processed by Microsoft (each a "Security Incident"), Microsoft will promptly and without undue delay (1) notify Customer of the Security Incident; (2) investigate the Security Incident and provide Customer with detailed information about the Security Incident; (3) take reasonable steps to mitigate the effects and to minimize any damage resulting from the Security Incident.*

*Notification(s) of Security Incidents will be delivered to Customer by any means Microsoft selects, including via email. It is Customer's sole responsibility to ensure Customer maintains accurate contact information with Microsoft for each applicable Product and Professional Service. Customer is solely responsible for complying with its obligations under incident notification laws applicable to Customer and fulfilling any third-party notification obligations related to any Security Incident.*

*Microsoft shall make reasonable efforts to assist Customer in fulfilling Customer's obligation under GDPR Article 33 or other applicable law or regulation to notify the relevant supervisory authority and data subjects about such Security Incident.*

*Microsoft's notification of or response to a Security Incident under this section is not an acknowledgement by Microsoft of any fault or liability with respect to the Security Incident. Customer must notify Microsoft promptly about any possible misuse of its accounts or authentication credentials or any security incident related to the Products and Services.*

## ANNEX A – MICROSOFT SECURITY CONTROLS

**Security Governance.** Security for Azure service offerings involves measures both at the service level and in the form of customer controls that allows customers to customize their use of Azure’s services according to specific organizational requirements.<sup>174</sup> ***This aspect emphasizes a “shared responsibility” for the protection of personal information.***

Microsoft has adopted the ISO/IEC 27018 code of practice, which concerns the processing of personal information by cloud service providers. Microsoft indicates that Azure complies with the ISO/IEC 27001/27002:2022 standards, which defines the security controls required of an information security management system.

At the service level, Microsoft indicates that it follows a “defense-in-depth” philosophy to protect information at the physical, logical and data layers of the service. Security controls are present at each layer of the service to ensure, in the event of the failure of one security measure, that compensating controls maintain data security.

To support its business activities, including the Azure cloud offerings, Microsoft has developed an Information Security Management System (“ISMS”). Microsoft’s ISMS is built on business objectives and security requirements and includes a compliance framework as well as an audit schedule that results in certifications and attestations.

The governance and controls framework of ISMS consists of:

- The *Microsoft Security Policy* suite, which includes the policy, standards, baselines, and standard operating procedures. These are the Microsoft-specific security requirements that must be followed by all Microsoft teams.
- The *Requirements* are a collection of regulatory, statutory, and industry obligations, as well as any additional business requirements that the cloud infrastructure must meet for Microsoft’s cloud services.
- The *Control Activities*, which represent operational work in support of security objectives. Each control activity has an owner and maps to both the Microsoft Security Policy suite and the Requirements.
- *Audits*, which ensure that the performance of control activities meet the Requirements.

This framework is connected by various governance workflows – for example, filing an exception when the policy cannot be met or creating and managing issues when gaps are identified between control activities and requirements.

---

<sup>174</sup> Further information about security measures and technologies for Azure can be found at: <https://learn.microsoft.com/en-us/azure/security/fundamentals/services-technologies>.

**Change Management.** Microsoft indicates that an operational change control procedure exists for Azure and system changes. This procedure considers:

- The identification and documentation of the planned change.
- An assessment process of the potential impact of planned changes.
- Change testing in an approved non-production environment.
- A Change communication plan.
- A Change management approval process.
- A Change abort and recovery plan (when applicable).

Security reviews are conducted every six (6) months.

Capacity planning is conducted to ensure information processing capacity, telecommunications, and environmental support exists and is appropriate during contingency operations.

Changes to any information system are analyzed in a separate test environment before implementation in an operational environment. Production environments are logically partitioned from all other environments (e.g. various development environments) in the same manner. Program managers, Leads or managers can approve changes, but requestors are prohibited from doing so (i.e. approving changes that they request).

**Access.** Microsoft has procedures as well as automated and semi-automated systems for granting and revoking access to the (i) servers in the "Managed" domain that contains customer applications and data as well as (ii) servers in the "Management" domain which provides systems management functions (e.g., monitoring, backup, troubleshooting, software, and patch management).

Personnel in Microsoft's "Access and Identity Group" manage access via Microsoft Entra (formerly known as Active Directory) to the "Managed" and "Management" domains. Authority is granted by the Service Managers in each area using the "Least Privilege Access" principle. Microsoft users of production systems are restricted to only one User ID per system.

Microsoft personnel do not have standing access to any service operation ("zero standing permission"). All access control activities are logged and audited.

Microsoft indicates that none of its personnel has standing access to customer content in Azure. Microsoft Azure uses Microsoft Entra to manage user accounts. Security group membership must be approved by the designated security group owners within Microsoft Azure. Automated procedures are in place to disable Entra ID Directory accounts upon the user's leave date. Domain-level user accounts are disabled after 90 days of inactivity.

Microsoft further indicates that it enforces segregation of duties through user defined groups to minimize the risk of unintentional or unauthorized access or change to production systems. Information system access is restricted based on the user's job responsibilities. The services are being engineered to minimize, to the extent possible, access to customer content by people performing service operations.

In the event a situation involving a user's content requires the assistance of a Microsoft technician or support engineer, that technician or support engineer must be pre-authenticated and undergo dual approvals within Microsoft to be able to respond to the Customer issue.

In responding to an issue, the Microsoft technician would use a Secure Administrative Workstation to address the issue. Upon completion of remediation activities, the administrative permissions are withdrawn. All activities conducted by Microsoft technicians are logged and audited.

Access to the Azure environments is restricted to operations personnel. Development and test teams may be granted access to information provided from the production environment to help troubleshoot issues.

The concept of "data minimization" is used to minimize the actual amount of customer data (usage data, administration account & address book data, regular and core customer data) that is managed on the customer's behalf. This is done by a process of "tiering" to specify which Microsoft internal teams can access what data.

Microsoft personnel build the servers before they are commissioned for the multi-tenant environment. Once a server build is complete, the build teams have their permissions removed. When servers are commissioned, there are limited pathways through which Microsoft personnel may obtain permissions to a system running on a commissioned server. Support staff may obtain access in response to a service ticket that requires access to install software or resolve a problem. In such cases, the audit log would show who logged in and when.

As previously noted, Microsoft conducts abuse monitoring to ensure conformity with its Code of Conduct. This process is similar to that for virus monitoring in that it is an automated process at first but then involves human review if specific activity is flagged for follow up. Some customers may not want Microsoft to do so and to facilitate this Microsoft allows customers who meet additional Limited Access eligibility criteria and attest to specific use cases to apply to modify the Azure OpenAI content management features.

Human reviewers assessing potential abuse, *may or may not be in the same Azure region as the customer's tenant*, can access prompts and completions data only when that data has been flagged by the abuse monitoring system. The human reviewers are authorized Microsoft employees who access the data via point wise queries using request IDs, Secure Access Workstations (SAWs), and Just-In-Time (JIT) request approval granted by team managers. If Microsoft approves a customer's request to modify abuse monitoring, then Microsoft does not store any prompts and completions and, as a result, human review process is not possible and is not performed.

**Tenant Isolation.** "Multi-tenancy" – the sharing of common infrastructure across numerous Customers – is a core concept in the provision of cloud-based services. This, however, raises customer questions about the separation between customers that are hosted on the same infrastructure. This separation, or "tenant isolation", in a multi-tenant environment is necessary to:

- Prevent data leakage or unauthorized access across tenants.
- Prevent the actions of one tenant from adversely affecting the service for another tenant.

A tenant exists in a single partition, and the partition for a tenant is chosen based on properties of the tenant. Secrets and other sensitive information in each partition are encrypted with a dedicated encryption key. Such keys being generated automatically when a new partition is created. Partition information is abstracted away from users.

Based on the number of role instances specified by a customer, Azure creates a virtual machine for each role instance, then runs the role in those VMs. These VMs, in turn, run on a hypervisor that's specifically designed for use in the cloud (the Windows Azure Hypervisor). One VM is special: it runs a hardened operating system called the root OS that hosts a fabric agent. Fabric agents are used in turn to manage guest agents within guest operating systems on customer VMs. Fabric agents also manage storage nodes. The collection of a Windows Azure hypervisor, a root OS/FA, and customer VMs constitute a compute node.

Together with the root OS, the hypervisor enforces constraints on outside communications and divides resources. This is done using network packet filters that assure that the untrusted VMs cannot generate spoofed traffic, cannot receive traffic not addressed to them, cannot direct traffic to protected infrastructure endpoints, and cannot send or receive inappropriate broadcast traffic. This provides the isolation of the root VM from the guest VMs and the guest VMs from one another, managed by the hypervisor and the root OS.

The Azure hypervisor is based on the Windows Hypervisor that has been certified as meeting the Common Criteria for IT Security Evaluation<sup>175</sup>.

*[Remainder of page left intentionally blank.]*

---

<sup>175</sup> The Common Criteria is designed to allow comparisons between independent IT security evaluations. This is achieved by providing a common set of requirements for the security functionality of IT products along with the assurance measures to be applied to them during a security evaluation. The evaluation process is intended to show that the security functionality of the IT product meet the common requirements.

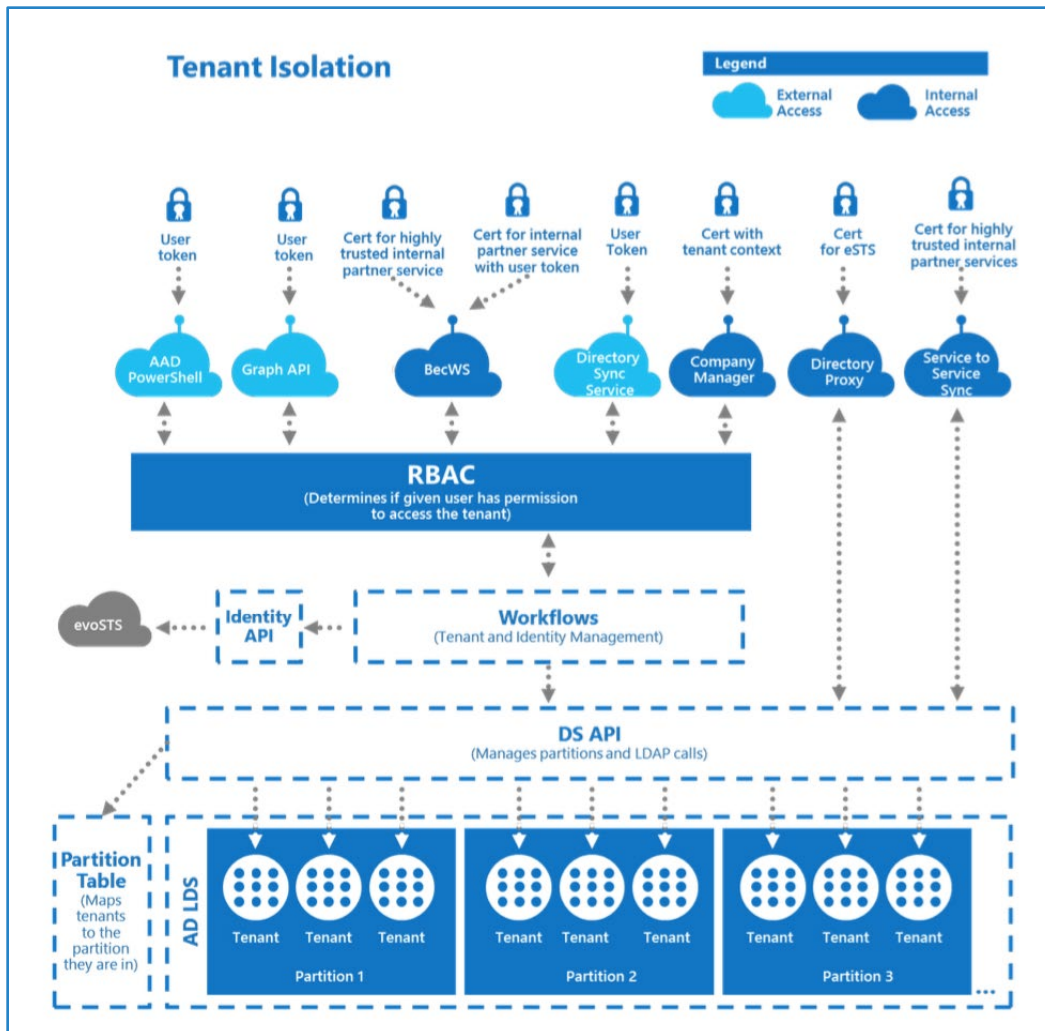


Image 10: Azure AD Internal Topology Indicating Tenant Isolation

**Support.** Microsoft indicates that most support operations are designed to be self-service or automated. Wherever possible, human intervention is replaced by an automated, tool-based process. This includes routine functions such as deployment, debugging, diagnostic collection, and service restarts. Where human intervention is required, it is controlled and isolated from customer content. All access control activities related to providing support to customers using Azure services, including the RBAC functionality, are logged and audited.

Mandatory personal background checks are required for high privilege access. Microsoft also conducts background verification checks of certain operations personnel and limits access to applications, systems, and network infrastructure in proportion to the level of background verification.

**Physical Security.** Microsoft's Canadian data centers are in Quebec City and Toronto. These facilities are designed to run "24x7x365" and employ a variety of measures to minimize the possibility of power failures, physical intrusions, and network outages.

The data centre buildings are nondescript and do not advertise that Microsoft Data Centre hosting services are provided at the location. Access to data centre facilities is restricted. The main interior or

reception areas have electronic card access control devices on the perimeter door(s), which restrict access to the interior facilities. Rooms within the data centres that contain critical systems (servers, generators, electrical panels, network equipment, etc.) are either restricted through various security mechanisms such as electronic card access control, keyed lock and/or biometric devices.

While they are located within non-Microsoft facilities, Microsoft operations within the two data centers are managed, monitored, and administered by Microsoft personnel. Microsoft indicates that the features of these facilities include:

- Perimeter Security: The data centers have “on-premises” security staff on a 24x7 basis.
- Surveillance: The data centres are monitored using motion sensors, video surveillance, and security breach alarms.
- Physical Access controls: Multi-factor authentication is used, including biometric scanning, badges, and smart cards for data centre access.
- Computer rooms: Rooms are equipped with two-factor access control biometric and card readers as well as cameras.
- Segregation: The internal data centre network is segregated from the external network.
- Power: Uninterruptable power supplies and diesel generators are present in the event of a power failure.

Further measures include:

- Role separation to render the location of specific Customer Data unintelligible to the personnel that have physical access.
- The demagnetization and physical destruction of faulty hard drives.
- The physical destruction of decommissioned hard drives.

**Application Security.** The provision of Azure services has several technical security controls. These include:

- Security Update management.
- Data Isolation (within multi-tenant environment).
- Data redundancy.
- Data destruction.
- Operating system security patching.
- Multi-factor authentication for service access.

Azure is a multi-tenant service, where deployments of virtual machines of multiple customers are stored on the same physical hardware. Data storage and processing involves the logical segregation of customers of the same service through the structure and capabilities of Entra ID Directory - specifically developed to help build, manage, and secure multitenant environments.

Azure code development adheres to Microsoft’s Security Development Lifecycle (“SDL”), a process that allows developers to build more secure software and address security compliance requirements. The SDL<sup>176</sup> is a Microsoft-wide, mandatory software development process with the objective of reducing the number and severity of vulnerabilities in Microsoft software. Microsoft indicates that, since 2004, the

---

<sup>176</sup> Further information concerning SDL is publicly available at: <https://www.microsoft.com/en-us/sdl/default.aspx>.

SDL has been used to institutionalize and embed security requirements into the Microsoft product lifecycle (i.e. from planning to design, development, and deployment phases). After a product is made available to Customers, the focus shifts to vulnerabilities. Microsoft indicates that it has created teams have been created to respond to any incidents, and their findings inform the SDL to help improve future products. Microsoft indicates that the Microsoft SDL conforms to ISO/IEC 27034-1:2011.

**Network Security.** It is to be emphasized that security cloud services and resources involves action by both Azure and the customer. In accepting incoming traffic from the Internet, a combination of mechanisms block attacks and harmful traffic while allowing legitimate requests further into the network.

In typical enterprise networks, the core infrastructure is heavily protected at the edge, or perimeter, with multiple layers of security devices. Each layer consists of devices and security policy decisions to be enforced. Devices in this context involves a combination of firewalls, denial of service prevention, intrusion detection or protection systems (“IDS/IPS”), and VPN devices. Policy enforcement can take the form of firewall policies, access control lists (“ACLs”), or specific routing.

Translating this into a cloud context, Azure has a layer to protect against Dedicated Denial of Service attacks. This layer has no user configurable attributes and is not accessible to the customer. It is important to note that Azure DDoS only looks for large-scale attacks and it is possible that a specific service could be overwhelmed before the platform level protection thresholds are reached. For example, a web site on a single A0 IIS server, could be taken offline by a DDoS attack before Azure platform level DDoS protection registered a threat.

The next layer is customer-defined public IP addresses (endpoints), which are used to determine which traffic can pass through the cloud service to the virtual network. Native virtual network isolation ensures complete isolation from all other networks and that traffic only flows through user configured paths and methods. These paths and methods are the next layer, where network security groups (“NSGs”), user data repositories (“UDR”), and network virtual appliances can be used to create security boundaries to protect Customer applications.

These virtual networks are created by customers and are what their workloads are connected to. In these networks, basic network-level security applies. It is a private network (a virtual network overlay) in Azure with the following features and characteristics:

- **Traffic isolation:** VMs in one virtual network cannot communicate directly to VMs in a different virtual network, even if both virtual networks are created by the same customer.
- **Multi-tier topology:** Customers can define a multi-tier topology by allocating subnets and designating separate address spaces for different elements or “tiers” of their workloads. Customers can then define different access policy based on the workload types, and control traffic flows between the tiers.
- **Cross-premises connectivity:** Using VNet Peering, Azure VPN Gateways, third-party network virtual appliances, or ExpressRoute, customers can establish cross-premises connectivity between a virtual network and multiple on-premises sites or other virtual networks in Azure.
- **NSG** allows customers to create rules (ACLs) at the desired level of granularity: network interfaces, individual VMs, or virtual subnets. Customers can control access by permitting or denying communication between the workloads within a virtual network, from systems on customer’s networks via cross-premises connectivity, or direct Internet communication.

- **UDR and IP Forwarding** allow customers to define the communication paths between different tiers within a virtual network. Customers can deploy a firewall, IDS/IPS, and other virtual appliances, and route network traffic through these security appliances for security boundary policy enforcement, auditing, and inspection.
- **Network virtual appliances** such as firewalls, load balancers, and IDS/IPS are available in the Azure Marketplace and the VM Image Gallery. Customers can deploy these appliances into their virtual networks, and specifically, at their security boundaries.

At the interface with the public network, Microsoft uses special-purpose security devices for firewall, NAT, and IP filtering functions. Functions at this layer include denial of service blocking, intrusion detection systems, SSL, and initial access/certificate validation. The edge of the service network houses those servers and services that provide first level authentication and load balancing.

The networks within the Azure datacenters are designed to create multiple, distinct network segments. The preferred method for logically partitioning systems, at the network level, are router ACLs, VLANs, and appropriately placed firewalls. This partitioning strategy is used to separate front end components (e.g. web servers) from the back-end components (e.g. databases or management devices).

For Azure, several network security measures exist:

- Penetration testing.
- Network-level Distributed Denial-of-Service detection and prevention.
- Network isolation.
- Virtual networks.
- Anti-virus and anti-malware protection.
- Anti-spam controls.
- Port scanning and remediation.
- Perimeter vulnerability scanning.

Microsoft indicates that vulnerability assessment and scanning tools are specifically designed to operate in virtualized environments. Procedures have been established and implemented to scan for vulnerabilities on managed hosts. Vulnerability scanning on server operating systems, databases, and network devices is performed, at a minimum, on a quarterly basis.

Microsoft indicates that it also contracts with external penetration testers who also constantly scan the systems. Identified vulnerabilities are tracked and verified for remediation. The Microsoft Security Response Center regularly monitors external security vulnerability awareness sites. Microsoft indicates that Azure software and hardware configurations are reviewed at least quarterly to identify and eliminate any unnecessary functions, ports, protocols, and services.

There is a default “deny-all” policy; and only the specific ports and protocols required for the operation of the service are allowed. All traffic leaving the boundary is for any Azure service is encrypted and restricted.

Filtering routers at the edge of the network provides security at the packet level to prevent unauthorized connections to Azure services.

**Monitoring.** Centralized monitoring, correlation, and analysis systems manage the large amount of information generated by devices within the Azure environment, providing both visibility and alerts to the teams that manage the service.

In addition to addressing software vulnerabilities, one aspect of security is the minimization of operational weaknesses. Microsoft administrative operations, including system access, are logged to provide an audit trail if unauthorized or accidental changes are made. The “administrator audit log” records specific actions performed by administrators and users who have been assigned administrative privileges. Customers can search for and view entries from the administrator audit log for actions performed by Microsoft administrators and delegated administrators.

Access to logs is restricted and defined by policy. Logs are reviewed on a regular basis. Customers are permitted to directly view a subset of logs to verify who has accessed what data, and what they did with it. While customers cannot access system event logs in real-time, Microsoft indicates that it has mechanisms in place to provide access in the event of a security incident and subsequent investigation.

Azure’s security monitoring agent collects users and groups that have been added to VM as well as diagnostics, audit, and IIS logs. Logs are maintained for 90 days and are protected through access controls to authorized users. Restrictions on software installation are maintained through scanning on a periodic basis.

**Anti-malware.** Microsoft indicates that it freely provides *Antimalware for Azure Cloud Services and Virtual Machines* that helps identify and remove viruses, spyware, and other malicious software, with configurable alerts when known malicious or unwanted software attempts to install itself or run on Customer Azure systems. This service is a single-agent solution for applications and tenant environments, designed to run in the background without human intervention.

Microsoft indicates that this service has the following core features:

- **Real-time protection** - monitors activity in Cloud Services and on Virtual Machines to detect and block malware execution.
- **Scheduled scanning** - periodically performs targeted scanning to detect malware, including actively running programs.
- **Malware remediation** - automatically acts on detected malware, such as deleting or quarantining malicious files and cleaning up malicious registry entries.
- **Signature updates** - automatically installs the latest protection signatures (virus definitions) to ensure protection is up to date on a pre-determined frequency.
- **Antimalware Engine updates** – automatically updates the Microsoft Antimalware engine.
- **Antimalware Platform updates** – automatically updates the Microsoft Antimalware platform.
- **Active protection** - reports telemetry metadata about detected threats and suspicious resources to Microsoft Azure to ensure rapid response to the evolving threat landscape, as well as enabling real-time synchronous signature delivery through the Microsoft Active Protection System.
- **Samples reporting** - provides and reports samples to the Microsoft Antimalware service to help refine the service and enable troubleshooting.
- **Exclusions** – allows application and service administrators to configure certain files, processes, and drives to exclude them from protection and scanning for performance and/or other reasons.

- **Antimalware event collection** - records the antimalware service health, suspicious activities, and remediation actions taken in the operating system event log and collects them into the customer's Azure Storage account.

The solution is built on the same anti-malware platform as Microsoft Security Essentials, Microsoft Forefront Endpoint Protection, Microsoft System Center Endpoint Protection, Windows Intune, and Windows Defender for Windows 8.0 and higher.

For Azure services generally, the following malware tools are installed:

1. Microsoft servers
  - a. Microsoft End Point Protection
  - b. System Center EP
  - c. Symantec EP
2. Linux servers
  - a. CLAM AV

Auditors have noted that signature updates are pushed at least every 8 hours.

**Patch Management.** Microsoft also indicates that it has robust patch management systems that are audited and tracked regularly by management. Any issues or requested exceptions require management approval to address. The MSRC releases security bulletins on the second Tuesday of every month ("Patch Tuesday"), or as appropriate to mitigate zero-day exploits. In the event that "proof-of-concept" code is publicly available regarding a possible exploit, or if a new critical security patch is released, patches to affected Azure systems are to be applied to remediate the vulnerability.

**Data Deletion.** In Azure, data destruction techniques vary depending on the type of data object being destroyed - whole subscriptions themselves, storage, Virtual Machines, or databases. In a multi-tenant environment, such as Microsoft Azure, attention also must be paid to ensure that one customer's data does not "leak" into another customer's data, or when a customer deletes data, no other customer (including, in most cases, the customer who once owned the data) can gain access to that deleted data. This highly virtualized storage system ensures, because of tenant isolation, that no tenant has access to an area of storage to which they have not previously written.

**Azure Storage.** In Azure Storage, all disk writes are sequential, and one cannot ensure it is overwritten with other data. The original data will remain on the disk and the new value will be written sequentially. Pointers will be updated such that it is impossible to find the deleted data anymore.

Once the disk is full, the system must write new logs onto disk space that has been freed up by the deletion of old data. Log files are created in a file system running New Technology File System ("NTFS"). A background thread running on Azure Storage nodes frees up space by going through the oldest log file, copying blocks that are still referenced from that oldest log file to the current log file (and updating all pointers as it goes). It then deletes the oldest log file.

As a result, there are two categories of free space on the disk: space that NTFS knows is free, where it allocates new log files from this pool; and space within those log files that Azure Storage knows is free since there are no current pointers to it.

**Azure Virtual Machines.** Virtual Machines are stored in Microsoft Azure Storage as blobs, so the deletion rules apply as indicated above. The virtualization mechanism, however, is designed to ensure that those spots on the disk cannot be read by another customer (or even the same customer) until data is written again, thus mitigating the threat of data leakage. When a new virtual disk is created for a VM, it will appear to the VM to be zeroed, however, the explicit zeroing of the data buffers occurs when a portion of the virtual disk is read before it is written. If a VM instance is reinitialized in place, it is as if it had been moved to new hardware.

**Azure SQL Database.** With Azure SQL Database, deleted data is marked for deletion. If an entire database is deleted, it is the equivalent of deleting the database's entire contents. The SQL Database implementation is designed to ensure user data is never leaked by disallowing all access to the underlying storage except via the SQL Database API. That API allows users to read, write, and delete data, but does not have a way to express the reading of data that the user has not previously written.

**Encryption.**<sup>177</sup> Each Azure storage account has its own unique credentials per access type (read, write, enumerate, and delete). Each set of credentials is held in the secure Key Store and is regularly refreshed.

There are three different types of stores, each with a distinct function:

- Content is stored as encrypted blobs in Azure storage. The key to each chunk of content is encrypted and stored separately in the Content Database. The content itself holds no clue as to how it can be decrypted.
- The Content Database is a SQL Server database. It holds the map required to locate and reassemble all the content blobs held in Azure storage as well as the keys needed to encrypt those blobs. However, the set of keys is itself encrypted. The master key is held in a separate Key Store.
- The Key Store is physically separate from the Content Database and Azure storage. It holds the credentials for each Azure storage container and the master key to the set of encrypted keys held in the Content Database.

Each of these three storage components – the Azure blob store, the Content Database, and the Key Store – is physically separate. The information held in any one of the components is unusable on its own. Without access to all three, it is impossible to retrieve the keys to the chunks, decrypt the keys to make them usable, associate the keys with their corresponding chunks, decrypt each chunk, or reconstruct a document from its constituent chunks.

**Storage Encryption.** Storage Service Encryption (“SSE”) provides customers with the capability to encrypt data at rest, handling encryption, decryption, and key management. All data is encrypted using 256-bit AES encryption. SSE encrypts data when it is written to Azure Storage, and can be used for “block” blobs, “page” blobs and “append” blobs. It works for the following:

- General purpose storage accounts and Blob storage accounts.

---

<sup>177</sup> An overview of the encryption measures taken by Microsoft and available to customers can be found at: <https://docs.microsoft.com/en-us/azure/security/fundamentals/encryption-overview>.

- Standard storage and Premium storage.
- All redundancy levels (LRS, ZRS, GRS, RA-GRS).<sup>178</sup>
- Azure Resource Manager storage accounts.
- All regions.

A customer's Azure portal, using the Settings blade, is used to enable or disable Storage Service Encryption for a storage account.

SSE permits customers to:

- Encrypt block blobs, append blobs, and page blobs.
- Encrypt archived VHDs and templates brought to Azure from on-premises.
- Encrypt underlying OS and data disks for IaaS VMs created using VHDs.

SSE only encrypts newly created data after the encryption is enabled. Data uploaded prior to encryption-enablement will not be encrypted unless they are rewritten or copied. Table, Queues, and Files data will not be encrypted. When the customer needs to access data, data is automatically decrypted before returning to the user.

**Disk Encryption.** Azure Disk Encryption permits customers to encrypt Windows and Linux IaaS virtual machine disks by leveraging the BitLocker feature of Windows and the DM-Crypt feature of Linux to provide volume encryption for the OS and the data disks. Microsoft indicates that the solution is integrated with Azure Key Vault to allow control and management of encryption keys and secrets.

The Azure Disk Encryption allows customers to:

- Enable encryption on new IaaS VMs created from pre-encrypted VHD and encryption keys.
- Enable encryption on new IaaS VMs created from the Azure Gallery images.
- Enable encryption on existing IaaS VMs running in Azure.
- Disable encryption on Windows IaaS VMs.

Azure Disk Encryption for Windows and Linux IaaS VMs is available in all Azure public regions for Standard VMs and VMs with premium storage.

**VM Encryption.** The Azure Security Center will alert customers if they have unencrypted virtual machines. If using Windows 10 to encrypt such machines, customers are to (i) install and configure Azure PowerShell to enable the running of PowerShell commands to set up the prerequisites required to encrypt Azure Virtual Machines; (ii) obtain and run the Azure Disk Encryption Prerequisites Azure PowerShell script.

**BitLocker.** BitLocker can be used to encrypt Customer Content Data at rest at the volume-level. BitLocker key management involves the management of recovery keys that are used to unlock/recover encrypted disks. BitLocker-managed keys are tied to the lifetime of an operating system installed on a server or a given encrypted disk. These keys are generally deleted and reset during server reinstallation or disk formatting.

---

<sup>178</sup> The acronyms represent the replication options available to Customers, specifically: locally redundant storage, zone-redundant storage, geo-redundant storage, and read-access geo-redundant storage.

BitLocker uses recovery keys where an operating system is reinstalled and encrypted data disks already exist. FIPS-compliant algorithms are used to ensure that encryption keys are never stored or sent “in the clear”. The recovery keys are managed outside of BitLocker but used for disk decryption.

**Data in Motion.** Where customers interact with Azure Storage through the Azure Portal, all transactions occur via HTTPS. Storage REST API over HTTPS can also be used to interact with Azure Storage and Azure SQL Database. Within Azure, data can be secured in transit between an application and Azure by using customer-side Encryption, HTTPs, or SMB 3.0.

As for traffic between datacenters, Microsoft deploys applications so that the Customer Content Data is encrypted using TLS or IPSec. All traffic between Microsoft datacenters is encrypted. This includes both application-layer encryption for the Customer Content Data itself, and network transport layer encryption for the communication of the Customer Content Data.

For data in motion, customers are recommended to use SSL/TLS protocols to exchange data across different locations or to isolate the entire communication channel between their on-premises and cloud infrastructure by using a virtual private network (“VPN”).

Microsoft recommends that organizations which need to secure access from one workstation located on-premises to Azure should use Point-to-Site VPN. For secure access from multiple workstations located on-premises to Azure, Microsoft recommends Azure site-to-site VPN.

Larger data sets can be moved over a dedicated high-speed WAN link such as ExpressRoute. If customers choose to use ExpressRoute, they may also encrypt the data at the application-level using SSL/TLS or other protocols for added protection.

**Customer-Side Encryption.** Customers may also encrypt data as well as apply policies on the data to limit or allow actions by the recipient of the data through Azure Rights Management.

Azure Rights Management System (“RMS”) is integrated with Azure Information Protection and uses a 2048-bit RSA asymmetric key with SHA- 256 hash algorithm to encrypt the content.

In a default Azure RMS implementation, Microsoft generates and manages the root key that is unique for each tenant. Access to the root key is always limited to applications and is not provided to any personnel. Customers can access a near real-time log showing all access to the root key at any time.

**Incident Detection and Response.** Microsoft indicates that it has a global, 24/7 incident response service to mitigate the effects of any attacks or malicious activity. Microsoft states that its Cyber Defense Operations Center brings together security response experts from across Microsoft to detect and respond to cyber-threats in real-time. Threat intelligence is built into the products and services to help customers more quickly identify and detect issues early and accurately. Microsoft Azure has developed robust processes to facilitate a coordinated response to incidents if one was to occur.

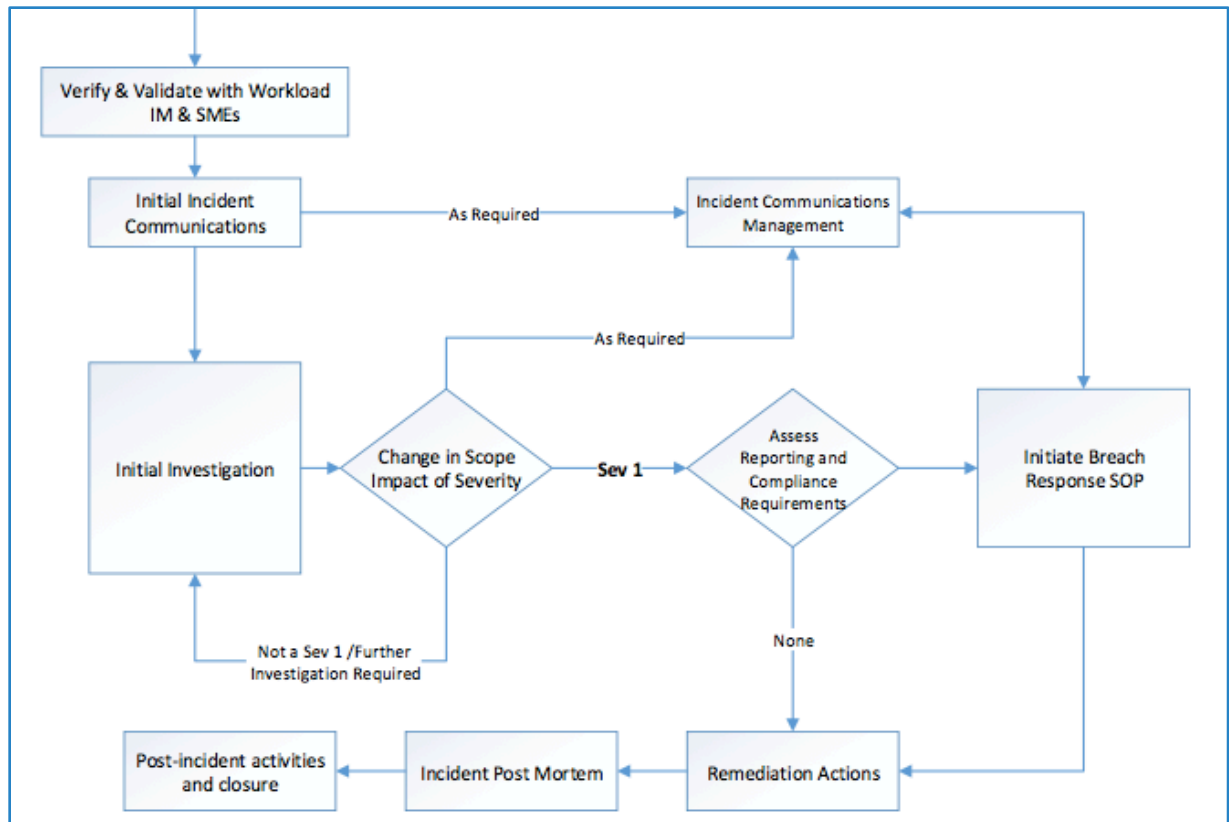


Image 11: Incident Investigation and Response Flow

Depending on the nature of the incident, the Microsoft’s Security Incident Response team may engage one or more subject matter experts from various groups within Microsoft, such as the Online Services Security and Compliance team, Microsoft Threat Intelligence Center, Microsoft Security Response Center, Microsoft Corporate, External & Legal Affairs, and Azure Security.

In the event of a security incident<sup>179</sup>, Microsoft’s policy is to promptly (i) notify Customer of the incident; (ii) investigate the incident and provide the Customer with detailed information about the incident; and (iii) take reasonable steps to mitigate the effects and to minimize any damage resulting from the incident. Notification(s) are to be delivered to one or more of a customer’s administrators by any means Microsoft selects, including email.

Microsoft has adopted an “assume breach” strategy. In doing so, it deploys a dedicated “red team” of software security experts that simulates real-world attacks at the network, platform, and application layers. The objective is to test Azure’s ability to detect, protect against and recover from, breaches. Microsoft’s policy in simulating attacks is that red teams do not target Customer Content Data but rather the Azure infrastructure and platforms.

Microsoft indicates that staff are required to report suspected security incidents. Upon identification, incidents are immediately brought to the attention of the Microsoft Online Services Investigation and

<sup>179</sup> “Security incident” is defined as any unlawful access to any Customer Data stored on Microsoft’s equipment or in Microsoft’s facilities, or unauthorized access to such equipment or facilities resulting in loss, disclosure, or alteration of Customer Content Data.

Response team. Tickets for the incidents are entered into the tracking system and escalated as necessary.

Customers are required to notify Microsoft promptly about any possible misuse of accounts or authentication credentials or any security incident related to an online service offered under Azure.

Contractual obligations in Microsoft's Data Processing Terms require Microsoft to notify affected customers promptly in the event of an incident affecting their data. The means of notifications will vary depending upon the facts of any specific incident.

**Audit.** Azure has several auditing and logging capabilities that permit customers to create an audit trail for applications deployed in Azure and virtual machines created from the Azure Virtual Machines Gallery. Microsoft indicates that audit policies can be customized.

Azure enables customers to perform security event generation and collection from Azure IaaS and PaaS roles to central storage in their subscriptions. Customers can then use HDInsight to aggregate and analyze the collected events. In addition, these collected events can be exported to on-premises security information and event management systems for ongoing monitoring.

Customers may monitor access and usage reporting using Azure's logging of administrative operations, including system access, to create an audit trail in case of unauthorized or accidental changes. Customers can also retrieve audit logs for their Azure Entra ID Directory (formerly Azure Active Directory) tenant, and view access and usage reports.

The Azure Management Portal can be used to view usage and asset reports that include anomalous sign-in events, user-specific reports, and activity logs. The Azure Security Center<sup>180</sup> allows for monitoring and policy management purposes across Azure subscriptions for security purposes. Customers can enable data collection for (i) daily scanning of all supported virtual machines for security monitoring and recommendations and (ii) security events for analysis and threat detection.

Customers can also use Azure Diagnostics -- configured to collect Windows security event logs and other security-specific logs -- to export security alerts to an on-premises Security Incident Event Management tool.

**Third-Party Assessment.** Several independent assessments of Azure have been conducted and these documents are assessable to authorized users via Azure Compliance Offerings<sup>181</sup>. These include:

**ISO/IEC 27001:2022.** Certification under this ISO/IEC 27001:2022 indicates that Microsoft has implemented the security controls defined in this standard. Audits against this standard are performed for Microsoft by BSI Group and address all 14 ISO domains:

- General Information
- Information Security
- Organization of Information Security

---

<sup>180</sup> Further information about the Azure Security Center can be found at <https://docs.microsoft.com/en-us/azure/security-center/security-center-intro>.

<sup>181</sup> Available at: <https://azure.microsoft.com/en-us/overview/trusted-cloud/compliance/>.

- Asset Management
- Human Resources Security
- Physical and Environmental Security
- Communications and Operations Management
- Access Control
- Information Systems Acquisition, Development, and Maintenance
- Information Security Incident Management
- Business Continuity Management
- Risk Management
- Compliance
- Privacy

The certification is valid for a 12-month period at which time re-certification occurs.

**ISO/IEC 27018:2020.** Azure services also meets the requirements of *ISO/IEC 27018:2020 — Information technology — Security techniques — Code of practice for protection of Personally Identifiable Information (PII) in public clouds acting as PII processors*. The certification is valid for a 12-month period at which time re-certification occurs.

**SOC 1 Type 2.** Azure has also been audited against the Service Organization Control (“SOC”) reporting framework for SOC 1 Type 2. The audit report covers the following Azure features/services, including infrastructure, development, operations, and support for Cloud Services as well as infrastructure for Microsoft Online Services. Audits against this standard are performed by Deloitte & Touche LLP.

The SOC 1 Type 2 audit report attests to the design and operating effectiveness of controls. Audits are conducted in accordance with (i) the Statement on Standards for Attestation Engagements No. 16 issued by the Auditing Standards Board of the American Institute of Certified Public Accountants and (ii) International Standard on Assurance Engagements 3402 issued by the International Auditing and Assurance Standards Board.

Similarly, with a SOC 2 Type 1 and/or Type 2 Attestation (AT Section 101), a report is created with respect to the controls relevant to security, availability, processing integrity, confidentiality, and privacy trust principles. While some trust principles may not be applicable depending on the nature of the cloud service (IaaS vs. PaaS vs. SaaS), cloud-based service providers must follow the control requirements specified in AT 101. Microsoft has indicated that the SOC 2 audit report can be shared with Customers who have signed a non-disclosure agreement.

**SOC 3.** Microsoft has also obtained a SOC 3 audit report, which, like a SOC 2 report, is based upon the Trust Service Principles and performed under AT101. The significant difference between the two is that a SOC 3 Report can be generally distributed since it contains less detail and only reports that Microsoft has achieved the Trust Services criteria or not. No description of tests and results or opinion on description of the system is provided.

A SOC 3 report can be provided as a Type II, unlike SOC 1 and SOC 2 where there is a Type I option. SOC 3 reports can be issued on one or multiple Trust Services principles (security, availability, processing integrity, confidentiality, and privacy).

**FedRAMP.** Azure’s Public Cloud Solution has been granted a Provisional Authority to Operate (from the

U.S. Federal Risk and Authorization Management Program (“FedRAMP”) Joint Authorization Board at a Moderate impact level based upon the FIPS 199 classification. FedRAMP is a US government program that provides a standard approach to security assessment, authorization, and monitoring for cloud services used by federal agencies.

## ANNEX B – ENTRA ID DIRECTORY ATTRIBUTES

The following are the attributes that may be used in Entra ID Directory (formerly Active Directory) and associated with an individual.

| Synced Object Attribute | User | Group | Contact (Src) | Description                                                                                                         |
|-------------------------|------|-------|---------------|---------------------------------------------------------------------------------------------------------------------|
| assistant               | Read | -     | Read          | The name of the assistant for an account.                                                                           |
| authOrig                | Read | Read  | Read          | Relationship that indicates that the mailbox for the target object is authorized to send mail to the source object. |
| C                       | -    | -     | Read          | Two-letter ISO 3166 [ISO3166] country code.                                                                         |
| cn                      | Read | Read  | Read          | The common name of the object.                                                                                      |
| co                      | Read | -     | Read          | The country/region in which the person (user or contact) or company is located.                                     |
| company                 | Read | -     | Read          | The person's (user or contact) company name.                                                                        |
| countryCode             | Read | -     | Read          | The country code for person's (user or contact) language of choice.                                                 |
| department              | Read | -     | Read          | The name of the person's (user or contact) department.                                                              |
| description             | Read | Read  | Read          | Human-readable descriptive phrases about the object.                                                                |
| displayName             | Read | Read  | Read          | The display name for an object, usually the combination of the person's first name, middle initial, and last name.  |
| dLMemRejectPerms        | Read | Read  | Read          | Relationship that indicates that members of the target object are not authorized to send mail to the source object. |
| dLMemSubmitPerms        | Read | Read  | Read          | Relationship that indicates that members of the target object are authorized to send mail to the source object.     |
| ExtensionAttribute1     | Read | Read  | Read          | Custom attribute that is defined in the customer on-premises directory.                                             |
| ExtensionAttribute10    | Read | Read  | Read          | Custom attribute that is defined in the customer on-premises directory.                                             |

|                          |      |      |      |                                                                                                |
|--------------------------|------|------|------|------------------------------------------------------------------------------------------------|
| ExtensionAttribute11     | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute12     | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute13     | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute14     | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute15     | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute2      | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute3      | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute4      | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute5      | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute6      | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute7      | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute8      | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| ExtensionAttribute9      | Read | Read | Read | Custom attribute that is defined in the customer on-premises directory.                        |
| facsimiletelephonenumber | Read | -    | Read | Telephone numbers (and, optionally, the parameters) for facsimile terminals.                   |
| givenName                | Read | -    | Read | Name strings that are the part of a person's (user or contact) name that is not their surname. |
| GroupType                | -    | Read | -    | Flag attribute indicating the type of group (security, global, etc.)                           |
| hideDLMembership         | -    | Read | -    | Hide the membership list on a distribution list from senders.                                  |
| homephone                | Read | -    | Read | The person's (user or contact) main home telephone number.                                     |
| info                     | Read | Read | Read | "Notes" field on "Telephone" tab of ADUC.                                                      |

|                          |            |      |      |                                                                                                                                                 |
|--------------------------|------------|------|------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| Initials                 | Read       | -    | Read | Strings of initials of some or all of an individual's names, except the surname(s).                                                             |
| ipPhone                  | Read       | -    | Read | The TCP/IP address for the telephone.                                                                                                           |
| I                        | Read       | -    | Read | Names of a locality or place, such as a city, county, or other geographic region.                                                               |
| legacyExchangeDN         | Read       | Read | Read |                                                                                                                                                 |
| mail                     | Read       | Read | Read | The list of email addresses for a person (user or contact).                                                                                     |
| mailnickname             | Read       | Read | Read |                                                                                                                                                 |
| managedBy                | -          | Read | -    | Resource/owner relationship, where the source object (a group) is the resource, and the target object is the owner.                             |
| manager                  | Read       | -    | Read | Manager/direct report relationship between two individuals, where the source object is the direct report, and the target object is the manager. |
| member                   | -          | Read | -    | Membership of the target object (of class User, Contact, or Group) in the group that is identified as the source object.                        |
| middleName               | Read       | -    | Read | Additional names for a person (user or contact), for example, middle name, patronymic, matronymic, or other names.                              |
| mobile                   | Read       | -    | Read | The primary mobile phone number for a person (user or contact).                                                                                 |
| msDS-HABSeniorityIndex   | Read       | Read | Read |                                                                                                                                                 |
| msDS-PhoneticDisplayName | Read       | Read | Read |                                                                                                                                                 |
| MsExchArchiveGUID        | Read       | -    | -    |                                                                                                                                                 |
| MsExchArchiveName        | Read       | -    | -    |                                                                                                                                                 |
| msExchArchiveStatus      | Read/Write | -    | -    | Created in the Exchange cloud for "write back" to on-premises when the customer has a cloud archive.                                            |
| msExchAssistantName      | Read       | -    | Read | The name of the assistant for an account.                                                                                                       |
| msExchAuditAdmin         | Read       | -    | -    |                                                                                                                                                 |
| msExchAuditDelegate      | Read       | -    | -    |                                                                                                                                                 |
| msExchAuditDelegateAdmin | Read       | -    | -    |                                                                                                                                                 |
| msExchAuditOwner         | Read       | -    | -    |                                                                                                                                                 |
| MsExchBlockedSendersHash | Read/Write | -    | Read | Populated through an upgrade from Business Productivity Online                                                                                  |

Standard Suite. Not synced from on-premises.

|                                         |            |      |      |                                                                                                             |
|-----------------------------------------|------------|------|------|-------------------------------------------------------------------------------------------------------------|
| msExchBypassAudit                       | Read       | -    | -    |                                                                                                             |
| MsExchBypassModerationFromDLMembersLink | Read       | Read | Read |                                                                                                             |
| MsExchBypassModerationLink              | Read       | Read | Read |                                                                                                             |
| msExchCoManagedByLink                   | -          | Read | -    |                                                                                                             |
| msExchDelegateListLink                  | Read       | -    | -    |                                                                                                             |
| msExchELCExpirySuspensionEnd            | Read       | -    | -    |                                                                                                             |
| msExchELCExpirySuspensionStart          | Read       | -    | -    |                                                                                                             |
| msExchELCMailboxFlags                   | Read       | -    | -    |                                                                                                             |
| MsExchEnableModeration                  | Read       | Read | -    |                                                                                                             |
| msExchExtensionCustomAttribute1         | Read       | Read | Read |                                                                                                             |
| msExchExtensionCustomAttribute2         | Read       | Read | Read |                                                                                                             |
| msExchExtensionCustomAttribute3         | Read       | Read | Read |                                                                                                             |
| msExchExtensionCustomAttribute4         | Read       | Read | Read |                                                                                                             |
| msExchExtensionCustomAttribute5         | Read       | Read | Read |                                                                                                             |
| MsExchGroupDepartRestriction            | -          | Read | -    |                                                                                                             |
| MsExchGroupJoinRestriction              | -          | Read | -    |                                                                                                             |
| msExchHideFromAddressLists              | Read       | Read | Read | Indicator to control the visibility of a mail recipient for name resolution.                                |
| MsExchImmutableID                       | Read       | -    | -    |                                                                                                             |
| msExchLitigationHoldDate                | Read       | Read | Read |                                                                                                             |
| msExchLitigationHoldOwner               | Read       | Read | Read |                                                                                                             |
| MsExchMailboxGuid                       | Read       | -    | -    | The GUID of the user's mailbox.                                                                             |
| msExchMailboxAuditEnable                | Read       | -    | -    |                                                                                                             |
| msExchMailboxAuditLogAgeLimit           | Read       | -    | -    |                                                                                                             |
| MsExchModeratedByLink                   | Read       | Read | Read |                                                                                                             |
| MsExchModerationFlags                   | Read       | Read | Read |                                                                                                             |
| MsExchRecipientDisplayType              | Read       | Read | Read |                                                                                                             |
| msExchRecipientTypeDetails              | Read       | Read | Read |                                                                                                             |
| MsExchRemoteRecipientType               | Read       | -    | -    |                                                                                                             |
| msExchRequireAuthToSendTo               | Read       | Read | Read | When enabled for a distribution list (DL), unauthenticated users are rejected.                              |
| MsExchResourceCapacity                  | Read       | -    | -    |                                                                                                             |
| MsExchResourceDisplay                   | Read       | -    | -    |                                                                                                             |
| MsExchResourceMetaData                  | Read       | -    | -    |                                                                                                             |
| MsExchResourceSearchProperties          | Read       | -    | -    |                                                                                                             |
| msExchRetentionComment                  | Read       | Read | Read |                                                                                                             |
| msExchRetentionURL                      | Read       | Read | Read |                                                                                                             |
| MsExchSafeRecipientsHash                | Read/Write | -    | Read | Populated through an upgrade from Business Productivity Online Standard Suite. Not synced from on-premises. |
| MsExchSafeSendersHash                   | Read/Write | -    | Read | Populated through an upgrade from Business                                                                  |

|                                   |            |      |      |                                                                                                                                                        |
|-----------------------------------|------------|------|------|--------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                   |            |      |      | Productivity Online Standard Suite. Not synced from on premises.                                                                                       |
| MsExchSenderHintTranslations      | Read       | Read | Read |                                                                                                                                                        |
| msExchTeamMailboxExpiration       | Read       | -    | -    |                                                                                                                                                        |
| msExchTeamMailboxOwners           | Read       | -    | -    |                                                                                                                                                        |
| msExchTeamMailboxSharePointLinkBy | Read       | -    | -    |                                                                                                                                                        |
| msExchTeamMailboxSharePointUrl    | Read       | -    | -    |                                                                                                                                                        |
| msExchUCVoiceMailSettings         | Read/Write | -    | -    |                                                                                                                                                        |
| msExchUsageLocation               | Read       | -    | -    |                                                                                                                                                        |
| msExchUserHoldPolicies            | Read/Write | -    | -    | Litigation Hold allows cloud services to determine which users are under Litigation Hold                                                               |
| msOrg-IsOrganizational            | -          | Read | -    |                                                                                                                                                        |
| msRTCSIP-ApplicationOptions       | Read       | -    | -    |                                                                                                                                                        |
| msRTCSIP-DeploymentLocator        | Read       | -    | Read | Fully qualified DNS name of the Microsoft Lync Server 2010 deployment, as specified in the authoritative (customer, on-premises) directory.            |
| msRTCSIP-Line                     | Read       | -    | Read | The device ID (either the Session Initiation Protocol (SIP) uniform resource identifier (URI) or the TEL URI) of the telephone that the user controls. |
| msRTCSIP-OwnerUrn                 | Read       | -    | -    |                                                                                                                                                        |
| msRTCSIP-PrimaryUserAddress       | Read       | -    | Read | SIP URI for instant messaging, as specified in the authoritative (customer, on-premise) directory.                                                     |
| msRTCSIP-UserEnabled              | Read       | -    | Read | Indicates whether the user is currently enabled for SIP instant messaging, as specified in the authoritative (customer, on-premises) directory.        |
| msRTCSIP-OptionFlags              | Read       | -    | Read |                                                                                                                                                        |
| objectGUID                        | Read       | Read | Read | Key for the object: this key is immutable, even if the object moves from one context to another, for example, as a result of a company merge or split. |
| oOFReplyToOriginator              | -          | Read | -    | Governs whether out-of-office notifications should be sent to a sender of a message to this distribution list (DL).                                    |
| otherFacsimileTelephone           | Read       | -    | Read | A list of alternative facsimile numbers.                                                                                                               |

|                            |            |            |            |                                                                                                                                                                                                               |
|----------------------------|------------|------------|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| otherHomePhone             | Read       | -          | Read       | A list of alternative home telephone numbers.                                                                                                                                                                 |
| otherIpPhone               | Read       | -          | Read       | A list of alternative TCP/IP addresses for the telephone.                                                                                                                                                     |
| otherMobile                | Read       | -          | Read       | A list of alternative mobile phone numbers.                                                                                                                                                                   |
| otherPager                 | Read       | -          | Read       | A list of alternative pager numbers.                                                                                                                                                                          |
| otherTelephone             | Read       | -          | Read       | A list of alternative office telephone numbers.                                                                                                                                                               |
| pager                      | Read       | -          | Read       | The primary pager number.                                                                                                                                                                                     |
| photo                      | Read       | -          | -          |                                                                                                                                                                                                               |
| physicalDeliveryOfficeName | Read       | -          | Read       | Names that a postal service uses to identify a post office.                                                                                                                                                   |
| postalCode                 | Read       | -          | Read       | Codes that a postal service uses to identify postal service zones.                                                                                                                                            |
| postOfficeBox              | Read       | -          | Read       | Postal box identifiers that a postal service uses when a customer arranges to receive mail at a box on the premises of the postal service.                                                                    |
| PreferredLanguage          | Read       | -          | -          | The preferred written or spoken language for a user.                                                                                                                                                          |
| proxyAddresses             | Read/Write | Read/Write | Read/Write | The address by which a Microsoft Exchange Server recipient object is recognized in a foreign mail system.                                                                                                     |
| PublicDelegates            | Read/Write | Read       | Read       | Cross-premises public delegation: allows users to specify delegates for their mailbox.                                                                                                                        |
| pwdLastSet                 | Read       | -          | -          | The date and time that the password for this account was last changed                                                                                                                                         |
| reportToOriginator         | -          | Read       | -          | Governs whether to send delivery reports to the message originator when a message that is sent to a group is not delivered. The delivery report lets the group owner know that the message was not delivered. |
| ReportToOwner              | -          | Read       | -          |                                                                                                                                                                                                               |
| samAccountName             | Read       | -          | -          |                                                                                                                                                                                                               |
| sn                         | Read       | -          | Read       | Name strings for the family names of a person (user or contact).                                                                                                                                              |
| sourceAnchor               | Read       | Read       | Read       | Mechanical property. Immutable identifier to maintain relationship                                                                                                                                            |

between ADDS and Azure AD.

|                      |      |      |      |                                                                                                                         |
|----------------------|------|------|------|-------------------------------------------------------------------------------------------------------------------------|
| st                   | Read | -    | Read | The full names of states or provinces.                                                                                  |
| streetAddress        | Read | -    | Read | The person's (user or contact) address.                                                                                 |
| targetAddress        | Read | -    | Read | The destination address for the person (user or contact).                                                               |
| TelephoneAssistant   | Read | -    | Read |                                                                                                                         |
| telephoneNumber      | Read | -    | Read | Telephone numbers that comply with the ITU Recommendation E.123.                                                        |
| thumbnailphoto       | Read | -    | Read | Persons Photo - 10kb maximum size limit                                                                                 |
| title                | Read | -    | Read | The title of a person (user or contact) in the person's organizational context.                                         |
| unauthOrig           | Read | Read | Read | Relationship that indicates that the mailbox for the target object is not authorized to send mail to the source object. |
| url                  | Read | -    | Read | The list of alternative web pages.                                                                                      |
| userAccountControl   | Read | -    | -    | Flag attribute to indicate settings.                                                                                    |
| userCertificate      | Read | Read | -    | Contains certificates used as part of the Exchange SMIME feature set.                                                   |
| UserPrincipalName    | Read | -    | -    | The user principal name (UPN) that is an Internet-style logon name for a user, as specified in RFC 822.                 |
| userSMIMECertificate | Read | Read | -    | Contains certificates used as part of the Exchange SMIME feature set.                                                   |
| wWWHomePage          | Read | -    | Read | The primary web page.                                                                                                   |